

Quantification du SCR lié à la non-conformité au règlement DORA

Une cascade dirigée entre les cinq piliers, dont l'état de conformité pilote le
capital

Kélian Kaddouri
ENSAE / Nexialog Consulting
Tuteurs : Hugo Rapior, Caroline Hillairet

22 juillet 2026

Résumé

Ce mémoire quantifie le coût en capital de solvabilité d'un défaut de conformité au règlement DORA (UE 2022/2554) pour un assureur exposé au risque cyber. Il propose un modèle interne partiel où la dépendance entre les cinq piliers de DORA n'est pas portée par une copule *a posteriori*, mais par une **cascade dirigée** : un incident amorcé sur un pilier se propage aux autres selon une matrice d'influence asymétrique W , normalisée à la Leontief de sorte que la stabilité du système est *garantie* et non supposée. Le capital est la VaR à 99,5 % de la perte annuelle ainsi agrégée, et il est fait dépendre de l'**état de conformité** de l'entité par une couche multi-états pilotée dans le temps par une chaîne de Markov, d'où une **trajectoire** de SCR plutôt qu'un chiffre unique.

La contribution centrale n'est pas de *mesurer* cette contagion, mais d'en établir la **frontière d'identifiabilité**. On démontre, sur deux sources qui échouent pour des raisons opposées et jusque sur la meilleure expérience naturelle disponible (le choc de chaîne d'approvisionnement MOVEit), que la *direction* de la contagion n'est pas identifiable sur les données publiques, quand sa *co-occurrence* l'est. Plutôt que de poser un W arbitraire, le mémoire caractérise l'**ensemble** des matrices compatibles avec ce que la donnée fixe et publie le capital en **bornes** sur cet ensemble (identification partielle). Il en résulte un socle calibré et défendable, une bande d'ignorance directionnelle explicitement chiffrée, et une mesure, en euros de capital, de ce qu'un registre d'incidents mieux spécifié ferait gagner.

On en tire le surcoût de non-conformité Δ_{DORA} , sa décomposition et son attribution par pilier (valeur de Shapley, règle d'Euler), et l'ordre de remédiation qui minimise le capital porté. Résultat saillant, énoncé avec sa limite : le **niveau** absolu du SCR est illustratif, car il varie d'un facteur 40 selon la source de sévérité, tandis que les **rapports** et le **classement** des piliers résistent au changement de source. Deux piliers, la gouvernance et la gestion des tiers, dominant robustement les trois autres ; leur ordre relatif, lui, dépend précisément de la direction non identifiée, ce qui délimite exactement ce qu'une élicitation d'expert peut encore apporter.

Mots-clés. Risque cyber ; DORA ; SCR ; Solvabilité II ; théorie des valeurs extrêmes ; cascade dirigée ; identification partielle ; bornes de capital ; chaîne de Markov ; Vasicek.

Abstract. *This thesis quantifies the solvency-capital cost of DORA non-compliance for a cyber-exposed insurer. Dependence across the five DORA pillars is carried by a **directed cascade** rather than an a posteriori copula : a pillar-initiated incident propagates through an asymmetric, Leontief-normalised influence matrix, and the capital charge is made to depend on the firm's **compliance state** through a Markov-driven multi-state layer. The central contribution is not to measure this contagion but to establish its **identifiability boundary** : the direction of propagation is shown to be non-identifiable from public data, even under the best available natural experiment, whereas its co-occurrence is not. Rather than positing an arbitrary matrix, the thesis characterises the **set** of matrices consistent with the data and reports capital as **bounds** over that set (partial identification), together with the euro value of the incident-registry data that would tighten them. The absolute capital level is shown to be illustrative (it moves by a factor of forty with the severity source), whereas the pillar ranking is robust ; the two leading pillars dominate the rest, but their internal order depends on precisely the direction that the data leaves unidentified.*

Table des matières

Résumé	1
1 Introduction	4
1.1 Le vide que ce mémoire comble	4
1.2 Un seul fil, en cinq mouvements	4
1.3 Contribution et plan	5
2 État de l’art et positionnement	6
2.1 Le mécanisme, et sa signature	6
2.2 Positionnement : pourquoi le mécanisme est irréductible	7
2.3 Revue de littérature, par thème	7
2.4 Où se situe ce mémoire	8
3 Cadre réglementaire	9
4 Données et limites	14
5 Le socle mécaniste : fréquence et sévérité	22
6 La cascade dirigée	29
6.1 Le point de départ : le Vasicek à un facteur, et pourquoi il ne suffit pas	29
6.2 Généralisation A : la structure systémique dépend du pilier	29
6.3 Généralisation B : la propagation dirigée	30
6.4 La normalisation de Leontief : une stabilité garantie	30
6.5 La cascade est un processus de branchement	31
6.6 Le seuil K_j : ce qui remplace $\Phi^{-1}(\text{PD})$	32
6.7 Calibration et faisabilité	32
6.8 Formalisation : définitions et propriétés	33
7 Trois propriétés du modèle	35
7.1 La criticité dépend de l’ordre, non de l’ensemble	35
7.2 La normalisation de Leontief borne la propagation	35
7.3 La direction n’est pas identifiée, et cela coûte	36
8 L’identifiabilité de la contagion dirigée	37
8.1 Ce qu’identifier W exigerait	37
8.2 Deux échecs opposés	37
8.3 La meilleure expérience naturelle disponible : le choc MOVEit	38
8.4 Identification partielle : la frontière explicite	39
8.5 La donnée manquante comme livrable	39

9	Identification partielle et bornes de capital	40
9.1	Le modèle en couches	40
9.2	Ce que le capital devient	40
9.3	Poser W ou le borner : la comparaison avant élicitation	41
9.4	Le niveau est illustratif, le rapport est le résultat	41
9.5	L'échelle de repli sur la direction	43
10	La conformité multi-états	44
10.1	Le principe des deux échelles de temps	44
10.2	Le Vasicek multi-états : latente et seuils ordonnés	44
10.3	Les trois canaux : comment l'état pilote la cascade	45
10.4	L'état par pilier	45
10.5	La chaîne de Markov et les séjours de type phase	45
10.6	Le couplage systémique et l'analogie de crédit	46
11	Résultats	47
11.1	SCR par état de conformité	47
11.2	Décomposition par pilier	50
11.3	Allocation du capital : Shapley et Euler	51
11.3.1	Shapley : attribuer le surcoût, interaction comprise	51
11.3.2	Euler : allouer le niveau, et une limite d'estimation assumée	51
11.4	Trajectoire du capital	53
11.5	Priorisation de la remédiation	53
11.6	Robustesse	54
11.7	Benchmark : la dépendance n'est pas le mécanisme	55
11.8	Mise en regard réglementaire	56
11.9	Un ordre de grandeur à l'épreuve du réel	57
12	Inventaire des hypothèses et de leur sensibilité	59
12.1	L'argument de robustesse, en une table	59
12.2	Tableau des paramètres non calibrés (et de leur sensibilité)	60
13	Conclusion	61
13.1	Ce qui est établi	61
13.2	Ce qui est démontré comme non mesurable	61
13.3	Ce qui en découle pour le régulateur	61
13.4	Limites, sans détour	61
13.5	Ouvertures	62
A	Démonstrations : le modèle de cascade	63
B	Démonstrations	65
C	Table des notations	67

1 Introduction

Question centrale. Comment traduire un niveau de non-conformité à DORA, même hypothétique ou graduel, en une distribution de pertes puis en une charge de capital ? Le mémoire ne pose pas la question *l'entité est-elle conforme aujourd'hui*, mais *combien coûte en capital de ne pas se conformer*.

Le règlement DORA, entré en application en janvier 2025, impose aux entités financières la maîtrise de cinq domaines de résilience opérationnelle numérique : la gouvernance du risque lié aux technologies (P1), la gestion et la notification des incidents (P2), les tests de résilience (P3), la gestion du risque lié aux prestataires tiers (P4) et le partage d'informations sur les cybermenaces (P5). Ces cinq piliers ne sont pas des cases indépendantes à cocher : ce sont des domaines de *contrôle*, et la défaillance de l'un dégrade la capacité de l'entité à tenir les autres. Une gouvernance défaillante retarde la détection des incidents ; une dépendance non maîtrisée à un prestataire ouvre une porte que les tests n'ont pas explorée. La non-conformité ne reste pas dans son pilier, elle se propage.

1.1 Le vide que ce mémoire comble

Aucun dispositif prudentiel ne traduit aujourd'hui ce niveau de maîtrise en capital. La Formule Standard de Solvabilité II charge le risque opérationnel par un pourcentage de primes ou de provisions, entièrement **aveugle** au fait qu'une entité soit exemplaire ou défaillante sur DORA. Une copule capturerait bien la co-occurrence des pertes, mais symétriquement : elle ne distingue pas une défaillance qui *entraîne* les autres d'une défaillance qui les *subit*. Or c'est précisément cette asymétrie, la direction de la propagation, qui devrait commander la priorité de remédiation d'un assureur. C'est le vide que le mémoire vient combler, sans prétendre à ce que la donnée ne permet pas.

1.2 Un seul fil, en cinq mouvements

Le mémoire poursuit une seule question, *combien coûte la non-conformité à DORA, et jusqu'où peut-on l'affirmer*, à travers cinq mouvements qui s'enchaînent. On **construit** d'abord le mécanisme, la cascade dirigée, et l'on en démontre les propriétés (chapitres 6 et 7). On **délimite** ensuite ce que la donnée permet d'en estimer : la frontière d'identifiabilité (chapitre 8). On **transforme** cette limite en méthode, l'identification partielle, qui borne le capital plutôt que de poser un paramètre inconnu (chapitre 9). On **fait alors parler** le modèle : la conformité devient un état qui évolue et pilote une trajectoire de capital (chapitre 10), d'où le surcoût, son attribution et l'ordre de remédiation (chapitre 11). On **met en regard**, enfin, ce que les cadres existants savent en exprimer. Les deux derniers mouvements, la trajectoire et les résultats, ne sont pas une thèse parallèle : ils sont l'*objet* que les trois premiers apprennent à lire avec la bonne prudence. Chaque niveau qu'ils affichent est illustratif, chaque hiérarchie qu'ils proposent est ce qui reste vrai une fois la limite d'identification prise en compte.

1.3 Contribution et plan

Le mémoire s’articule autour de trois apports, et il est aussi explicite sur ce qu’il *n’affirme pas* que sur ce qu’il établit.

1. Un **mécanisme** de dépendance dirigée et à l’ordre entre les piliers, la cascade, dont on démontre trois propriétés (chapitres 6 et 7) : la criticité dépend de l’*ordre* de la chaîne et non du seul ensemble des piliers touchés, ce qu’aucune dépendance symétrique ne reproduit ; la normalisation de Leontief borne la propagation ; et une matrice et sa transposée, indistinguables pour la donnée, donnent un capital et une décision différents.
2. Une **frontière d’identifiabilité**, démontrée (chapitre 8) puis muée en méthode (chapitre 9) : la direction n’étant pas identifiable, on ne la pose pas, on borne le capital sur l’ensemble des matrices admissibles, et l’on chiffre en euros la valeur de la donnée manquante.
3. Une **lecture décisionnelle** : le surcoût Δ_{DORA} , son attribution par pilier (Shapley, Euler) et l’ordre de remédiation, présentés en rapports et en bornes plutôt qu’en niveaux (chapitre 11).

Ce que le mémoire ne prétend pas. La matrice de contagion n’est jamais présentée comme calibrée : elle est normative, élicitée, et bornée par une analyse de sensibilité. Le niveau absolu du SCR est illustratif, non une mesure : c’est l’effet *relatif* de la conformité et la hiérarchie des piliers qui sont défendus. Cette discipline n’est pas une précaution rhétorique, elle est un résultat, et le fil directeur du document.

2 État de l’art et positionnement

La modélisation actuarielle du risque cyber s’est construite en trois vagues, dont ce mémoire hérite les acquis tout en s’en démarquant sur un point. La première interroge l’**assurabilité** même du risque et la rareté des données (Biener et al., 2015), et pose les marges par la théorie des valeurs extrêmes. La deuxième modélise la **contagion**, mais entre entités d’un portefeuille, par des modèles de réseau ou épidémiologiques. La troisième saisit la **dynamique temporelle** des arrivées par des processus de Hawkes. Le présent travail emprunte à chacune ses marges empiriques et son cadre de risque extrême, et emprunte au risque de crédit deux outils structurels que la littérature cyber n’avait pas mobilisés ensemble : le processus de **branchement multitype**, qui décrit la propagation d’un incident entre piliers (chapitre 6), et les **modèles multi-états** de type migration de rating, qui font dépendre le capital de l’état de conformité (chapitre 10). Sa démarcation tient en un mécanisme que ces trois vagues laissent de côté, exposé ci-dessous.

La contribution en une phrase. Là où la littérature cyber actuarielle modélise soit la *co-occurrence* (copules, chocs communs), soit la *contagion entre entités* (réseaux, épidémiologie), soit la *dynamique temporelle* (Hawkes), ce mémoire introduit une **dépendance dirigée et à l’ordre entre les domaines de contrôle réglementaires** (les piliers DORA) au sein d’une même entité, et la traduit en SCR. Sa signature est que la criticité dépend de l’**ordre** de la chaîne et non du seul ensemble des piliers touchés, ce qu’aucune des approches recensées ne peut reproduire.

2.1 Le mécanisme, et sa signature

La cascade dirigée pose une matrice W de contagion entre piliers, où W_{jk} mesure la propension d’une défaillance de k à entraîner celle de j . Trois propriétés la distinguent : elle est **dirigée** ($W_{jk} \neq W_{kj}$), elle autorise les **cycles** ($P1 \rightarrow P2 \rightarrow \dots \rightarrow P1$), stabilisés par la normalisation de Leontief ($\rho(W) \leq g < 1$, forme réduite $(I - W)^{-1}$), et surtout elle est **à l’ordre** : la criticité d’une chaîne n’est pas une fonction de l’*ensemble* des piliers touchés, elle dépend de l’*ordre* dans lequel ils le sont. Ce n’est pas une intuition : sur les 26 sous-ensembles de taille au moins deux, **22 changent de criticité selon l’ordre**, avec un écart atteignant **6 points sur une échelle de 10** (la chaîne $P1 \rightarrow P2$ vaut 8, la chaîne $P2 \rightarrow P1$ vaut 2). Or toute dépendance symétrique et tout score additif sont, par construction, invariants par permutation : **aucun ne peut reproduire cela**.

Remarque de méthode, et ce qui n’est pas revendiqué. Une propriété plus forte, la *non-transitivité* de la dominance entre piliers, a été testée dans trois formulations : la transitivité des corrélations qu’impose un modèle à facteur unique, la positivité de la dépendance symétrisée, et l’existence de cycles de dominance par paire. **Aucune ne se vérifie** sur ce modèle. Elle n’est donc pas revendiquée. La dépendance à l’ordre, elle, se vérifie, et elle exclut exactement les mêmes concurrents. Signaler l’énoncé que l’on a testé et abandonné vaut mieux que de le laisser à la sagacité du lecteur.

2.2 Positionnement : pourquoi le mécanisme est irréductible

Approche	Dir.	Ordre	Cycles	Propag.	Donnée requise	Objet modélisé
Matrices de risque / AMDEC	×	×	×	×	dires d'expert	risques listés (proba × gravité)
Copule (Gumbel, gaussienne)	×	×	×	×	co-mouvement observé	briques de perte
Réseau / épidémiologie (SIR)	✓	×	✓	✓	structure réseau + taux d'infection	entités d'un portefeuille
Hawkes (multivarié)	✓	×	✓	✓	horodatage fin des arrivées	types d'attaque, dans le temps
Réseau bayésien	✓	×	×	✓	tables de proba conditionnelle	variables d'un graphe acyclique
Cascade (ici)	dirigée	✓	✓	✓	jugement d'expert (élicité)	domaines de contrôle (piliers) d'une entité

Point par point :

- **Matrices de risque / AMDEC** (le standard praticien, $RPN = \text{gravité} \times \text{occurrence} \times \text{détection}$) : listent et notent des risques mais n'ont *aucune* propagation ni direction. La cascade ajoute exactement la couche qui leur manque.
- **Copules** (Böhme and Kataria, 2006 ; Herath and Herath, 2011) : capturent la dépendance de queue entre pertes, mais **symétrique** : elles ne distinguent pas $k \rightarrow j$ de $j \rightarrow k$. Notre benchmark le chiffre : une copule ne peut pas exprimer la propagation (interaction moyenne +0 par construction contre +560 M€ pour la cascade), et sa priorité de remédiation suit les *réceptacles*, la cascade les *sources*.
- **Modèles réseau et épidémiologiques** (Hillairet and Lopez, 2021 ; Hillairet et al., 2022 ; Xu and Hua, 2017 ; Baldwin et al., 2017) : ils modélisent la vraie contagion, mais **entre entités** d'un portefeuille, et **exigent la structure du réseau** et des taux d'infection, données indisponibles ici. Nous *empruntons* à Hillairet et Lopez la logique d'états de conformité, mais l'appliquons **entre piliers** d'une entité, pas entre assurés.
- **Hawkes** (Bessy-Roland et al., 2021 ; Boumezoued et al., 2023) : modélisent l'auto-excitation de la **fréquence dans le temps**, entre *types d'attaque*, pas la structure inter-piliers. Nous montrons (chapitre ??) que sur la fréquence d'entrée, l'excitation est intra-journalière et exogène, et nous ne l'ajoutons pas ; ce constat rejoint leur raffinement two-phase de 2023.
- **Réseaux bayésiens** : peuvent porter la direction, mais supposent un graphe **acyclique** (pas de cycle de contagion) et des tables de probabilités conditionnelles qui se heurtent au **même mur d'identification** que W (chapitre 8). La forme de Leontief, elle, gère les cycles.

2.3 Revue de littérature, par thème

Dépendance et accumulation. La modélisation actuarielle du cyber a d'abord traité la *corrélation* entre risques par copules (Böhme and Kataria, 2006 ; Herath and Herath, 2011) et par chocs communs. Ces approches capturent l'accumulation (que nos données confirment, concentration journalière de Gini 0,69) mais restent symétriques.

Contagion structurée. Une seconde vague introduit la propagation : Hillairet and Lopez (2021) couplent des processus de comptage à un modèle épidémiologique compartimental (type SIR) pour la contagion dans un portefeuille ; Hillairet et al. (2022) ajoutent une structure de réseau ; Xu and Hua (2017) et Baldwin et al. (2017) modélisent la contagion entre cibles. Toutes exigent la donnée de réseau ou d'infection.

Dynamique temporelle. La fréquence auto-excitée est traitée par les processus de Hawkes : Bessy-Roland et al. (2021) sur données PRC (dont notre source dérive), puis Boumezoued et al. (2023) avec un terme exogène; Hillairet et al. (2021) en développent la théorie pour le pricing de dérivés; Peng et al. (2016) sur des taux d’attaque horodatés. Notre travail se situe dans cette lignée mais en *sort* sur la fréquence d’entrée, pour les raisons données au chapitre ??.

Fréquence, sévérité, queue. Sur les marges, Edwards et al. (2016) ajustent des lois discrètes (binomiale négative) au nombre journalier de brèches; Lu et al. (2024) séparent fréquence et nombre de brèches par événement (structure de paquet qui soutient notre Poisson composé); Farkas et al. (2021) tarifent par arbres de régression GPD. Nous en retenons la théorie des valeurs extrêmes (indice de queue ξ) et la structure de paquet.

Cadre structurel. Le squelette quantitatif emprunte au modèle à facteur de Vasicek (2002) (risque de crédit) l’idée d’un stress latent à composante systémique, et à l’analyse entrées-sorties de Leontief (1936) la normalisation qui garantit la stabilité d’une contagion *avec cycles*. La nouveauté est de faire porter cette mécanique par une matrice **dirigée** entre domaines de contrôle réglementaires.

2.4 Où se situe ce mémoire

Le mémoire **emprunte** ce qui est établi et ancré sur données (la queue de sévérité par EVT, la structure de paquet de la fréquence, la logique d’états de conformité de Hillairet et Lopez) et **ajoute** deux choses absentes de la littérature : (i) une dépendance **dirigée et à l’ordre** entre les piliers DORA, traduite en capital; (ii) une **frontière d’identifiabilité** explicite, muée en spécification de reporting. Aucune des références recensées ne modélise une dépendance dirigée entre domaines de contrôle au sein d’une entité, ni ne la relie au SCR.

La revendication de nouveauté, défendable. « Je n’invente pas une nouvelle loi de sévérité ni un nouveau processus de fréquence : sur ces marges, je m’appuie sur la littérature établie et je la calibre. Ma contribution est le **mécanisme de dépendance** lui-même, dirigé et à l’ordre entre piliers réglementaires, que ni les copules (symétriques), ni les modèles de réseau (qui exigent une donnée absente), ni les processus de Hawkes (qui vivent dans le temps) ne capturent, et que je traduis en capital tout en démontrant sa limite d’identification. » C’est une nouveauté *maîtrisée* : neuve sur le mécanisme, sobre sur le reste, honnête sur les limites.

3 Cadre réglementaire

La quantification du capital requis au titre de la non-conformité au règlement DORA s'inscrit dans un écosystème prudentiel dont il importe de retracer l'architecture. Le risque que nous cherchons à modéliser — le risque opérationnel d'origine technologique, et le risque de manquement aux exigences de résilience numérique — se situe à l'intersection de trois cadres réglementaires construits successivement, selon des philosophies distinctes mais convergentes : le dispositif bancaire de Bâle, la directive Solvabilité II propre à l'assurance, et le règlement transsectoriel DORA. Cette section retrace cette construction, identifie le *pont quantitatif* que DORA permet d'établir entre exigence de capital et résilience opérationnelle, et formalise la non-conformité comme une variable latente exploitable dans l'évaluation interne des risques.

Le risque opérationnel : une définition partagée, des traitements divergents. Le risque opérationnel a connu, au cours des deux dernières décennies, une mutation profonde marquée par une recherche de convergence entre les secteurs bancaire et assurantiel. Défini par le Comité de Bâle puis repris par la directive Solvabilité II, il désigne le risque de perte résultant de l'inadaptation ou de la défaillance de procédures internes, de personnels et de systèmes, ou d'événements extérieurs. Cette définition inclut le risque juridique mais exclut les risques stratégiques et de réputation.

Si la définition est partagée, les modes de quantification ont divergé. Le secteur bancaire a progressivement abandonné les modèles internes au profit d'une approche standardisée, tandis que l'assurance a conservé une liberté méthodologique. Cette asymétrie, que nous détaillons ci-après, éclaire le choix méthodologique du présent mémoire : c'est précisément parce que Solvabilité II laisse subsister un espace de modélisation interne que la quantification du risque cyber sous forme d'une distribution de pertes y conserve toute sa pertinence.

Bâle III/IV : du modèle interne AMA à la standardisation SMA. Sous le régime de Bâle II, les établissements bancaires d'envergure internationale étaient encouragés à développer des modèles internes complexes, regroupés sous l'appellation d'approche de mesure avancée (*Advanced Measurement Approaches*, AMA). Ces modèles reposaient principalement sur l'approche par distribution des pertes (*Loss Distribution Approach*, LDA) ou sur des approches par scénarios. Le présent mémoire en reprend les deux marges, fréquence et sévérité, mais en remplace l'agrégation par une cascade dirigée (chapitre 6). S'ils offraient une grande flexibilité théorique, ils ont engendré une variabilité excessive et difficilement justifiable des actifs pondérés par le risque d'un établissement à l'autre, érodant la confiance des superviseurs dans les ratios de solvabilité déclarés.

La finalisation des réformes de Bâle III, communément désignée sous le nom de Bâle IV, a acté le retrait des modèles internes AMA pour le calcul du capital de Pilier 1, à compter du 1^{er} janvier 2022, au profit d'une méthode unique et comparable : l'approche d'évaluation standardisée (*Standardised Measurement Approach*, SMA). L'exigence de capital pour risque opérationnel (*ORC*) s'exprime alors comme le produit d'une composante de volume d'activité, le *Business Indicator Component* (*BIC*), et d'un facteur d'échelle fondé sur l'historique des pertes internes, l'*Internal Loss Multiplier* (*ILM*) :

$$ORC = BIC \times ILM, \quad RWA_{Op} = 12,5 \times ORC. \quad (3.1)$$

Le *Business Indicator* synthétise la taille de l'établissement à partir de trois composantes comptables (intérêts et dividendes, services, activité financière), auxquelles sont appliqués des coefficients marginaux croissants par tranches. Le profil de risque propre est réintroduit par l'*ILM*, qui compare le *BIC* à la composante de pertes historiques *LC*, égale à quinze fois la moyenne des pertes opérationnelles annuelles significatives des dix dernières années. Lorsque la sinistralité historique est faible relativement à l'activité ($LC < BIC$), l'*ILM* est inférieur à l'unité et réduit l'exigence ; lorsqu'elle est élevée, il agit comme une pénalité en fonds propres.

Enseignement pour notre démarche. Le retrait de l'AMA n'invalide nullement l'approche LDA en tant qu'outil de modélisation : il en restreint l'usage *pour le calcul réglementaire de Pilier 1 dans le secteur bancaire*. La logique de la composante *LC* — faire dépendre le capital de l'historique réel des pertes — demeure parfaitement pertinente, et c'est cette logique, transposée à l'assurance et enrichie de la théorie des valeurs extrêmes, que nous mettons en oeuvre.

Solvabilité II : l'asymétrie réglementaire et le maintien du choix méthodologique. Contrairement au secteur bancaire, le secteur de l'assurance conserve sous Solvabilité II une liberté de choix pour la quantification du risque opérationnel : formule standard, paramètres propres à l'entreprise (USP), ou modèle interne, partiel ou global, approuvé par l'autorité de contrôle. Dans la formule standard, l'exigence pour risque opérationnel (SCR_{Op}) s'ajoute de manière additive au capital de solvabilité requis de base ($BSCR$), ajusté de la capacité d'absorption des pertes :

$$SCR = BSCR + Adj + SCR_{Op}, \quad SCR_{Op} = \min(0,3 \times BSCR, Op) + 0,25 \times Exp_{ul}, \quad (3.2)$$

où $Op = \max(Op_{premiums}, Op_{provisions})$ est calculé à partir de coefficients forfaitaires appliqués aux primes et provisions, vie et non-vie. Nous en donnons ici la forme simplifiée ; la formule complète de l'Article 204 du règlement délégué 2015/35 comporte en outre des termes de croissance, sous la forme $\max(0; 0,04 \times \Delta)$, pénalisant les hausses de primes supérieures à 20 % d'un exercice à l'autre.

Cette approche présente une faiblesse conceptuelle majeure pour l'actuaire. En se fondant exclusivement sur des indicateurs de volume, elle pose l'hypothèse implicite que deux assureurs gérant le même volume de primes présentent une exposition identique au risque opérationnel — indépendamment de la qualité de leur infrastructure informatique, du degré d'automatisation de leurs processus, ou de leur dépendance à des prestataires d'externalisation critiques. Or c'est précisément cette dépendance technologique que DORA vient encadrer, et dont nous cherchons à mesurer l'effet sur le capital.

Pilier 1 et Pilier 2. Le SCR_{Op} relève du Pilier 1, quantitatif et forfaitaire. Mais Solvabilité II comporte un second pilier, l'évaluation interne des risques et de la solvabilité (*Own Risk and Solvency Assessment*, ORSA), qui impose à l'assureur une évaluation prospective de l'adéquation entre son profil de risque réel et ses besoins de solvabilité. C'est dans le cadre de l'ORSA — et non du forfait de Pilier 1, plafonné à 30 % du $BSCR$ — que notre modélisation trouve sa place naturelle : l'ORSA autorise, et même encourage, le recours à des scénarios de stress stochastiques que la formule standard ne sait pas produire.

DORA : un cadre transversal de résilience opérationnelle numérique. Face à l'insuffisance des exigences de capital de Pilier 1 pour garantir la continuité des opérations en cas de crise informatique d'envergure, l'Union européenne a introduit le règlement sur la résilience opérationnelle numérique du secteur financier (*Digital Operational Resilience Act*, règlement UE 2022/2554). Entré en application le 17 janvier 2025, DORA agit comme une *lex specialis* par rapport à la directive NIS 2 et harmonise les obligations de gestion des risques liés aux technologies de l'information et de la communication (TIC) à travers vingt-et-une catégories d'entités financières : banques,

entreprises d'assurance et de réassurance, intermédiaires, ainsi que les prestataires tiers critiques de services TIC.

Le postulat de DORA est que la résilience opérationnelle ne saurait se réduire à l'allocation de tampons de fonds propres. Le règlement impose un cadre proactif, articulé autour de la capacité à *résister, absorber, récupérer et s'adapter* face aux perturbations informatiques majeures.

Position dans l'écosystème. La progression Bâle → Solvabilité II → DORA traduit un déplacement du centre de gravité prudentiel : de la *couverture financière* du risque (détenir assez de capital) vers la *continuité opérationnelle* (rester capable d'opérer). DORA ne remplace pas les exigences de capital ; il en révèle l'angle mort, à savoir la dynamique propre des défaillances technologiques, que ni le *SCR_{Op}* forfaitaire ni l'ORSA qualitatif ne savaient capturer.

Le règlement DORA structure ses exigences autour de cinq piliers, qui couvrent l'ensemble du cycle de vie du risque informatique, de sa prévention à sa résolution. Chacun d'entre eux introduit une granularité que ni la formule standard, ni l'ORSA qualitatif traditionnel ne parvenaient à atteindre.

Pilier 1 — Gouvernance et gestion du risque TIC. DORA impose l'existence d'un cadre de gouvernance formalisé, porté au plus haut niveau de l'organe de direction, incluant une cartographie des actifs informationnels et des dépendances critiques, une politique de sécurité documentée, et un dispositif de contrôle interne capable d'identifier et de corriger les faiblesses technologiques de façon continue — non plus seulement lors d'audits ponctuels.

Pilier 2 — Gestion, classification et notification des incidents. Les entités doivent disposer d'un processus structuré de détection, de qualification et de suivi des incidents liés aux TIC. Les incidents jugés majeurs doivent être notifiés selon un calendrier resserré : une alerte sous quatre heures après classification (et au plus tard vingt-quatre heures après détection), un rapport intermédiaire sous soixante-douze heures, puis un rapport final sous un mois.

Pilier 3 — Tests de résilience opérationnelle numérique. Il ne suffit plus de documenter des procédures : elles doivent être éprouvées. Les entités identifiées comme significatives sont soumises à des tests de pénétration guidés par la menace (*Threat-Led Penetration Testing*, TLPT), à mener au moins tous les trois ans, en conditions proches du réel.

Pilier 4 — Gestion du risque lié aux prestataires tiers ICT. Ce pilier est central dans un environnement marqué par l'externalisation et le recours au cloud. Il impose une cartographie exhaustive des contrats critiques via un Registre d'Informations harmonisé, une gouvernance contractuelle renforcée (clauses impératives de l'article 30), et une surveillance directe des prestataires tiers critiques par les autorités européennes, jusqu'au rang 3 de la chaîne de sous-traitance.

Pilier 5 — Partage d'informations sur les cybermenaces. DORA encourage les entités à partager, de façon volontaire et encadrée, des informations sur les menaces observées, dans une logique de résilience collective. Ce pilier reste moins directement mobilisable dans le calibrage actuariel du présent mémoire, mais il rappelle que DORA porte aussi une dimension systémique de la résilience numérique, au-delà de la seule entité individuelle.

Dimension	Solvabilité II (ORSA)	DORA
Taxonomie du risque	Traitement agrégé dans le module <i>SCR_{Op}</i>	Taxonomie granulaire des actifs TIC et indicateurs de risque distincts
Reporting des incidents	Notification interne, dialogue prudentiel non standardisé	Notification obligatoire à l'ACPR : alerte sous 4 h après classification comme majeur (et au plus tard 24 h après détection), rapport intermédiaire 72 h, rapport final 1 mois
Tests de résilience	Stress tests orientés adéquation du capital	Tests de continuité et TLPT (pénétration guidée par la menace) au moins tous les 3 ans pour les entités identifiées comme significatives
Cartographie des dépendances	Analyse générale des accords d'externalisation	Registre d'Informations harmonisé, chaînes de sous-traitance jusqu'au rang 3
Encadrement des tiers	Lignes directrices EIOPA non contraignantes	Clauses contractuelles impératives (Art. 30), surveillance directe des prestataires critiques

Le *Registre d'Informations* (ROI) mérite une attention particulière. En imposant le recensement exhaustif et structuré des contrats TIC critiques et de leurs chaînes de sous-traitance, DORA produit, pour la première fois, une donnée exploitable pour modéliser quantitativement le risque de concentration technologique — donnée qui faisait précisément défaut à l'ORSA traditionnel.

Les limites structurelles de l'ORSA traditionnel. L'ORSA traditionnel s'appuyait principalement sur des cartographies de risques fondées sur l'avis d'experts. Trois limites en découlaient.

Un cloisonnement méthodologique. Les risques TIC étaient traités séparément des risques financiers et assurantiels, sans intégration des corrélations réelles. L'interaction entre une défaillance de l'outil de tarification (risque opérationnel) et la sous-évaluation systématique des primes qui en résulte (risque de souscription) était rarement modélisée de manière dynamique.

L'absence de données de sinistralité qualifiées. Les assureurs ne disposaient pas de base standardisée permettant d'alimenter les modèles de sévérité pour les événements cyber de faible fréquence et de forte gravité. L'étalonnage des distributions à queue lourde restait hautement incertain et sujet à une forte volatilité de modèle — difficulté que notre travail aborde frontalement en mobilisant plusieurs sources indépendantes (PRC, SAS OpRisk Global, Hackmageddon) et en assumant explicitement l'incertitude résiduelle.

La non-prise en compte des interdépendances de la chaîne de valeur. Les politiques d'externalisation sous Solvabilité II se limitaient à des audits documentaires ponctuels. L'effet de cascade d'une panne systémique chez un fournisseur d'infrastructure cloud partagé par plusieurs acteurs du marché n'était pas intégré aux tests de résistance.

Zone de recouvrement. ORSA et DORA partagent un même objet — le risque opérationnel d'origine technologique — et une même exigence d'évaluation prospective. Trois domaines se recouvrent explicitement : le risque opérationnel informatique, traité de façon agrégée par l'ORSA

et granulaire par DORA ; les scénarios de stress cyber, que l'ORSA peut désormais alimenter des données et tests imposés par DORA ; et la continuité d'activité, exigence commune mais de portée différente. C'est dans ce recouvrement que se loge la contribution du présent mémoire : utiliser les artefacts produits par DORA (taxonomie, registre, tests) pour *quantifier* dans l'ORSA ce que celui-ci ne savait jusqu'alors que décrire.

Zones de divergence fondamentale. La finalité de l'évaluation. Solvabilité II s'inscrit dans une logique de continuité *financière* : prouver que l'assureur détient assez de fonds propres pour absorber les pertes d'une défaillance majeure. DORA s'inscrit dans une logique de continuité *opérationnelle* : garantir que, même sans capital excédentaire, l'infrastructure maintient les services critiques et se restaure rapidement. Les deux cadres sont complémentaires, non substituables.

Le principe de proportionnalité. Solvabilité II applique une proportionnalité fondée sur la taille globale (primes, provisions). DORA décline la sienne selon la complexité des systèmes d'information, la dépendance au cloud tiers, et la criticité dans l'écosystème de distribution. Une captive de réassurance ou une petite mutuelle peut ainsi bénéficier d'un régime DORA simplifié sans pour autant échapper aux exigences de capital.

La temporalité de la supervision. Solvabilité II fonctionne sur des cycles trimestriels et annuels (QRT, SFCR, RSR). DORA impose une réactivité quasi temps réel, notamment par la notification des incidents majeurs sous quatre heures, contraignant l'assureur à des processus permanents de veille connectés aux canaux du régulateur.

4 Données et limites

La modélisation développée dans ce mémoire ne repose sur aucune base de données unique. Chaque source mobilisée présente un périmètre, un biais et un niveau de granularité distincts, et c'est précisément leur articulation — plutôt que le choix d'une source « privilégiée » — qui constitue la démarche méthodologique retenue. Cette partie présente successivement les trois sources utilisées, avant de formaliser un cadre épistémique explicite sur les limites de l'exercice.

Bloc synthèse — Cartographie des sources et de leurs rôles

Un point de clarification méthodologique central structure l'ensemble de cette partie : **aucune base n'est utilisée seule**. Chaque source alimente une composante précise du modèle, selon ses propriétés propres.

Source	Rôle dans le modèle	Justification / limite
PRC 2025	Fréquence (λ) ; sévérité indirecte via conversion Jacobs	Périmètre défini, mais sévérité dérivée d'un modèle log-log
SAS OpRisk Global	Sévérité (montants réels)	Montants observés, mais biais vers les grandes entités financières
Hackmageddon	Multiplicateurs de scénario DORA (structure du risque)	Ne calibre pas le modèle : ajuste λ selon le niveau de conformité

Cette répartition des rôles évite un écueil fréquent dans la modélisation du risque cyber : traiter une base généraliste comme si elle pouvait, à elle seule, calibrer l'ensemble d'un modèle fréquence-sévérité. Chaque source est au contraire mobilisée là où elle est la plus fiable, et ses limites propres sont explicitement documentées dans les sous-sections suivantes.

L'utilisation d'un modèle interne, même partiel, est strictement encadrée par la directive Solvabilité II. L'Article 19 du Règlement Délégué (UE) 2015/35 impose que les données utilisées pour le calcul de la distribution de probabilité prévisionnelle respectent trois critères cumulatifs : l'exactitude, l'exhaustivité et la pertinence.

Dans le domaine du risque cyber, aucune base de données publique ou commerciale ne satisfait pleinement ces trois critères. L'actuaire est donc contraint de documenter rigoureusement les biais inhérents aux données historiques et de justifier les retraitements appliqués. La validité du SCR calculé ne repose pas sur la perfection de la donnée (qui n'existe pas), mais sur la transparence des limites épistémiques et la robustesse du modèle mathématique face à ces biais.

L'utilisation conjointe des bases *Privacy Rights Clearinghouse* (PRC) et SAS OpRisk Global permet de croiser les perspectives, mais nécessite d'identifier trois biais statistiques majeurs qui altèrent l'estimation de l'indice de queue ξ .

1. Le biais de sélection (Selection Bias). Ce biais affecte particulièrement la base OpRisk Global, qui se nourrit principalement d'événements rendus publics dans la presse financière ou

les rapports annuels. Par construction, un incident cyber n'atteint ce seuil de visibilité que s'il frappe une entité d'une certaine taille (généralement des institutions systémiques ou de grandes banques internationales) ou si son montant est exceptionnellement élevé. Ce biais de taille (size bias) conduit à une sur-représentation des événements extrêmes et une sous-représentation de la sinistralité d'attrition. Si l'on calibre directement un modèle sur cette base pour une entité de taille moyenne (ex : une mutuelle régionale), la probabilité de subir une perte extrême sera mécaniquement surestimée. C'est pour cette raison que notre approche conditionne la fréquence d'occurrence au profil de l'entité via le modèle de Vasicek (chapitre 6).

2. Le biais de déclaration (Reporting Bias). La base PRC est soumise à un biais de déclaration lié aux asymétries réglementaires. Aux États-Unis, la notification des fuites de données personnelles (Data Breaches) est obligatoire dans la plupart des États, ce qui rend la base PRC très riche sur ce vecteur d'attaque. En revanche, un rançongiciel (Ransomware) qui paralyse les serveurs de l'entreprise mais n'exfiltre aucune donnée personnelle peut ne déclencher aucune obligation de notification légale (avant l'entrée en vigueur d'actes récents comme le CIRCIA). Par conséquent, calibrer une fréquence globale sur la PRC tend à sous-estimer le risque d'interruption d'activité (Business Interruption) au profit du seul risque de compromission de données. C'est précisément pour corriger ce biais que nous avons superposé la structure des vecteurs d'attaque de la base Hackmageddon (qui capte l'ensemble du spectre, y compris les ransomwares) sur la fréquence de base issue de la PRC.

3. Le biais de survie (Survivorship Bias). Dans les bases de pertes opérationnelles, la sévérité maximale observée est paradoxalement bornée par la capacité de survie de l'entité. Une cyberattaque ayant entraîné la faillite pure et simple de l'entreprise (ruine) disparaît souvent des bases de pertes opérationnelles classiques, car il n'y a plus d'entité survivante pour reporter la perte financière finale et les coûts de remédiation à long terme. Ce biais tronque artificiellement l'extrême queue de distribution. La Théorie des Valeurs Extrêmes (EVT), en ajustant une loi de Pareto Généralisée (GPD) qui permet d'extrapoler au-delà du maximum historique observé, est la réponse mathématique adéquate à ce biais de survie.

L'hétérogénéité temporelle des bases de données constitue une autre infraction potentielle au critère d'exactitude de Solvabilité II. La base OpRisk Global agrège des pertes allant de l'année 2000 à 2026. Utiliser un montant de perte de 2018 tel quel dans un modèle de capital en 2026 constitue une erreur actuarielle sévère, l'inflation cyber ne se comportant pas comme l'inflation macroéconomique classique (IPC).

Le coût d'un sinistre cyber est principalement tiré par trois facteurs :

- **L'inflation salariale IT** : Le coût des experts en remédiation (forensic, restauration de systèmes) connaît une inflation nettement supérieure à l'indice des prix à la consommation, en raison de la pénurie de talents en cybersécurité.
- **L'inflation juridique et réglementaire** : L'entrée en vigueur du RGPD en 2018 a drastiquement modifié l'échelle des sanctions. Une fuite de données en 2015 coûtait infiniment moins cher en amendes administratives que la même fuite en 2025.
- **L'escalade des rançons** : La professionnalisation du cybercrime (Ransomware-as-a-Service) a transformé les demandes de rançons de quelques milliers de dollars en 2016 à plusieurs dizaines de millions d'euros en 2026.

Pour respecter les exigences de l'Article 19, les sinistres historiques doivent être actualisés en euros de l'année de modélisation (2026). Soit L_t la perte observée l'année t , la perte actualisée $\tilde{L}_{2026}$ s'écrit :

$$\tilde{L}_{2026} = L_t \times \prod_{k=t}^{2025} (1 + i_k^{cyber}) \quad (4.1)$$

où i_k^{cyber} est un taux d'inflation spécifique aux sinistres technologiques (souvent estimé par des indices sectoriels entre 5 % et 10 % annuels). Dans le cadre de ce mémoire, nous assumons que les bases commerciales traitées intègrent une homogénéisation monétaire, mais soulignons que la construction d'un indice d'inflation cyber robuste demeure un défi majeur pour la place financière.

Par ailleurs, le traitement des données manquantes dans la PRC (qui recense parfois le nombre d'enregistrements compromis sans le montant financier) est géré par la conversion de Jacobs. Bien qu'utile comme *proxy*, ce modèle de régression log-log présente la limite de « lisser » la variance et de minorer les extrêmes, justifiant notre décision de ne pas plafonner la calibration issue directement d'OpRisk (où les montants sont observés de bout en bout).

Les limites épistémiques et statistiques exposées ci-dessus contraignent aujourd'hui le calcul du SCR cyber à de larges intervalles d'incertitude. Cependant, cette situation est transitoire. L'apport fondamental du règlement DORA ne réside pas uniquement dans l'imposition de normes de sécurité (Chapitre II), mais dans la création d'un cadre de **notification harmonisée des incidents majeurs liés aux TIC** (Chapitre III, Article 19 de DORA).

DORA impose aux entités financières de reporter à leur autorité compétente (l'ACPR en France) les incidents majeurs selon une taxonomie standardisée (causes, vecteurs, temps de résolution, pertes financières directes et indirectes). À terme, le règlement prévoit la centralisation de ces rapports au sein d'un pôle de l'Union européenne (EU Hub).

La constitution de ce registre européen résoudra structurellement les trois failles actuelles des bases de données :

- **Suppression du biais de déclaration** : Le *reporting* étant réglementairement obligatoire, la base sera exhaustive.
- **Suppression du biais de sélection** : Le registre couvrira toutes les strates du marché financier (grandes banques, mais aussi courtiers, mutuelles et sociétés de gestion), offrant enfin une granularité suffisante pour conditionner la sévérité par taille d'entité.
- **Visibilité sur les tiers** : Le registre DORA cartographiera l'implication des prestataires tiers ICT. C'est exactement la donnée qui manque pour identifier la direction de la contagion, et le chapitre 9 chiffre en euros de capital ce que son obtention ferait gagner.

Dès lors, l'architecture du Modèle Interne Partiel développée dans ce mémoire (LDA, théorie des valeurs extrêmes, facteurs de Vasicek, allocation d'Euler) prend toute sa valeur. Le modèle mathématique et les scripts de simulation construits sont intégralement agnostiques à la source de données. Lorsqu'une base d'incidents DORA harmonisée sera rendue disponible à la profession actuarielle, il suffira de substituer ces nouvelles données aux actuelles bases PRC et OpRisk. Le moteur de calcul absorbera ces entrées qualifiées pour produire un SCR cyber d'une précision inédite, répondant simultanément aux exigences qualitatives de DORA et aux contraintes quantitatives de Solvabilité II.

Automatisation du reclassement par NLP. En attendant ce registre harmonisé, une partie du travail de fiabilisation des données peut d'ores et déjà être outillée. Le reclassement manuel par grille de mots-clés opéré au chapitre 4 sur la taxonomie Hackmageddon (nécessaire pour isoler le ransomware, absent en tant que catégorie en 2023) illustre une limite récurrente des bases de sinistralité cyber : une taxonomie déclarative instable, dont la correction repose aujourd'hui sur un travail manuel documenté mais non reproductible à grande échelle. Les travaux R&D menés chez Nexialog Consulting sur l'exploitation du NLP et des modèles de langage pour l'enrichissement de bases de sinistralité cyber (rapports d'incidents, bases de vulnérabilités, publications techniques) ouvrent une voie directe pour systématiser ce type de reclassement — en le rendant à la fois plus rigoureux (classification supervisée validée statistiquement plutôt que grille de mots-clés ad hoc) et transposable à d'autres bases (OpRisk, futur registre DORA). Cette piste n'a pas été mise en oeuvre dans le présent mémoire, faute de corpus annoté disponible dans le périmètre de ce travail, mais constitue une perspective directe de prolongement.

La base *Privacy Rights Clearinghouse* (PRC) constitue le socle de calibration de la fréquence annuelle de référence λ_{ref} utilisée dans le modèle. Son intérêt principal tient à son périmètre défini et à sa couverture longitudinale, qui permettent d’obtenir un niveau de fréquence directement exploitable pour une simulation actuarielle.

La PRC joue toutefois un second rôle, plus fragile : celui de source de sévérité indirecte, via une conversion dite de Jacobs, qui traduit un nombre d’enregistrements compromis en un montant de perte financière à partir d’un modèle log-log. Ce mécanisme permet d’élargir le spectre de tailles d’incidents disponibles, mais introduit un biais de modèle supplémentaire : la sévérité qui en résulte n’est pas observée directement, elle est *dérivée*. La calibration en queue de distribution obtenue sur la PRC — réalisée en propre sur les 15 053 incidents 2019–2025 de la base brute, via la conversion Jacobs $\ln(L) = 7,68 + 0,76 \ln(X)$ — donne un paramètre de forme $\hat{\xi}_{PRC} = 1,03$ (IC90% [0,97 ; 1,09]), caractéristique d’une queue extrêmement lourde, à espérance infinie — un résultat qui, pris seul, rendrait toute simulation numériquement instable et qui doit donc être discuté conjointement avec les corrections méthodologiques présentées au chapitre 4.

La justification du recours à la PRC malgré ces limites tient à l’absence d’alternative comparable pour la fréquence : aucune des deux autres sources mobilisées (Hackmageddon, OpRisk Global) ne permet, seule, d’ancrer un niveau annuel de sinistralité directement transposable à un portefeuille assurantiel.

Périmètre consolidé. La base Hackmageddon a été consolidée sur le semestre complet et contigu janvier–juin 2026, soit **1 041 incidents**. La couverture pluriannuelle initialement envisagée a été abandonnée : l’année 2024 est absente du jeu transmis, et 2025 n’est disponible que partiellement. La base est donc exploitée pour la *structure* du risque, non pour son *niveau* ou sa dynamique temporelle — ce qui explique pourquoi elle n’intervient pas dans la calibration de λ_{ref} , réservée à la PRC.

Apport 1 : structure du risque et mapping DORA. Sur les 1 041 incidents, 840 disposent d’un vecteur d’accès initial identifié (81 %), regroupés en familles et reliés directement aux articles DORA :

Vecteur d’attaque	Part	Exigence DORA
Phishing / Ingénierie sociale	38,8 %	Art. 13 — Sensibilisation & formation
Exploitation vuln. exposée	33,8 %	Art. 26 — Tests TLPT ; Art. 8–10
Supply chain / Tiers ICT	15,8 %	Art. 28–44 — Gestion risque tiers
Identifiants compromis	6,3 %	Art. 9 — Contrôle d’accès & MFA

Deux chiffres sont structurants pour la construction des scénarios de la chapitre 10 : **15,8 %** des attaques empruntent le vecteur tiers/supply chain, coeur des articles 28–44 ; et **49,6 %** relèvent de vecteurs qu’un test TLPT (art. 26) est censé détecter en amont (exploitation et tiers cumulés).

Limite 1 : biais de visibilité. Hackmageddon recense des incidents rendus publics, majoritairement médiatiques ou déclarés, ce qui sur-représente structurellement les événements les plus visibles au détriment des incidents ordinaires, moins commentés. La base ne peut donc servir à estimer un niveau absolu de fréquence, seulement une répartition relative entre vecteurs d’attaque.

Limite 2 : taxonomie instable. Une comparaison de structure entre 2023 (3 019 incidents, Q3 manquant) et 2026 a mis en évidence un artefact de taxonomie. La catégorie « Ransomware » n’existait pas en 2023, les incidents correspondants étant alors classés sous « Malware ». Une

lecture naïve suggérait une hausse du ransomware de +11 points ; après reclassement par grille de mots-clés commune, le ransomware *recule* en réalité de 23 points.

Dimension	2023	2026	Δ
Cybercriminalité (motivation)	81,1 %	73,9 %	−7,1
Cyberespionnage (motivation)	9,6 %	20,6 %	+11,0
Ransomware (reclassé)	35,8 %	12,7 %	−23,1

Seules les **motivations** (taxonomie stable de haut niveau) sont donc comparables directement dans le temps ; les **types d’attaque** ne le sont qu’après un travail de reclassement documenté. Le signal robuste qui demeure est la bascule du cybercrime de masse vers l’espionnage ciblé, une information pertinente pour la discussion du risque systémique au chapitre 11, mais qui illustre aussi la fragilité méthodologique de toute lecture brute d’une base de ce type.

Nature et périmètre. OpRisk Global est la base de référence historique du risque opérationnel au sens de Bâle 2/3, comptant **41 975 incidents** après nettoyage d’une aberration de saisie. Le risque cyber n’y constitue pas une catégorie native : il est reconstruit à partir des catégories « Systems Security » et « Business Disruption and System Failures ». Le périmètre cyber $\times$ finance retenu compte **582 incidents** sur la période 2000–2026.

Lien avec l’approche AMA. Cette base est historiquement celle qui alimentait les modèles internes de type *Advanced Measurement Approach* évoqués au chapitre 3, avant leur retrait au profit de la SMA sous Bâle III/IV. Son usage ici renoue donc, à des fins de modélisation interne et non de calcul réglementaire de Pilier 1, avec la logique originelle de la LDA bancaire : calibrer une sévérité extrême à partir de pertes réellement observées plutôt qu’à partir d’un indicateur de volume forfaitaire.

Statistiques de sévérité.

Indicateur	Valeur	Indicateur	Valeur
Médiane	1,50 M\$	P99	402 M\$
Moyenne	26,4 M\$	Maximum	1 500 M\$
P90	51,5 M\$	Total cumulé	15,4 Md\$

La concentration extrême de la sévérité — les 10 % d’incidents les plus graves représentent 82,7 % de la perte totale, et le seul top 1 % en représente 31 % — constitue une signature de queue lourde qui justifie directement le recours à la théorie des valeurs extrêmes développée en chapitre 6.

Choix du seuil POT. Le choix du seuil u au-dessus duquel la loi de Pareto généralisée est calibrée résulte d’un compromis classique biais-variance, arbitré graphiquement. Le *mean excess plot* (figure 4.1) présente une pente positive et globalement linéaire au-delà de $u = 20$ M€, signature attendue d’un régime GPD à queue lourde ($\xi > 0$) ; c’est ce seuil, correspondant au percentile 85 de la distribution des montants, qui est retenu pour la suite.

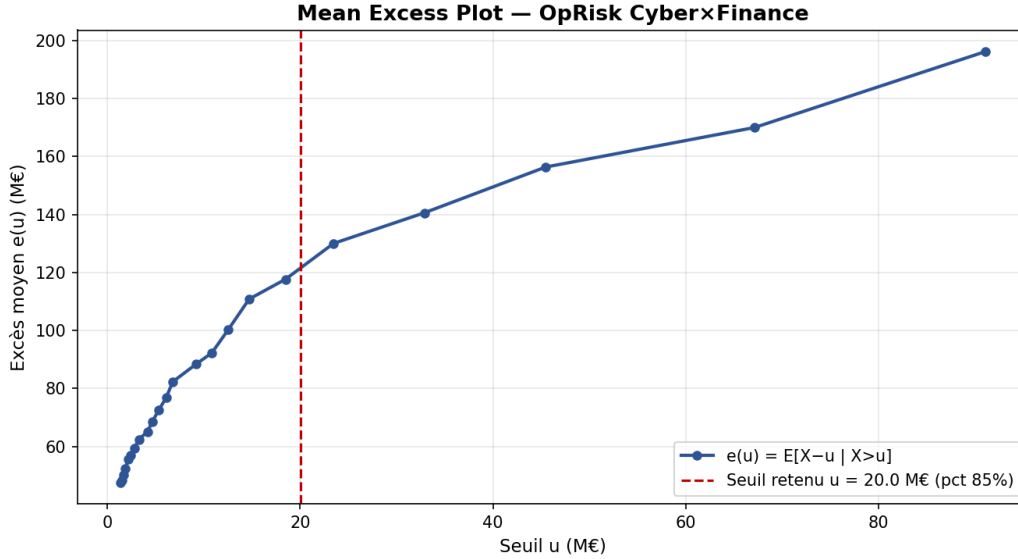


Figure 4.1. Mean excess plot sur le périmètre cyber×finance d’OpRisk Global. La linéarité de $e(u)$ au-delà du seuil retenu $u = 20$ M€(pointillés) confirme le régime de queue lourde justifiant l’ajustement GPD.

Calibration GPD et validation croisée. Au seuil du percentile 85 ($u = 20,0$ M€, 91 excès), la calibration GPD donne :

$$\hat{\xi} = 0,595 \quad (\text{IC}_{90\%} = [0,31 ; 0,83]), \quad \hat{\sigma} = 58,0 \text{ M€}, \quad \text{VaR}_{99,5\%} = 663 \text{ M€}.$$

L’intervalle de confiance bootstrap sur cette VaR est $[411 ; 1037]$ M€, soit un facteur 2,5 entre les bornes — une ampleur qui, à elle seule, illustre que le SCR ne peut être présenté comme un point.

La comparaison avec la PRC ($\hat{\xi}_{\text{PRC}} = 1,03$ contre $\hat{\xi}_{\text{OpRisk}} = 0,595$) révèle un écart de régime de queue, expliqué par le biais de taille d’OpRisk : les grandes entités financières y sont sur-représentées et absorbent mieux les chocs, d’où une queue apparemment plus légère. Les deux sources confirment néanmoins le même régime qualitatif de queue lourde ($\xi > 0$). Il n’existe donc pas de hiérarchie « source primaire » en sévérité : OpRisk fournit des montants réels, la PRC un spectre de tailles plus large via la conversion Jacobs — deux estimations indépendantes et complémentaires, dont l’écart constitue lui-même une information sur l’incertitude du modèle.

La décomposition par sous-catégorie révèle en outre deux profils de risque distincts : les pannes (« Business Disruption ») sont moins fréquentes (19 % des incidents) mais nettement plus coûteuses, avec une médiane cinq fois supérieure à celle des intrusions (« Systems Security »), suggérant que les multiplicateurs DORA pourraient à terme être différenciés non seulement en fréquence mais aussi en sévérité — sous réserve de la taille réduite de l’échantillon « pannes » (28 excès), qui rend cette calibration indicative.

La discipline méthodologique retenue dans ce mémoire consiste à ne jamais prétendre inférer davantage que ce que les données permettent réellement, ce qui impose d’explicitier aussi bien les capacités que les limites du dispositif.

Ce que l’on sait faire. On sait calibrer une fréquence de référence annuelle à partir d’un proxy sectoriel documenté (PRC), et la moduler selon une structure d’attaque observée empiriquement (Hackmageddon). On sait calibrer une sévérité de queue lourde par la théorie des valeurs extrêmes à partir de pertes réellement observées (OpRisk Global), et confronter cette calibration à une source indépendante pour objectiver l’incertitude. On sait enfin traiter l’écart entre sources non comme un bruit à éliminer, mais comme une dimension d’incertitude à part entière, qui s’ajoute à l’incertitude de paramètre estimée par bootstrap.

Ce que l'on ne sait pas faire. On ne sait pas mesurer directement le niveau de conformité DORA d'une entité donnée ; c'est précisément la raison d'être de l'état de conformité par pilier introduit au chapitre 10. On ne sait pas disposer d'une base d'incidents harmonisée à l'échelle européenne, exhaustive et non biaisée par la visibilité médiatique. On ne sait pas non plus estimer avec précision la corrélation entre les différentes briques de perte, faute d'historique suffisant sur les événements joints ; cette incertitude est traitée au chapitre 6 par une structure de dépendance explicite plutôt que par une hypothèse d'indépendance non fondée.

Deux corrections méthodologiques transparentes. Ce cadre épistémique a conduit à identifier et corriger deux défauts du moteur de simulation en cours de travail. D'une part, avec $\hat{\xi}_{\text{PRC}} = 1,03 \geq 1$, l'espérance de la sévérité PRC est infinie et la VaR simulée diverge numériquement ; un plafond de sévérité de 40 M€, ancré sur la capacité de réassurance cyber observable sur le marché, est appliqué à la *seule source PRC*. La calibration OpRisk, dont l'indice de queue $\hat{\xi}_{\text{OpRisk}} = 0,595 < 1$ garantit une espérance finie, n'est en revanche pas plafonnée : ses montants étant observés de bout en bout, y appliquer un plafond tronquerait des pertes réelles et contredirait sa propre calibration. D'autre part, le moteur attribuait initialement une sévérité de queue (GPD) à l'intégralité des événements simulés, au lieu de la seule fraction p_u dépassant le seuil de queue ; cette correction ramène les SCR simulés dans des ordres de grandeur cohérents avec les données observées.

La conséquence directe de ce cadre épistémique est méthodologique autant que présentationnelle : le résultat final ne peut être livré comme un montant unique, mais doit être présenté comme une distribution large, conditionnelle à des hypothèses documentées et à des sources dont les écarts sont eux-mêmes informatifs — ce principe structure l'ensemble de le chapitre 11.

Le dispositif retenu — PRC pour la fréquence, OpRisk Global pour la sévérité observée, Hackmageddon pour la structure du risque — appelle une question préalable à toute discussion de robustesse : ce triptyque est-il suffisant pour l'exercice mené dans ce mémoire ? La réponse tient à la nature même de l'exercice. L'objectif n'est pas de produire une formule réglementaire de Pilier 1, qui exigerait une base exhaustive et représentative du marché au sens de l'Article 19 — base qui, comme l'a établi la chapitre 4, n'existe aujourd'hui pour aucun acteur, public ou privé, sur le risque cyber. L'objectif est de construire, dans l'esprit du Pilier 2 et de l'ORSA, une mesure prospective dont la valeur ajoutée actuarielle réside dans la transparence de ses limites autant que dans la précision de son résultat. Sous cet angle, les trois sources mobilisées couvrent exactement les trois rôles qu'exige une architecture fréquence-sévérité-structure, et leurs biais respectifs — sélection, déclaration, survie, visibilité, instabilité taxonomique — sont documentés plutôt que dissimulés (chapitre 4).

Pourquoi ne pas simplement en ajouter d'autres. Des bases supplémentaires existent (bases commerciales de sinistres cyber assurantiels, enquêtes sectorielles européennes) et pourraient, en principe, enrichir le dispositif. Mais chacune porterait ses propres biais de sélection et de représentativité, sans lever la limite structurelle identifiée dès la chapitre 4 : l'absence, à ce jour, d'un registre harmonisé et exhaustif à l'échelle du marché. Multiplier les sources déplacerait la difficulté sans la résoudre, et complexifierait un narratif dont la clarté — trois sources, trois rôles distincts, aucune hiérarchie de « source primaire » — constitue en elle-même un gage de rigueur méthodologique. L'analyse de sensibilité menée au chapitre 11 confirme d'ailleurs, *a posteriori*, la pertinence de ce choix : c'est l'incertitude sur l'indice de queue ξ de la sévérité — estimé sur les sources déjà mobilisées — qui domine très largement toute autre source de variation du modèle, multipliers de fréquence et paramètres de dépendance compris. Approfondir l'exploitation des trois sources retenues (bootstrap, validation croisée, diagnostics de stabilité) réduit donc l'incertitude du capital de façon bien plus significative que l'ajout d'une quatrième base de sinistralité.

La structure du risque tirée de Hackmageddon (chapitre 4), bien que documentée quant à ses limites de visibilité et de taxonomie, gagne à être confrontée à une source indépendante, de

nature différente et couvrant un périmètre réglementaire proche de celui du présent mémoire. Le rapport *ENISA Threat Landscape 2025*, déjà mobilisé au chapitre 10 pour ancrer les bornes du multiplicateur associé à l'exploitation de vulnérabilités, remplit ce rôle : constitué par l'agence européenne de cybersécurité elle-même à partir de 4 875 incidents de périmètre européen, il repose sur une méthodologie de collecte distincte de celle, essentiellement médiatique, de Hackmageddon.

La confrontation porte sur un point précis, déjà exploité au chapitre 10 : ENISA mesure un taux de conversion tentative-vers-intrusion de 70 % pour l'exploitation de vulnérabilités, contre seulement 27 % pour le phishing. Cette asymétrie, mesurée par un organisme réglementaire sur un périmètre indépendant, confirme un résultat qu'Hackmageddon, par construction, ne peut révéler à partir du seul volume d'incidents observés : le phishing domine la structure en volume (38,8 % contre 33,8 % pour l'exploitation de vulnérabilités, chapitre 4), mais convertit nettement moins efficacement en intrusion réussie. Les deux sources s'accordent ainsi, chacune sur son propre plan — structure des incidents rapportés pour Hackmageddon, taux de conversion pour ENISA — sur une même hiérarchie qualitative des vecteurs d'attaque, ce qui renforce la crédibilité du mapping vecteurs → exigences DORA retenu au chapitre 10 sans nécessiter de recalibration.

Piste non mobilisée : Verizon DBIR. Le *Data Breach Investigations Report* de Verizon, fondé sur des méthodologies de collecte distinctes à la fois de Hackmageddon et d'ENISA, constituerait une troisième confrontation naturelle. Il n'est pas mobilisé dans le présent mémoire, faute de statistiques suffisamment vérifiées dans le périmètre de ce travail pour en garantir l'exactitude des chiffres cités — une prudence identique à celle déjà retenue pour les références bibliographiques marquées comme à vérifier (cf. `references.bib`). Cette confrontation constitue une perspective directe de prolongement, dans le même esprit que l'automatisation du reclassement par NLP déjà évoquée au chapitre 4.

Ce que ces données permettent, et ce qu'elles interdisent. Elles fixent la queue de sévérité ($\xi \approx 0,9$), la fréquence d'entrée et l'accumulation par cause commune. Elles ne fixent *pas* la direction de la contagion : le chapitre 8 le démontre sur deux sources qui échouent pour des raisons opposées, et le chapitre 9 en tire les conséquences en bornes de capital. Cette frontière n'est pas une faiblesse du dispositif de données, c'est un résultat qu'il produit.

5 Le socle mécaniste : fréquence et sévérité

Ces deux briques (loi de sévérité GPD par pilier, fréquence surdispersée pilotée par un facteur commun) sont reprises telles quelles : elles alimentent l'agrégation, qui est le seul élément que la cascade remplace.

Là où le Théorème Central Limite s'intéresse au comportement asymptotique des sommes de variables aléatoires, la Théorie des Valeurs Extrêmes (EVT) étudie le comportement asymptotique de leurs maxima.

Soit une séquence $(X_1, X_2, \dots, X_n)$ de variables aléatoires indépendantes et identiquement distribuées (i.i.d.) de fonction de répartition F , représentant la sévérité des cyberattaques. L'approche initiale de l'EVT, dite des *Block Maxima*, s'intéresse au maximum sur des blocs de taille n (par exemple, le sinistre cyber maximal annuel) :

$$M_n = \max(X_1, X_2, \dots, X_n) \quad (5.1)$$

Théorème de Fisher-Tippett-Gnedenko (1928, 1943). S'il existe des suites de constantes de normalisation $a_n > 0$ et $b_n \in \mathbb{R}$, et une distribution non dégénérée H telles que :

$$\lim_{n \rightarrow \infty} \mathbb{P} \left(\frac{M_n - b_n}{a_n} \leq x \right) = \lim_{n \rightarrow \infty} F^n(a_n x + b_n) = H(x) \quad (5.2)$$

Alors, H appartient nécessairement à la famille des distributions des extrêmes généralisées (GEV - *Generalized Extreme Value*), dont la fonction de répartition s'écrit :

$$H_\xi(x) = \begin{cases} \exp \left(- (1 + \xi x)^{-1/\xi} \right) & \text{si } \xi \neq 0 \\ \exp(-\exp(-x)) & \text{si } \xi = 0 \end{cases} \quad (5.3)$$

définie sur l'ensemble $\{x : 1 + \xi x > 0\}$. Le paramètre ξ (indice de queue) définit trois grands domaines d'attraction :

- $\xi > 0$ (**Loi de Fréchet**) : La distribution présente une queue lourde à décroissance polynomiale. C'est le régime critique qui nous intéresse pour les sinistres cyber majeurs.
- $\xi = 0$ (**Loi de Gumbel**) : La distribution présente une queue légère à décroissance exponentielle (domaine d'attraction des lois Normale, Lognormale, Gamma).
- $\xi < 0$ (**Loi de Weibull**) : La distribution a un support fini supérieur (queue courte).

On peut énoncer formellement ce résultat fondateur, qui joue pour les maxima le rôle du théorème central limite pour les sommes.

Théorème 5.1 (Fisher-Tippett-Gnedenko). Soit $(X_i)_{i \geq 1}$ i.i.d. de fonction de répartition F et $M_n = \max(X_1, \dots, X_n)$. S'il existe des suites $a_n > 0$, $b_n \in \mathbb{R}$ et une loi non dégénérée H telles que $(M_n - b_n)/a_n \xrightarrow{d} H$, alors H est, à un changement d'échelle et de position près, une loi GEV H_ξ . Le signe de ξ détermine le domaine d'attraction : Fréchet ($\xi > 0$, queue lourde), Gumbel ($\xi = 0$) ou Weibull ($\xi < 0$, support borné).

Éléments. La loi limite H est nécessairement *max-stable* : pour tout n , $H^n(a_n x + b_n) = H(x)$, car M_{nk} est le maximum de k blocs de taille n . L'équation fonctionnelle de max-stabilité, résolue via la théorie des fonctions à variation régulière, n'admet (à normalisation près) que la famille à un paramètre H_ξ . La correspondance queue de $F \leftrightarrow$ signe de ξ s'obtient en caractérisant les F dont la fonction de survie est à variation régulière d'indice $-1/\xi$ (cas Fréchet). Le détail figure en Annexe B. $\square$

Bien que rigoureuse, l'approche *Block Maxima* (GEV) présente une limite majeure en actuariat pratique : elle induit un immense gaspillage d'information. En ne retenant que le maximum de chaque bloc, elle occulte potentiellement le deuxième plus grand sinistre d'une année extrême, qui pourrait pourtant être supérieur au maximum d'une année calme. Dans le contexte du risque cyber, où les données historiques fiables et quantifiées sont particulièrement rares, un tel gaspillage statistique fragiliserait la modélisation.

Pour contourner ce problème, ce mémoire privilégie l'approche *Peaks-Over-Threshold* (POT). Au lieu de ne garder que les maxima, cette méthode exploite **toutes** les observations excédant un seuil élevé u . On s'intéresse alors à la distribution des excès $Y = X - u$.

La fonction de répartition conditionnelle des excès est donnée par :

$$F_u(y) = \mathbb{P}(X - u \leq y \mid X > u) = \frac{F(u + y) - F(u)}{1 - F(u)} \quad (5.4)$$

Théorème de Balkema-de Haan-Pickands (1974). Ce théorème établit le pont mathématique entre la GEV et l'approche POT. Pour une large classe de distributions sous-jacentes F (celles appartenant au domaine d'attraction d'une loi GEV H_ξ), il existe une fonction mesurable positive $\sigma(u)$ telle que, lorsque le seuil u tend vers la limite supérieure du support de F (x_F), la distribution des excès converge asymptotiquement vers une distribution de Pareto Généralisée (GPD) :

$$\lim_{u \rightarrow x_F} \sup_{0 \leq y < x_F - u} |F_u(y) - G_{\xi, \sigma(u)}(y)| = 0 \quad (5.5)$$

Où la fonction de répartition de la GPD s'écrit :

$$G_{\xi, \sigma}(y) = \begin{cases} 1 - \left(1 + \frac{\xi y}{\sigma}\right)^{-1/\xi} & \text{si } \xi \neq 0 \\ 1 - \exp\left(-\frac{y}{\sigma}\right) & \text{si } \xi = 0 \end{cases} \quad (5.6)$$

avec $y \geq 0$ si $\xi \geq 0$, et $0 \leq y \leq -\sigma/\xi$ si $\xi < 0$. Le paramètre de forme ξ de la GPD est strictement le même que celui de la loi GEV correspondante. Dans le contexte du risque cyber, un indice de queue $\xi > 0$ traduit une distribution à queue lourde de type Fréchet, impliquant des moments potentiellement infinis (l'espérance est infinie si $\xi \geq 1$, la variance si $\xi \geq 0.5$). Le résultat s'énonce formellement ainsi.

Théorème 5.2 (Pickands–Balkema–de Haan). *Soit F dans le domaine d'attraction d'une GEV H_ξ (Théorème 5.1). Alors il existe une fonction $\sigma(u) > 0$ telle que la loi des excès converge uniformément vers une GPD lorsque le seuil approche la borne supérieure x_F du support :*

$$\lim_{u \rightarrow x_F} \sup_{0 \leq y < x_F - u} |F_u(y) - G_{\xi, \sigma(u)}(y)| = 0, \quad (5.7)$$

où $F_u(y) = \mathbb{P}(X - u \leq y \mid X > u)$ et $G_{\xi, \sigma}$ est la fonction de répartition de la GPD. L'indice de queue ξ est identique à celui de la GEV limite.

Esquisse. L'appartenance de F au domaine d'attraction de H_ξ équivaut à une condition de variation régulière sur la fonction de survie $\bar{F}$. On montre que $\bar{F}(u + y a(u))/\bar{F}(u) \rightarrow (1 + \xi y)^{-1/\xi}$ quand $u \rightarrow x_F$, pour une fonction d'échelle $a(u)$ adéquate ; ce membre de droite est exactement la fonction de survie GPD. La convergence uniforme découle de la monotonie des fonctions de répartition (théorème de Pólya). Détail et lien avec le Théorème 5.1 en Annexe B. $\square$

L'estimation de l'indice de queue ξ est un enjeu critique, car une infime variation de ce paramètre modifie massivement le Capital de Solvabilité Requis (SCR). Deux approches principales s'affrontent dans la littérature.

L'estimateur de Hill. Pour $\xi > 0$, l'estimateur non paramétrique de Hill (1975) repose sur les statistiques d'ordre. Soit $X_{(1)} \geq X_{(2)} \geq \dots \geq X_{(n)}$ l'échantillon ordonné de manière décroissante. L'estimateur de Hill fondé sur les k plus grandes observations est défini par :

$$\hat{\xi}_{Hill}(k) = \frac{1}{k} \sum_{i=1}^k \ln X_{(i)} - \ln X_{(k+1)} \quad (5.8)$$

Bien que cet estimateur soit asymptotiquement convergent et sans biais sous la stricte condition que la distribution sous-jacente appartienne exactement au domaine d'attraction de Fréchet, il présente en pratique un biais d'échantillon fini majeur. En effet, si la composante à variation lente de la queue de distribution ne converge pas assez vite, $\hat{\xi}_{Hill}$ devient instable.

Le Maximum de Vraisemblance (MLE). Pour pallier le biais de l'estimateur de Hill hors du régime asymptotique strict, ce mémoire privilégie l'estimation par Maximum de Vraisemblance (MLE) sur les excès de la GPD. La log-vraisemblance pour un échantillon de N_u excès y_i au-delà du seuil u s'écrit (pour $\xi \neq 0$) :

$$\ell(\xi, \sigma) = -N_u \ln(\sigma) - \left(1 + \frac{1}{\xi}\right) \sum_{i=1}^{N_u} \ln \left(1 + \frac{\xi y_i}{\sigma}\right) \quad (5.9)$$

La maximisation numérique de cette fonction fournit des estimateurs $(\hat{\xi}_{MLE}, \hat{\sigma}_{MLE})$ qui, bien que nécessitant des méthodes d'optimisation (telles que l'algorithme de Nelder-Mead utilisé dans nos scripts Python), offrent une robustesse supérieure face à la variance d'échantillonnage des bases de sinistres cyber comme OpRisk ou PRC.

Loi asymptotique et information de Fisher. La qualité d'un intervalle de confiance sur ξ conditionne toute l'interprétation du SCR. Nous en donnons ici le fondement théorique, qui servira de contrôle indépendant du bootstrap employé au chapitre 11.

Proposition 5.3 (Normalité asymptotique de l'EMV de la GPD). *Pour $\xi > -\frac{1}{2}$, l'estimateur du maximum de vraisemblance $(\hat{\xi}, \hat{\sigma})$ de la GPD est consistant et asymptotiquement normal :*

$$\sqrt{N_u} \begin{pmatrix} \hat{\xi} - \xi \\ \hat{\sigma} - \sigma \end{pmatrix} \xrightarrow{d} \mathcal{N} \left(\mathbf{0}, (1 + \xi) \begin{pmatrix} 1 + \xi & -\sigma \\ -\sigma & 2\sigma^2 \end{pmatrix} \right). \quad (5.10)$$

En particulier, la variance asymptotique de l'indice de queue est $\text{Var}(\hat{\xi}) \simeq (1 + \xi)^2 / N_u$.

Esquisse. La matrice de covariance limite est l'inverse de l'information de Fisher $\mathcal{I}(\xi, \sigma)$, obtenue en prenant l'espérance de l'opposé de la hessienne de ℓ . Le détail du calcul de $\mathcal{I}$ (dérivées secondes de (5.9) et intégration contre la densité GPD, valide pour $\xi > -\frac{1}{2}$ où l'information est finie) est reporté en Annexe B. Le résultat classique remonte à Smith (1987). $\square$

Appliquée à la calibration OpRisk ($\hat{\xi} = 0,595$, $N_u = 91$ excès), la Proposition 5.3 donne un écart-type asymptotique $\widehat{\text{sd}}(\hat{\xi}) = (1 + \hat{\xi}) / \sqrt{N_u} = 0,167$, soit un intervalle de confiance à 90 % par la delta-méthode de $[0,320; 0,870]$. Cet intervalle recoupe presque exactement l'intervalle bootstrap $[0,304; 0,831]$ obtenu indépendamment (§5.5) : la concordance des deux approches — l'une paramétrique et asymptotique, l'autre par rééchantillonnage — renforce la fiabilité de l'incertitude reportée sur ξ .

Proposition 5.4 (Loi asymptotique de l'estimateur de Hill). *Si F est à variation régulière d'indice $-1/\xi$ (domaine de Fréchet), alors pour une suite $k = k(n) \rightarrow \infty$ avec $k/n \rightarrow 0$,*

$$\sqrt{k} (\hat{\xi}_{Hill}(k) - \xi) \xrightarrow{d} \mathcal{N}(0, \xi^2). \quad (5.11)$$

L'écart-type $\xi/\sqrt{k}$ décroît en $\sqrt{k}$: d'où l'arbitrage biais-variance qui gouverne le choix de k dans le *Hill plot*, et qui explique l'instabilité signalée plus haut lorsque k est pris trop grand (contamination par le corps de la loi) ou trop petit (variance explosive). La preuve, fondée sur la représentation de Rényi des espacements exponentiels, est esquissée en Annexe B.

Quantile extrême et capital : formules fermées. Le passage des paramètres (ξ, σ) au capital réglementaire est explicite. Notons $\zeta_u = \mathbb{P}(X > u)$ la probabilité de dépassement du seuil.

Proposition 5.5 (VaR et Expected Shortfall d'une queue GPD). *Sous le modèle POT, pour α tel que $\text{VaR}_\alpha > u$ et $\xi \in (0, 1)$:*

$$\text{VaR}_\alpha(X) = u + \frac{\sigma}{\xi} \left[\left(\frac{1-\alpha}{\zeta_u} \right)^{-\xi} - 1 \right], \quad (5.12)$$

$$\text{TVaR}_\alpha(X) = \mathbb{E}[X \mid X > \text{VaR}_\alpha] = \frac{\text{VaR}_\alpha(X)}{1-\xi} + \frac{\sigma - \xi u}{1-\xi}. \quad (5.13)$$

Lorsque $\xi \geq 1$, l'espérance $\mathbb{E}[X]$ est infinie et TVaR_α n'est pas définie.

Démonstration. Pour $x > u$, la propriété POT donne $\mathbb{P}(X > x) = \zeta_u (1 + \xi(x - u)/\sigma)^{-1/\xi}$. En posant ce membre égal à $1 - \alpha$ et en inversant, on obtient (5.12). Pour (5.13), la stabilité de la GPD par franchissement de seuil implique que l'excès au-delà de VaR_α suit encore une GPD de paramètre ξ et d'échelle $\sigma + \xi(\text{VaR}_\alpha - u)$, d'espérance $(\sigma + \xi(\text{VaR}_\alpha - u))/(1 - \xi)$ pour $\xi < 1$; en ajoutant VaR_α et en réarrangeant, on retrouve (5.13). La divergence pour $\xi \geq 1$ découle de $\mathbb{E}[X] = \int_u^\infty \mathbb{P}(X > x) dx = +\infty$ dès que $1/\xi \leq 1$. Détail en Annexe B. $\square$

Numériquement, la calibration OpRisk ($u = 20,03$, $\sigma = 57,97$, $\xi = 0,595$, $\zeta_u = 0,151$) donne par (5.12) une VaR mono-perte $\text{VaR}_{99,5\%} = 663,0$ M€ et par (5.13) $\text{TVaR}_{99,5\%} = 1\,752,4$ M€. La Proposition 5.5 éclaire surtout le contraste entre sources : la calibration PRC affiche $\hat{\xi} = 1,033 > 1$, ce qui place la sévérité en **régime d'espérance infinie** — l'Expected Shortfall y est mathématiquement indéfini, ce qui justifie *a posteriori* le recours à un plafond de sévérité (capacité de réassurance) pour rendre le capital PRC calculable.

Décomposition par vecteur d'attaque. La fréquence de référence λ_{ref} , calibrée sur la base PRC ($\lambda_{ref} = 341$ incidents/an), est décomposée en sous-fréquences par vecteur d'attaque, pondérées par la structure observée dans la base Hackmageddon :

$$\lambda_{ref} = \sum_v \lambda_v, \quad \lambda_v = \lambda_{ref} \times \pi_v, \quad (5.14)$$

où π_v est la part du vecteur v dans la structure Hackmageddon (38,8 % phishing, 33,8 % exploitation de vulnérabilités, 15,8 % supply chain, 6,3 % identifiants compromis, 5,3 % autres). Cette décomposition transforme un constat structurel en levier de modélisation : un défaut de conformité sur une exigence donnée n'agit que sur la sous-fréquence du vecteur qu'elle est censée mitiger, pas sur l'ensemble de λ_{ref} .

Choix de la loi binomiale négative. La fréquence agrégée $\lambda_{S_x} = \sum_v \lambda_{ref} \pi_v m_{v,S_x}$ obtenue sous un scénario S_x n'est pas simulée par une loi de Poisson, mais par une loi binomiale négative, pour tenir compte de la sur-dispersion observée dans les données ($\sigma^2/\mu > 1$). Le facteur de sur-dispersion $\phi = \sigma^2/\mu = 9,2$ est traité comme une propriété structurelle de la sinistralité, supposée indépendante du niveau de fréquence : c'est donc ϕ qui est maintenu constant d'un scénario à l'autre, et non le paramètre r de la binomiale négative, qui est au contraire recalculé sous chaque scénario :

$$r_{S_x} = \frac{\lambda_{S_x}}{\phi - 1}, \quad p_{S_x} = \frac{r_{S_x}}{r_{S_x} + \lambda_{S_x}}. \quad (5.15)$$

Augmenter λ via les multiplicateurs DORA déplace ainsi la fréquence moyenne tout en préservant la *forme* de sur-dispersion de la sinistralité — une hypothèse de modélisation explicite, dont la limite est que le comportement de la sur-dispersion en régime de forte dégradation n'est pas lui-même observé, faute d'historique de crise DORA.

De la fréquence par scénario à la fréquence par entité. Le choix d'un scénario $S_x \in \{S_0, S_1, S_2\}$ reste, par construction, discret et appliqué uniformément à l'ensemble du marché. L'état de conformité continu $PCD_i(Y)$, repris au chapitre 10, permet de dépasser cette limite, en substituant à ce choix discret l'interpolation continue $m_v(PCD_i(Y))$ décrite au chapitre 10, où $\bar{m}_v^{S_2}$ est le centre de l'intervalle de multiplicateur sourcé en scénario S_2 . Une entité au profil de conformité mature conserve ainsi une fréquence proche de S_0 même en cas de choc systémique Y défavorable, tandis qu'une entité en retard de conformité peut, sous un ρ_i élevé, dépasser le multiplicateur S_2 dès l'environnement normal.

Choix de la loi de Pareto généralisée. La sévérité des sinistres cyber présente une signature de queue lourde documentée au chapitre 4 : sur OpRisk Global, les 10 % d'incidents les plus graves concentrent 82,7 % de la perte totale. Cette concentration extrême justifie le recours à la théorie des valeurs extrêmes, et plus précisément à une modélisation de la queue de distribution par une loi de Pareto généralisée (GPD) au-delà d'un seuil u , selon l'approche *peaks-over-threshold*.

Calibration OpRisk. Au seuil du percentile 85 ($u = 20,0$ M€, 91 excès), la calibration donne :

$$\hat{\xi}_{\text{OpRisk}} = 0,595 \quad (\text{IC}_{90\%} = [0,31 ; 0,83]), \quad \hat{\sigma}_{\text{OpRisk}} = 58,0 \text{ M€}, \quad \text{VaR}_{99,5\%} = 663 \text{ M€}. \quad (5.16)$$

L'intervalle de confiance bootstrap sur cette VaR, $[411 ; 1037]$ M€, matérialise à lui seul un facteur 2,5 entre les bornes, uniquement imputable à l'incertitude de paramètre.

Stabilité du paramètre de forme. Le choix du seuil est corroboré par deux diagnostics complémentaires. Le *diagnostic GPD* (figure 5.1) montre que $\hat{\xi}$ se stabilise autour de 0,6 dès que le seuil atteint $u = 20$ M€, tout en conservant un nombre d'excès suffisant ($n = 91 > 30$) pour une estimation fiable : le seuil retenu se situe précisément à la frontière où le paramètre de forme quitte la zone instable ($\xi \geq 1$) pour se fixer dans un régime de moments finis. Le *Hill plot* (figure 5.2) confirme qualitativement ce niveau, l'estimateur de Hill restant compatible avec la référence MLE $\hat{\xi} \approx 0,60$ dans la plage des extrêmes retenus.

L'estimateur de Hill : définition et rôle diagnostique. Introduit par Hill (1975), l'estimateur de Hill fournit une estimation de l'indice de queue ξ à partir des k statistiques d'ordre les plus élevées d'un échantillon $X_{(1)} \leq \dots \leq X_{(n)}$, sans passer par l'ajustement paramétrique d'une loi de Pareto généralisée :

$$\hat{\xi}_{\text{Hill}}(k) = \frac{1}{k} \sum_{i=1}^k \ln X_{(n-i+1)} - \ln X_{(n-k)}. \quad (5.17)$$

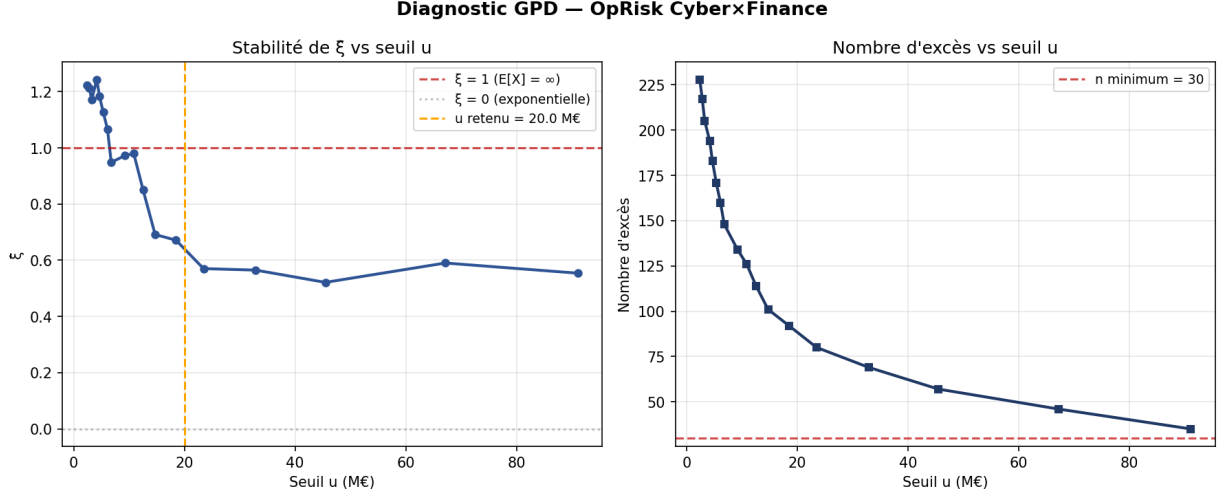


Figure 5.1. Diagnostic GPD sur le périmètre cyber×finance d’OpRisk. *Gauche* : stabilité de $\hat{\xi}$ en fonction du seuil u ; le paramètre passe sous $\xi = 1$ (espérance finie) et se stabilise autour de 0,6 au seuil retenu $u = 20$ M€. *Droite* : le nombre d’excès correspondant ($n = 91$) demeure au-dessus du minimum de 30 requis pour une estimation robuste.

Contrairement au maximum de vraisemblance sur la GPD, qui exploite le cadre théorique de Pickands–Balkema–de Haan et estime conjointement ξ et σ , l’estimateur de Hill repose sur une hypothèse de Pareto *pure* dans la queue et ne fournit qu’un indice de forme, sans paramètre d’échelle explicite (Beirlant et al., 2004). Sa propriété la plus documentée dans la littérature EVT est un compromis biais–variance piloté par le choix de k : pour k trop petit, l’estimateur est instable (variance élevée, intervalle de confiance large) ; pour k trop grand, il intègre des observations situées hors du régime purement asymptotique de la queue, ce qui induit un biais positif croissant avec k (Embrechts et al., 1997 ; Beirlant et al., 2004).

Application et confrontation au MLE-GPD. Le Hill plot obtenu sur le périmètre cyber×finance d’OpRisk (figure 5.2) illustre ce compromis de façon nette : l’estimateur croît de façon quasi monotone avec k , passant de $\hat{\xi} \approx 0,5$ pour k faible à $\hat{\xi} \approx 1,8$ pour $k = 200$, tandis que la bande de confiance asymptotique à 90 % s’élargit continûment. La référence par maximum de vraisemblance ($\hat{\xi}_{MLE} = 0,595$, pointillés rouges) n’est statistiquement compatible avec l’estimateur de Hill que sur une plage restreinte, $k \in [3, 25]$ environ, où la bande de confiance recouvre encore la valeur MLE. Au-delà de $k \approx 30$, l’estimateur de Hill diverge continûment de cette référence, ce qui traduit le biais positif attendu lorsque des observations hors du régime purement asymptotique de la queue sont intégrées au calcul. Sur le seuil effectivement retenu pour la calibration ($k = 86$), cet écart atteint 138,7 % ($\hat{\xi}_{Hill} = 1,42$ contre $\hat{\xi}_{MLE} = 0,595$), ce qui confirme que l’estimateur de Hill n’est pas adapté à ce niveau de k et que le MLE-GPD, qui exploite un cadre théorique plus général (loi GPD complète plutôt que Pareto pure), demeure l’estimateur de référence pour la calibration finale.

Validation croisée PRC. La calibration sur la PRC, via la conversion Jacobs, donne $\hat{\xi}_{PRC} = 1,03$ (seuil $u = 4,18$ M€, 2 258 excès), supérieur à $\hat{\xi}_{OpRisk} = 0,595$, les IC90% des deux estimateurs ne se chevauchant pas. Ce paramètre correspond formellement à une espérance de sévérité infinie ($\xi \geq 1$), ce qui impose un plafond de sévérité opérationnel — fixé à 40 M€, ancré sur la capacité de réassurance cyber observable sur le marché — pour que la simulation reste numériquement stable ; ce plafond ne s’applique qu’à la source PRC, la calibration OpRisk ($\xi < 1$, espérance finie) demeurant non plafonnée. L’écart entre les deux calibrations s’explique par le biais de taille d’OpRisk : les grandes entités financières y sont sur-représentées et absorbent mieux les chocs, d’où une queue apparemment plus légère. Les deux sources confirment néanmoins le même régime

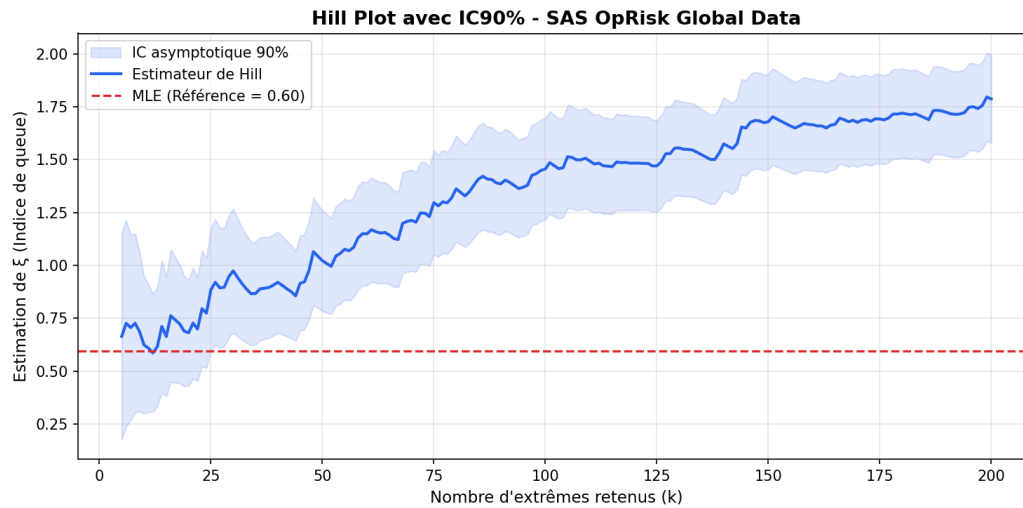


Figure 5.2. Hill plot avec intervalle de confiance asymptotique à 90 % sur OpRisk Global. La référence MLE ($\hat{\xi} \approx 0,595$, pointillés rouges) n'est statistiquement compatible avec l'estimateur de Hill que pour $k \lesssim 25$; au-delà, la dérive de $\hat{\xi}_{\text{Hill}}$ traduit le biais croissant lié à l'intégration d'observations hors du régime asymptotique pur de la queue.

qualitatif de queue lourde ($\xi > 0$), et aucune hiérarchie de type « source primaire » n'est retenue entre elles — leur écart est traité comme une composante de l'incertitude totale du modèle, non comme un désaccord à trancher.

6 La cascade dirigée

Idée directrice. La dépendance entre les cinq piliers n'est pas ajoutée après coup par une copule : elle est *produite* par la propagation d'un incident le long d'une matrice d'influence dirigée. La cascade est ainsi la vue **structurelle** (bottom-up) de la dépendance, en regard de la vue **copule** (top-down) de l'ancien mémoire. Le fil du chapitre part du Vasicek à un facteur, l'ouvre en deux temps (systémique par pilier, puis propagation dirigée), et remplace le seuil de défaut du crédit par un seuil ancré sur la barre de matérialité du règlement.

6.1 Le point de départ : le Vasicek à un facteur, et pourquoi il ne suffit pas

Le modèle structurel de Merton-Vasicek associe à chaque entité une variable latente. On retient la convention où X mesure le **stress** et non la santé (un X élevé est une mauvaise nouvelle), de sorte qu'une contagion positive encode bien une contamination :

$$X_i = \sqrt{\rho} Y + \sqrt{1-\rho} \varepsilon_i, \quad \text{Var}(X_i) = 1, \quad (6.1)$$

où $Y \sim \mathcal{N}(0,1)$ est le facteur systémique commun, $\varepsilon_i \sim \mathcal{N}(0,1)$ le choc idiosyncratique, et $\rho \in [0,1]$ la part du systémique, commune à toutes les entités. L'incident survient lorsque le stress franchit un seuil, $D_i = \mathbf{1}\{X_i \geq K_i\}$, avec dans le modèle classique $K_i = \Phi^{-1}(1 - \text{PD}_i)$.

Deux hypothèses de ce modèle sont fausses pour le cyber sous DORA. D'abord, la dépendance y est **symétrique** (un seul Y , un seul ρ) : le modèle ne peut pas dire si P1 entraîne P2 plus que l'inverse, alors que nos données d'expert sont dirigées à **81 %**. Ensuite, le seuil $\Phi^{-1}(\text{PD})$ suppose une PD stable, mesurable et une valeur de firme sous-jacente, dont rien n'existe en cyber. Les deux généralisations qui suivent lèvent ces deux limites.

6.2 Généralisation A : la structure systémique dépend du pilier

On indexe désormais par entité i et pilier $j \in \{1, \dots, 5\}$, et l'on remplace le facteur unique par **un facteur systémique par pilier** Y_j et une sensibilité propre ρ_{ij} :

$$X_{ij} = \sqrt{\rho_{ij}} Y_j + \sqrt{1-\rho_{ij}} \varepsilon_{ij}. \quad (6.2)$$

Chaque pilier a sa météo systémique propre (l'état de la menace sur la chaîne d'approvisionnement pour P4, l'état réglementaire pour P1), et les Y_j sont corrélés entre eux par une matrice Σ_Y : c'est là que vivent proprement les dépendances croisées, au niveau systémique. Sur des données cyber rares, on ne calibre pas un ρ_{ij} par entité (environ $5N$ paramètres, non identifiable) : on retient le compromis hiérarchique $\rho_{ij} = \rho_j + u_{ij}$, où la sensibilité de chaque entité gravite autour de la moyenne de son pilier ρ_j (pooling partiel).

Cette partie A n'est pas neuve, et il faut le dire. Le Merton-Vasicek multifacteur à matrice de corrélation générale est celui de Li (2000), employé tel quel dans les modèles de stress-test (Pineau et Zúñiga, 2023). La contribution propre ne commence qu'en partie B, avec la contagion **dirigée**. Le revendiquer clairement évite de se voir opposer une littérature qu'on aurait ignorée.

6.3 Généralisation B : la propagation dirigée

Pour encoder l'asymétrie, on ajoute un terme de réseau dirigé : le stress de j subit celui des autres piliers de la même entité, pondéré par une matrice **asymétrique** W :

$$X_{ij} = \underbrace{\sum_{k \neq j} W_{jk} X_{ik}}_{\text{contagion dirigée}} + \sqrt{\rho_{ij}} Y_j + \sqrt{1 - \rho_{ij}} \varepsilon_{ij}, \quad (6.3)$$

d'où, en forme matricielle sur les cinq piliers, la forme réduite $\mathbf{X}_i = (I - W)^{-1}(\text{systemique} + \text{idio})$, sous réserve que $\rho(W) < 1$. Si $W = 0$ on retombe sur la partie A, et avec un seul facteur sur le Vasicek standard : l'emboîtement est propre.

La propagation dirigée W : qui entraîne qui, et de combien

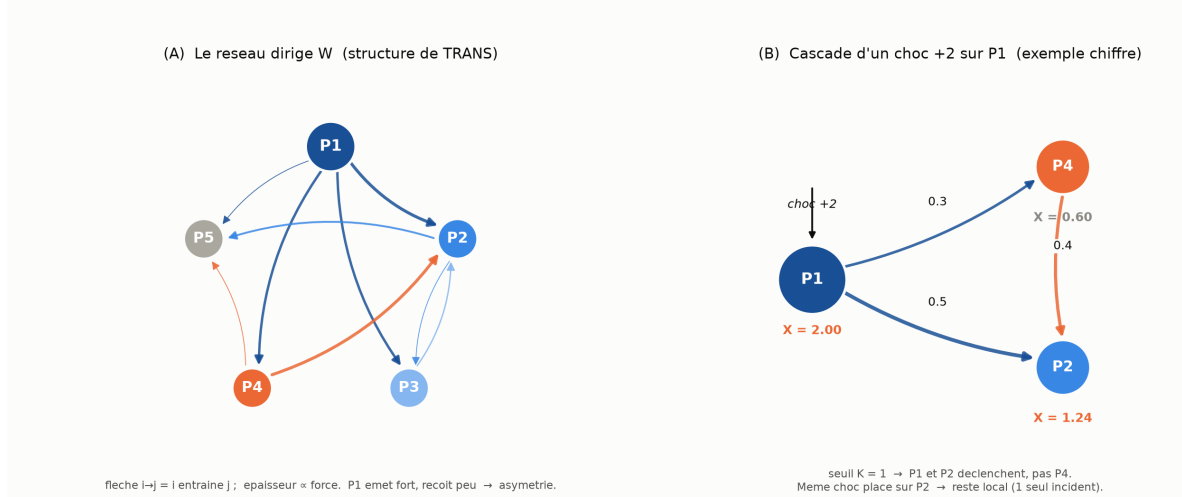


Figure 6.1. Structure dirigée de W sur les cinq piliers (P1 émet fort et reçoit peu) et propagation d'un choc sur un sous-réseau. Source : `build_network_figure`.

6.4 La normalisation de Leontief : une stabilité garantie

Brancher la matrice d'expert TRANS telle quelle est une erreur de catégorie. $(I - W)^{-1}$ ne représente une cascade que si la série $I + W + W^2 + \dots$ converge, soit $\rho(W) < 1$. Or $\rho(\text{TRANS}) = 1,461 > 1$, et $(I - \text{TRANS})^{-1}$ contient **21 entrées négatives sur 25** : un choc positif produirait un stress négatif ailleurs. TRANS n'a jamais été une matrice de parts.

La discipline vient du modèle entrées-sorties de Leontief, dont l'inverse $B = (I - A)^{-1} = \sum_{k \geq 0} A^k$ n'explose jamais parce que A est une matrice de **parts** : les colonnes somment à moins de un, la différence étant la valeur ajoutée, strictement positive. On applique la même règle en

lisant la ligne j de W comme les parts du stress de j provenant des autres piliers :

$$W = g \cdot \frac{\text{TRANS}}{\max_j \sum_k \text{TRANS}_{jk}}, \quad g \in (0, 1] \quad (6.4)$$

où g est la part de contagion du pilier le plus exposé. La contrainte $g \leq 1$ n'est pas ad hoc : W est positive et chaque ligne somme à au plus g , donc par Perron-Frobenius (le strict analogue de la valeur ajoutée positive de Leontief)

$$\rho(W) \leq \max_j \sum_k W_{jk} \leq g < 1, \quad (6.5)$$

et $(I - W)^{-1}$ existe. **La stabilité est donc garantie par la normalisation**, sur tout le domaine admissible, et non supposée. Numériquement, $\rho(W) = 0,635 g$. On divise par un scalaire et non ligne à ligne, ce qui préserve l'hétérogénéité de ce que *reçoit* chaque pilier (P1 reçoit trois fois moins que P2) : la revendication n°1 émet fort et reçoit peu z survit à la normalisation.

6.5 La cascade est un processus de branchement

Le modèle simultané sur latentes n'est pas celui que les données pourraient identifier. On lui substitue une contagion **retardée sur incidents**, qui est un **processus de branchement multitype** : un incident sur le pilier k engendre, à la période suivante, un nombre aléatoire d'incidents sur les autres piliers. Toute la théorie de l'extinction des épidémies s'applique, et l'objet central n'est plus W mais la **matrice de génération suivante** M , qui compte des incidents et non des écarts-types latents :

$$M_{jk} = \Phi(\text{base}_j + W_{jk}) - \Phi(\text{base}_j). \quad (6.6)$$

Deux rayons spectraux, à ne pas confondre. $\rho(W)$ gouverne le système latent simultané (il doit être < 1 pour que $(I - W)^{-1}$ existe) ; $R_0 = \rho(M)$ gouverne la cascade d'incidents, qui s'éteint si et seulement si $R_0 < 1$ (le R_0 des épidémiologistes). Avec une incidence de fond de 4,5 % et $g = 0,9$, on obtient $\rho(W) = 0,572$ et $R_0 = \mathbf{0,062}$: les deux lectures sont stables, mais pas du même ordre.

K3 : la cascade est un processus de branchement

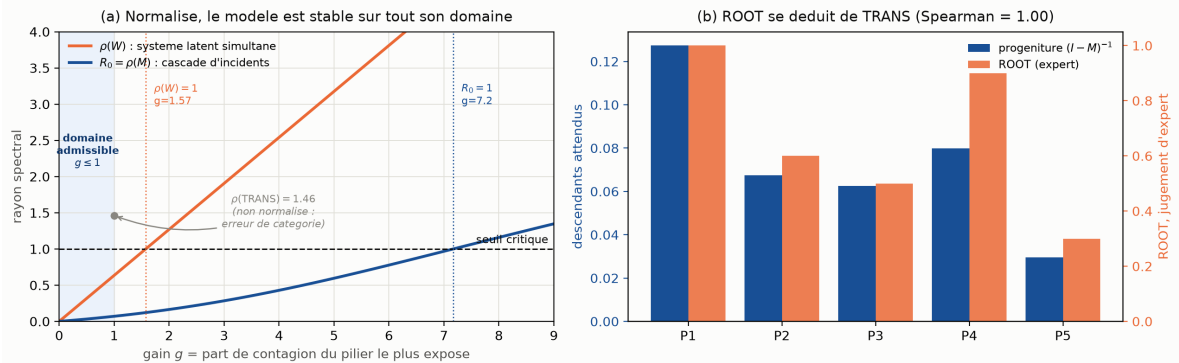


Figure 6.2. (a) Sur le domaine admissible $g \leq 1$, les deux rayons spectraux restent < 1 ; les seuils critiques ($\rho(W) = 1$ à $g = 1,57$; $R_0 = 1$ à $g = 7,2$) sont hors domaine. (b) La progéniture $(I - M)^{-1}$ reproduit exactement le classement ROOT du jugement d'expert. Source : 03_calibration_W.

Deux résultats en découlent. D'une part, la forme simultanée est **structurellement alarmiste** : même normalisée, elle approche son seuil critique cinq fois plus vite que la cascade réelle

($g^* = 1,57$ contre 7,2). Une lecture naïve de TRANS crierait à l'emballlement systémique dans un régime où la contagion s'éteint tranquillement. D'autre part, la progéniture $(I - M)^{-1}$ se lit comme le nombre de descendants d'un incident initial : le calcul donne 0,127 (P1), 0,080 (P4), 0,068 (P2), 0,063 (P3), 0,030 (P5), un classement **identique** à celui du barème ROOT (Spearman = 1,00), et ce pour toute valeur de g .

Ce que cela prouve, et ce que cela ne prouve pas. ROOT et TRANS ont été élicités par le même expert ; retrouver ROOT à partir de TRANS n'est pas une validation externe mais un test de **cohérence interne** du jugement, réussi. Sa portée réelle est une **réduction de paramètres** : ROOT se déduit de TRANS au lieu d'être posé, soit cinq paramètres d'expert en moins.

6.6 Le seuil K_j : ce qui remplace $\Phi^{-1}(\text{PD})$

Il faut distinguer deux seuils vivant dans deux espaces : u_j , le seuil de **matérialité** (DORA art. 18), dans l'espace des sévérités observables (euros, clients, heures) ; et K_j , le seuil sur la variable **latente**, sans unité. On ne peut pas prendre l'un pour l'autre : on **apparie leurs probabilités**, en choisissant K_j pour que l'événement latent $\{X_{ij} \geq K_j\}$ ait la même probabilité que l'incident majeur observable $\{S_{ij} \geq u_j\}$:

$$K_j = F^{-1}(1 - p_j), \quad p_j = \mathbb{P}(S_{ij} \geq u_j). \quad (6.7)$$

La littérature fait déjà exactement cela. Dans la représentation CreditMetrics des matrices de transition (Morgan et coll., 1997), le seuil de migration vaut $L = \Phi^{-1}(\text{fréquence cumulée observée})$: on inverse *toujours* une répartition. Ce qu'on reproche à $\Phi^{-1}(\text{PD})$ n'est pas l'inversion, ce sont ses deux entrées : une fréquence non mesurable (remplacée par p_j , définie par le règlement, donc stable et comparable entre entités) et une queue gaussienne trop fine (remplacée par une loi F à queue lourde). La probabilité de dépassement devient alors une **sortie** du modèle, conditionnelle à l'état systémique.

Le biais sur K_j ne vient pas de la méthode d'estimation de la queue mais de la **sous-déclaration** : en notant $q(s)$ la probabilité qu'un incident de sévérité s soit déclaré, on a l'identité exacte $\hat{p}_j^{\text{naïf}}/p_j = \mathbb{E}[q(S) \mid S \geq u_j] < 1$. On sous-estime p_j , donc on sur-estime K_j , donc on sous-provisionne, et ce biais s'effondre quand la barre monte dans la queue (+0,369 à $u = 0,5$; +0,001 à $u = 40$). **La barre DORA est défendable parce qu'elle est haute**, pas parce qu'elle est réglementaire, et c'est une propriété vérifiable : il suffit d'estimer $q(u_j)$. Le rôle de l'EVT n'est pas de débiaiser cette fréquence (extrapoler le taux depuis un seuil haut n'est pas pilotable), mais de modéliser la **sévérité** au-dessus de la barre, donc le capital (−0,8 % de biais contre −63,9 % pour la lognormale).

6.7 Calibration et faisabilité

L'asymétrie de W ne s'identifie que par l'information **temporelle** (qui déclenche avant qui) : le modèle de calibration est dynamique, et l'estimateur est **littéralement un probit** (le modèle générateur a un bruit gaussien et un seuil), non un logit qui gonflerait les magnitudes d'un facteur 2,1. Sur données *simulées*, ce protocole fonctionne : le probit retrouve W dans ses unités (corrélation 0,92, pente 1,08). Le protocole n'est donc pas en cause dans ce qui suit.

Ce que ce protocole donne sur données réelles : rien. Appliqué aux sources disponibles, il échoue, et il échoue pour des raisons qui tiennent aux *données* et non à la méthode. Le chapitre 8 le démontre sur deux sources qui échouent pour des raisons opposées et en tire la frontière d'identification ; le chapitre 9 en tire les conséquences sur le capital. Une précision de méthode mérite d'être posée dès ici : le test intuitif du « temps inversé » est **dégénéré** sur des comptages, puisque la matrice obtenue en renversant la chronologie vaut, par construction, la transposée. Il ne prouve rien, et seul le placebo par permutation est valide.

Le présent chapitre en donne la substance ; le détail du banc d'essai Φ^{-1} contre EVT, de la calibration du facteur systémique et des diagnostics de puissance est reporté en annexe.

6.8 Formalisation : définitions et propriétés

Cette section consolide le modèle sous une forme opposable à un lecteur exigeant. On note $P = \{1, \dots, 5\}$ les piliers, $W \in [0, 1]^{P \times P}$ la matrice de contagion avec $W_{jj} = 0$, et $s_{\max} = \max_j \sum_k \text{TRANS}_{jk}$. Les démonstrations sont rassemblées à l'annexe A.

Définition 6.1 (Cascade indépendante). *À chaque couple ordonné (j, k) , $j \neq k$, on associe une variable de Bernoulli indépendante $B_{jk} \sim \mathcal{B}(W_{jk})$. Le graphe d'arêtes vivantes G possède l'arc $j \rightarrow k$ si et seulement si $B_{jk} = 1$. Pour un pilier d'amorce a , l'ensemble atteint est*

$$S_a = \{a\} \cup \{k \in P : \text{il existe un chemin dirigé } a \rightsquigarrow k \text{ dans } G\}.$$

C'est la construction standard de la cascade indépendante, équivalente à une percolation de liens sur le graphe dirigé pondéré par W .

Proposition 6.2 (Forme réduite et descendance espérée). *Le nombre espéré de marches dirigées de longueur n de a vers k vaut $(W^n)_{ak}$, et la descendance totale espérée, comptée avec multiplicité, est*

$$\sum_{n \geq 0} (W^n)_{ak} = ((I - W)^{-1})_{ak},$$

série convergente si et seulement si $\rho(W) < 1$. L'ensemble atteint étant compté sans multiplicité, on a la majoration $\mathbb{E}|S_a| \leq [(I - W)^{-1}\mathbf{1}]_a$, et l'écart mesure exactement les piliers atteints par plusieurs chemins.

Proposition 6.3 (Sous-criticité par normalisation de Leontief). *Sous la normalisation (6.4), $W = (g/s_{\max}) \text{TRANS}$, la matrice W est positive et chacune de ses lignes somme à au plus g ; par conséquent*

$$\rho(W) \leq \max_j \sum_k W_{jk} \leq g < 1.$$

La convergence de $(I - W)^{-1}$, donc la stabilité de la cascade, est ainsi garantie sur tout le domaine admissible, et non supposée.

Proposition 6.4 (Loi exacte de l'ensemble atteint). *Pour tout $A \subseteq P$ avec $a \in A$,*

$$\mathbb{P}(S_a = A) = R(A) B(A), \quad B(A) = \prod_{j \in A, k \notin A} (1 - W_{jk}),$$

où $B(A)$ est la probabilité qu'aucune arête ne fuie hors de A , et $R(A)$, la probabilité que a atteigne tout A par les seules arêtes internes, vérifie $R(\{a\}) = 1$ et

$$R(A) = 1 - \sum_{\substack{A' \subsetneq A \\ a \in A'}} R(A') \prod_{j \in A', k \in A \setminus A'} (1 - W_{jk}).$$

Le SCR du chapitre 11 est calculé par cette récursion exacte, sans simulation de la cascade.

Proposition 6.5 (Monotonie stochastique). *Si $W \leq W'$ terme à terme, alors $S_a(W)$ est stochastiquement dominé par $S_a(W')$. Toute fonctionnelle croissante de S_a , en particulier la perte agrégée et sa VaR, est donc croissante en chaque entrée de W . En revanche une perturbation antisymétrique A déplace W_{jk} et W_{kj} en sens opposés : le capital n'est pas monotone en A_{jk} , ce qui justifie de balayer les sommets de l'ensemble admissible (chapitre 9) sans revendiquer de bornes exactes.*

Proposition 6.6 (Dépendance à l'ordre). *La vraisemblance d'une chaîne ordonnée $\ell(i_1, \dots, i_n) = \text{ROOT}_{i_1} \prod_k \text{TRANS}_{i_k i_{k+1}}$ est invariante par permutation si et seulement si TRANS est symétrique. Comme TRANS est asymétrique, la criticité n'est pas une fonction de l'ensemble des piliers touchés : aucune copule ni aucun score additif, invariants par permutation, ne peut la reproduire.*

Proposition 6.7 (Non-identification directionnelle). *Dans la décomposition unique $W = S + A$ avec $S = \frac{1}{2}(W + W^\top)$ et $A = \frac{1}{2}(W - W^\top)$, la matrice de co-occurrence et la statistique du placebo par permutation ne dépendent de W que par sa partie symétrique S . Les matrices W et $W^\top$, de même S , sont donc observationnellement équivalentes sous les données de co-occurrence, alors que $\text{SCR}(W) \neq \text{SCR}(W^\top)$ en général : la direction est non identifiée.*

7 Trois propriétés du modèle

Objet du chapitre. Le mémoire ne prétend pas apporter un théorème nouveau d'analyse stochastique. Il établit en revanche trois propriétés de son propre objet, et chacune est accompagnée de sa **vérification numérique** : l'énoncé dit ce qui doit se produire, le calcul montre que cela se produit. La troisième est la plus importante, car elle transforme la limite d'identification en résultat opposable.

7.1 La criticité dépend de l'ordre, non de l'ensemble

Proposition 1. Soit $c(\sigma)$ la criticité d'une chaîne *ordonnée* σ de piliers. Si c était une fonction du seul *ensemble* des piliers touchés, on aurait $c(\sigma) = c(\sigma')$ pour toute permutation σ' de σ . Ce n'est pas le cas.

Démonstration. Il suffit d'un contre-exemple, et la construction en fournit une famille. La vraisemblance d'une chaîne $(i_1, \dots, i_n)$ vaut $\text{ROOT}[i_1] \prod_k \text{TRANS}[i_k][i_{k+1}]$, produit qui dépend de l'ordre dès lors que TRANS est asymétrique. Pour la paire $\{P_1, P_2\}$: $\text{TRANS}[1][2] = 0,80$ alors que $\text{TRANS}[2][1] = 0,20$, et les criticités valent respectivement 8 et 2. ■

Vérification. Sur les 26 sous-ensembles de taille au moins deux, 22 **changent de criticité selon l'ordre**, avec un écart atteignant 6 **points sur une échelle de 10**, soit 60 % de l'échelle, pour un *même* ensemble de piliers.

Portée. Toute dépendance symétrique (copule) et tout score additif sont, par construction, **invariants par permutation**. Aucun ne peut donc reproduire la criticité. C'est l'argument d'exclusion des approches concurrentes, et il ne requiert *aucun* jugement d'expert sur la *valeur* de la direction : il suffit que TRANS ne soit pas symétrique.

Ce qui n'est pas revendiqué, et pourquoi le dire. Une propriété plus forte, la **non-transitivité** de la dominance entre piliers, a été testée dans trois formulations : la transitivité des corrélations qu'impose un modèle à facteur unique, la positivité de la dépendance symétrisée, et l'existence de cycles de dominance par paire. **Aucune ne se vérifie** : zéro violation de l'inégalité de transitivité sur 420 triplets, valeur propre minimale +0,405 donc matrice de corrélation parfaitement valide, et zéro cycle. Cette revendication est donc **retirée**. La dépendance à l'ordre exclut exactement les mêmes concurrents et, elle, se démontre.

7.2 La normalisation de Leontief borne la propagation

Proposition 2. Pour une cascade indépendante de matrice moyenne W , où W_{jk} est la probabilité que le pilier j contamine directement k , et en notant S_j l'ensemble des piliers atteints depuis l'amorce j :

$$\mathbb{E}[|S_j|] \leq [(I - W)^{-1}\mathbf{1}]_j,$$

quantité finie si et seulement si $\rho(W) < 1$.

Démonstration. Le nombre moyen de descendants de génération k issus de j est la j -ème ligne de W^k . La descendance totale espérée, comptée *avec* multiplicité, vaut donc $\sum_{k \geq 0} W^k = (I - W)^{-1}$, série géométrique matricielle convergente si et seulement si $\rho(W) < 1$. L'ensemble atteint compte chaque pilier une seule fois, là où la descendance le compte autant de fois qu'il est contaminé : $|S_j|$ est donc dominé par la descendance totale. ■

Portée. La normalisation $W = g \text{ TRANS} / \max_k s_k$ impose $\rho(W) \leq g < 1$: la cascade est **sous-critique par construction**, et non par calibration heureuse. C'est ce qui autorise la forme réduite $(I - W)^{-1}$ malgré les cycles de propagation, là où un graphe bayésien exigerait l'acyclicité.

Vérification, et ce que l'écart mesure. Avec le classeur actuel, $\rho(W) = 0,506$. L'inégalité est vérifiée sur les cinq amorces et sur 300 matrices de l'ensemble admissible, sans aucun contre-exemple. L'écart entre la borne et la valeur exacte va de 10,6 % (amorce P5) à 19,9 % (amorce P1). **Cet écart n'est pas une imprécision** : il mesure exactement les *collisions*, c'est-à-dire les piliers atteints par plusieurs chemins, que la forme linéaire compte plusieurs fois. Sur cinq piliers fortement connectés il n'est pas négligeable, ce qui justifie de conserver le calcul exact par sous-ensembles plutôt que la seule forme close.

7.3 La direction n'est pas identifiée, et cela coûte

Proposition 3. Toute matrice se décompose de façon *unique* en $W = S + A$, avec $S = (W + W^\top)/2$ symétrique et $A = (W - W^\top)/2$ antisymétrique. Les matrices W et $W^\top$ partagent donc exactement la même partie symétrique et ne diffèrent que par le signe de A .

Conséquence. Le test directionnel ne rejette pas l'hypothèse $A = 0$ (chapitre 8 : asymétrie observée 119 contre un nul de permutation à 128 ± 27 , soit $z = -0,33$, et aucune arête significative sur 18). Les deux matrices sont donc **également compatibles avec ce que l'on observe**. Elles ne produisent pourtant ni le même capital, ni la même décision.

Vérification. Le SCR passe de 8 110 M€ sous W à 7 816 M€ sous $W^\top$, soit 295 M€ d'écart (3,6 %), et 7,9 % d'écart sur la perte moyenne. Surtout, **la priorité de remédiation bascule de P1 à P4**. Sur l'ensemble admissible, l'écart entre une matrice et sa transposée atteint 1 173 M€.

L'énoncé à retenir : observationnellement indistinguables, matériellement différentes. C'est la formulation la plus nette de la frontière d'identification, et elle ne repose sur *aucun* dire d'expert. Elle chiffre en euros de capital, et en inversion de priorité, le prix de ne pas savoir dans quel sens la contagion circule. C'est ce qui fonde à la fois le modèle en couches (chapitre ??) et la spécification de reporting adressée au régulateur.

8 L'identifiabilité de la contagion dirigée

Thèse du chapitre. La matrice de contagion dirigée W entre les cinq piliers DORA *n'est pas identifiable* sur les données publiques disponibles. Ce n'est pas un aveu, c'est un résultat : je le démontre sur deux sources qui échouent pour des raisons **opposées**, je distingue proprement ce que la donnée fixe de ce qu'elle ne fixe pas (identification *partielle*), et j'en tire une **spécification de reporting** qui, seule, rendrait W estimable. La contagion reste donc un objet **normatif**, élicité et borné par la sensibilité, jamais présenté comme calibré.

8.1 Ce qu'identifier W exigerait

Le coefficient W_{jk} mesure la propension d'une défaillance du pilier k à *entraîner*, dans la foulée, une défaillance du pilier j . L'identifier sur données demande trois choses simultanément : (i) observer des **co-occurrences** de défaillances de piliers au sein d'une même entité ; (ii) disposer d'une **antériorité temporelle** fiable (qui précède qui) pour distinguer W_{jk} de W_{kj} ; (iii) une **taxonomie par pilier** (domaine de contrôle), et non par vecteur d'attaque. Aucune des deux sources examinées ne réunit les trois.

8.2 Deux échecs opposés

Source 1 : Data Breach Chronology (notifications d'États américains). La base est volumineuse (74 783 incidents, 25 009 organisations) mais inexploitable pour W , par **manque de taxonomie et de volume informatif**. La catégorie non déterminée (UNKN) pèse **52,7 %** des incidents et n'est attribuable à aucun pilier. La date de *survenance* n'est exploitable que dans **49,6 %** des cas, et son caractère manquant n'est pas aléatoire : il varie par type d'incident, si bien qu'ordonner par survenance élimine des catégories entières du panel. Ordonner par *déclaration*, l'autre date disponible, ne mesure pas la contagion mais le **délai de détection** (qui varie d'un facteur important selon le type). Résultat : une fois restreint aux types informatifs et aux trimestres consécutifs, il ne reste que **71 transitions** $k(t-1) \rightarrow j(t)$ (soit 3,6 observations par cellule hors-diagonale), et **34** dans le seul secteur financier. La direction n'y est pas estimable, faute de matière.

Source 2 : SAS OpRisk Global Data (pertes opérationnelles, Bâle). Ici le **volume est au rendez-vous : 4 329 transitions** annuelles entre les 7 catégories de risque, soit environ **103 observations par cellule**. Et pourtant la direction reste inidentifiable, pour la raison *opposée* : le pas de temps est l'**année**, trop grossier pour porter une antériorité. Un test placebo le montre sans appel. On permute les années *à l'intérieur de chaque firme* (ce qui détruit toute antériorité mais conserve la co-occurrence), et l'on recalcule l'asymétrie $\|M - M^T\|_1/2$ de la matrice de transition :

$$\text{asymétrie réelle} = 119 \quad \text{contre placebo} = 128 \pm 27 \quad \Rightarrow \quad z = -0,33.$$

L'asymétrie observée est *sous* le bruit du placebo : aucun signal directionnel. Le test binomial par paire confirme : sur 18 paires suffisamment peuplées, **aucune** n'est significative à 5 %, ni avant ni

après correction de Bonferroni. La matrice de transition est **symétrique** : le pas annuel a lessivé la direction.

Précaution de méthode (à afficher). Le test intuitif du « temps inversé » (comparer M à la matrice obtenue en renversant la chronologie) est **dégénéré** sur un comptage : par construction $M_{\text{inv}} = M^T$, donc la corrélation des asymétries vaut -1 quel que soit le contenu. Il ne prouve rien. Seul le **placebo par permutation** est valide sur des comptages. Le signaler est un gage de rigueur, pas une faiblesse.

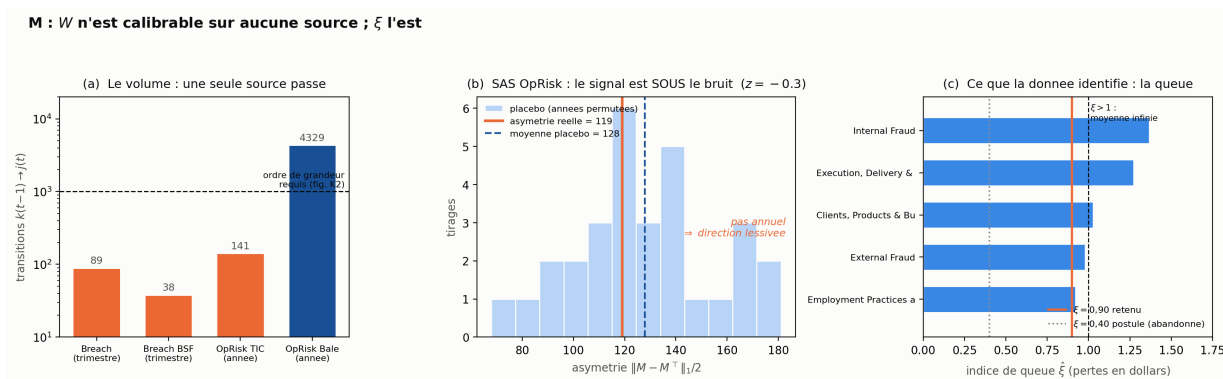


Figure 8.1. Les deux échecs et ce qui subsiste. (a) Une seule source atteint le volume requis. (b) Sur cette source, le signal directionnel est sous le bruit du placebo ($z = -0,33$). (c) Ce que la donnée identifie, elle : l'indice de queue ξ .

8.3 La meilleure expérience naturelle disponible : le choc MOVEit

Avant de conclure à l'indentifiabilité, on tente la stratégie la plus ambitieuse que la donnée autorise : une expérience quasi naturelle. En mai 2023, l'exploitation de masse de la faille du logiciel de transfert MOVEit, édité par un **tiers**, frappe simultanément des centaines d'organisations. C'est un choc **exogène**, **daté**, et **typé pilier 4**. Si la contagion dirigée existe, ce choc doit élever, dans les mois suivants et chez les mêmes organisations, le risque de défaillances relevant d'autres piliers. C'est une prédiction directionnelle testable, par différence de différences (188 organisations financières touchées, groupe de contrôle apparié, fenêtres de 180 jours).

Le piège, et ce qu'il apprend. La différence de différences brute est grande et statistiquement significative (+1,17 jour-brèche par organisation, IC bootstrap $[+1,07; +1,27]$). Mais un **placebo** (le même dispositif calé sur une fausse date un an plus tôt) produit presque le même chiffre (+1,11), alors qu'aucun choc n'a eu lieu. L'effet apparent n'est donc pas causal : il vient de la sélection du groupe de contrôle, qui revient mécaniquement vers sa moyenne. **L'effet net, une fois le placebo retranché, tombe à +0,06, indistinguishable de zéro.** Et quand bien même un signal subsisterait, la cible resterait non attribuable : la taxonomie de la source est un vecteur d'attaque (HACK, DISC..., 32% non déterminés), pas un domaine de contrôle DORA. Même la meilleure expérience naturelle ne fait donc pas apparaître de propagation dirigée, et sa cible ne serait de toute façon pas identifiable. La tentative la plus dure a été faite ; elle bute sur la donnée, pas sur la méthode.

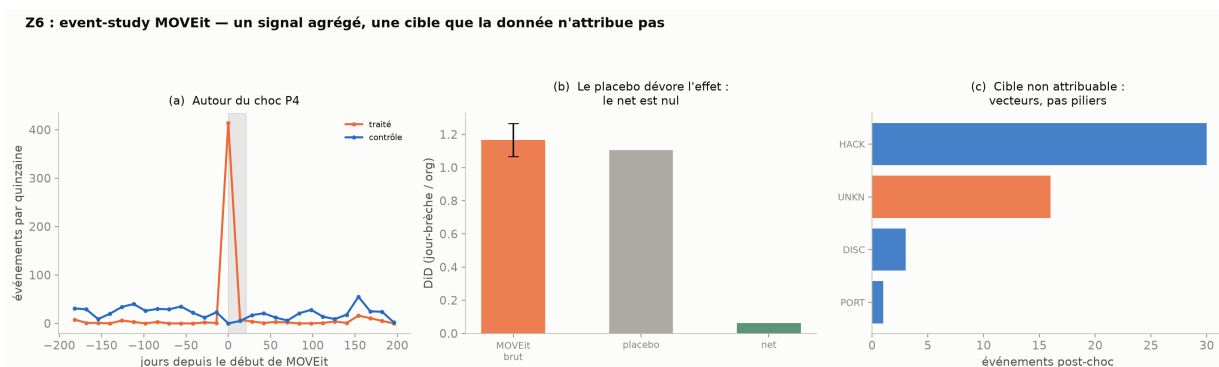


Figure 8.2. Event-study du choc MOVEit. (a) Fréquence des brèches, groupe touché contre contrôle, autour du choc. (b) La différence de différences brute est dévorée par le placebo : l'effet net est nul. (c) La cible reste non attribuable, la taxonomie étant un vecteur d'attaque et non un pilier.

8.4 Identification partielle : la frontière explicite

L'échec n'est pas total, et c'est ce qui fait la valeur du modèle. La donnée **fixe** plusieurs objets, qui sont ceux des chapitres empiriques :

- la **fréquence marginale** d'entrée (mélange de Poisson calibré) ;
- l'**accumulation** par cause commune (concentration journalière, Gini 0,69) ;
- l'**indice de queue** de sévérité $\xi \approx 0,90$, avec sa sensibilité au seuil (0,93, 0,83, 0,68 aux seuils q_{90} , q_{95} , q_{99}) et son **hétérogénéité par catégorie** (0,92 à 1,37 selon la catégorie Bâle), qui justifie un ξ_j *par pilier*.

Elle **ne fixe pas** la **direction hors-diagonale** de W . La frontière d'identification est donc nette : les marges sont ancrées, la structure dirigée ne l'est pas. W relève alors d'un autre régime de connaissance, le **jugement d'expert structuré** (élicitation de Cooke, chapitre ??), et son influence est **bornée par une analyse de sensibilité**, jamais posée comme mesurée.

8.5 La donnée manquante comme livrable

Puisque les deux sources échouent pour des raisons opposées (l'une manque de volume et de taxonomie, l'autre de résolution temporelle), la donnée qui identifierait W se déduit par complémentarité. Un registre d'incidents TIC **identifiant** W devrait :

1. horodater la **survenance** (et non la seule déclaration) au **mois ou à la semaine**, afin de porter une antériorité que le pas annuel efface ;
2. catégoriser par **domaine de contrôle** (les piliers DORA), et non par vecteur d'attaque, afin qu'une transition soit interprétable comme un lien $k \rightarrow j$;
3. consolider une **cause commune** comme *un* événement à N victimes, pour ne pas confondre un batch de déclaration avec une contagion séquentielle.

Cette spécification n'est pas un vœu : elle est directement opposable au cadre de reporting DORA, dont elle constitue une **recommandation actionnable**. La limite d'identifiabilité devient ainsi une contribution réglementaire.

Ce que ce chapitre apporte au mémoire. Démontrer, chiffres à l'appui, qu'une dépendance que tout le monde *postule* n'est pas *mesurable* sur les données publiques est rare et courageux. Cela transforme une faiblesse apparente (« je n'ai pas calibré W ») en trois résultats : une **frontière d'identification** explicite, une **discipline** sur l'usage de W (normatif, borné, jamais sur-vendu), et une **spécification de reporting** qui donne au travail une portée au-delà du modèle.

9 Identification partielle et bornes de capital

Le problème, et la sortie. Le chapitre précédent établit que la *direction* de la contagion n'est pas identifiable sur les données disponibles. Deux attitudes sont alors possibles. On peut **poser** W au jugement d'expert et publier un SCR ponctuel : c'est simple, lisible, et entièrement suspendu à un jugement qui n'a pas encore été élicité. Ou bien on peut refuser de choisir, caractériser l'**ensemble** des W compatibles avec ce que l'on sait, et publier des **bornes**. Ce chapitre construit la seconde voie, la compare à la première, et montre qu'elle est la seule des deux à être opposable aujourd'hui.

9.1 Le modèle en couches

Le modèle se lit désormais en deux couches, dont la séparation est la ligne de partage entre ce qui est estimé et ce qui est posé.

Le socle, identifié. Fréquence d'entrée surdispersée, accumulation par cause commune, sévérité GPD en euros. Aucun de ces éléments ne dépend de W . En annulant toute contagion ($W = 0$), on obtient le **SCR nu** : 5 275 M€ dans le calage de référence. C'est le plancher défendable, et il ne repose sur aucun paramètre non identifiable.

La couche de contagion, partiellement identifiée. Toute matrice se décompose de façon unique en

$$W = S + A, \quad S = \frac{1}{2}(W + W^\top), \quad A = \frac{1}{2}(W - W^\top).$$

La donnée identifie la co-occurrence, donc S . Elle n'identifie pas la direction, donc A (chapitre 8). L'**ensemble admissible** est alors

$$\mathcal{W}(t) = \{ S + A : A^\top = -A, |A_{jk}| \leq t S_{jk}, \rho(S + A) < 1 \},$$

la contrainte $|A_{jk}| \leq S_{jk}$ découlant de la seule positivité ($W_{jk} \geq 0$ et $W_{kj} \geq 0$), et $t \in [0, 1]$ mesurant ce que la donnée *ignore* de la direction : $t = 1$ est l'ignorance totale, c'est-à-dire l'état actuel des sources publiques.

9.2 Ce que le capital devient

Les bornes sont obtenues par énumération **exhaustive** des $2^{10} = 1\,024$ sommets du pavé, ce qui les rend déterministes et reproductibles. À $t = 1$:

$$\text{SCR} \in [6\,858 ; 8\,697] \text{ M€},$$

soit un facteur 1,27 entre les deux bouts. Rapporté au socle, cela s'énonce ainsi : **la contagion ajoute entre +30 % et +65 % au capital, et la donnée ne permet pas de trancher plus finement**. Le point d'expert (8 110 M€) est un point de cet ensemble, jamais sa mesure.

Une lecture à ne pas faire. À indice de queue élevé, la queue annuelle obéit au principe de la perte unique dominante : la VaR est *peu* sensible à la structure de cascade. Faire porter la démonstration par le seul niveau de VaR donnerait un tableau de sensibilité plat et trompeusement rassurant. La contribution se lit sur la **perte moyenne** (bornes [849 ; 1 100] M€, estimateur bien moins bruité) et surtout sur la **décision**, c'est-à-dire l'ordre de remédiation.

La valeur de l'information. Le paramètre t se lit comme le degré de contrainte qu'un registre d'incidents apporterait sur la direction. Passer de $t = 1$ à $t = 0,5$, c'est-à-dire borner l'asymétrie à la moitié du niveau de co-occurrence, ferait tomber la largeur des bornes de 1 839 à 695 M€, soit **−62 %**. La spécification de reporting proposée au chapitre 8 cesse ainsi d'être un vœu : elle est chiffrée en euros de capital.

9.3 Poser W ou le borner : la comparaison avant élicitation

Le test décisif se fait *avant* les séances d'élicitation, car un dispositif qui ne survit qu'à une élicitation réussie n'est pas un dispositif, c'est un pari.

	Régime A : on pose W	Régime B : modèle en couches
Sortie sur le capital	un point, 8 110 M€	socle 5 275 + bande [6 858 ; 8 697]
Opposable sans élicitation	non, tout repose sur le classeur	oui, 79 % du capital est déjà fixé
Panel biaisé	déplace le SCR de 777 M€	la bande ne bouge pas
Priorité de remédiation	P1, sans marge d'erreur	tête P1/P4, ordre interne ouvert
Si l'élicitation échoue	plus de paramètre, plus de modèle	le résultat tient, en bornes

Le test de biais du panel. On fait varier la direction élicitée depuis « le panel confirme le classeur » jusqu'à « le panel dit l'inverse », en allant au bord du pavé admissible. Le régime A suit : le SCR publié se déplace de 777 M€, soit 10 %, et la priorité bascule entre trois piliers différents, **sans que rien dans le régime A ne signale ce déplacement au lecteur**. La bande du régime B, elle, ne bouge pas d'un euro, et contient tous les dérapages possibles du panel.

À quoi sert alors l'élicitation. Son rôle est précis et limité, et c'est un résultat acquis sans elle. Sur l'ensemble admissible, **P5 n'arrive jamais en tête**, P3 dans moins de 10 % des cas, et P1 (45 %) et P4 (36 %) concentrent 81 % des configurations. L'élicitation sert donc à **départager P1 et P4** et à resserrer la bande. Elle ne peut pas faire remonter les autres piliers : l'ensemble admissible l'interdit déjà.

9.4 Le niveau est illustratif, le rapport est le résultat

Un relecteur exigeant objectera qu'une tour d'hypothèses accouche d'un grand nombre. L'objection est fondée si le mémoire vend un niveau. Elle tombe si le mémoire vend un rapport *et* démontre que le rapport, lui, ne bouge pas. On fait donc varier ce que le modèle ne maîtrise pas, en laissant la cascade inchangée.

Configuration	socle	bornes	haute/socle	% fixé
Référence (OpRisk)	5 275	[6 858 ; 8 697]	1,65	78,9 %
Sévérité PRC	239	[336 ; 424]	1,77	79,2 %
Fréquence $\times 3$	11 709	[14 353 ; 17 405]	1,49	82,5 %

Lecture. Le **niveau** bouge d'un facteur 41. Il est fixé par la calibration de sévérité et de fréquence, qui sont des *entrées* du modèle et non des sorties de la cascade, et qui dépendent d'un périmètre de collecte non transposable (pertes américaines de grandes institutions, plafond de réassurance). Les **rapports** varient d'au plus 33 % de leur valeur moyenne, soit un ordre de grandeur trente fois plus faible, et le **groupe de tête** de la priorité de remédiation est identique dans les trois configurations.

Où la stabilité du relatif s'arrête, et il faut le dire. Le rapport le moins stable est la largeur de bande rapportée au socle, qui varie de 32,9 % : elle diminue quand la fréquence augmente, ce qui est attendu, la queue annuelle étant alors moins dominée par une perte unique et donc moins sensible à la structure de cascade. La stabilité du relatif n'est donc pas parfaite. Elle est simplement d'un tout autre ordre que celle du niveau.

Ce que ce chapitre autorise à écrire. Le niveau absolu du SCR est **illustratif** et ne doit pas être lu comme une mesure. Ce que le modèle détermine, et qui résiste au changement de source, c'est le rapport du capital au socle, la largeur de la bande d'ignorance directionnelle, et le classement des piliers. Ce n'est pas une précaution de langage ajoutée après coup : c'est un résultat vérifié, et c'est la raison pour laquelle le mémoire présente partout des écarts et des bornes plutôt que des points.

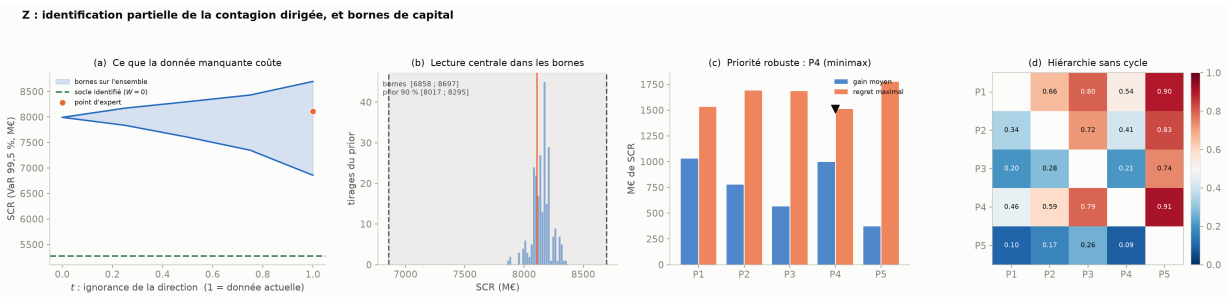


Figure 9.1. Identification partielle de la contagion dirigée. (a) Le coût de la donnée manquante : les bornes se resserrent à mesure que l'ignorance directionnelle t diminue. (b) La lecture centrale du prior d'expert, à l'intérieur de bornes qui n'en dépendent pas. (c) La priorité de remédiation robuste, au sens du regret maximal. (d) La dominance majoritaire entre piliers sur l'ensemble admissible.

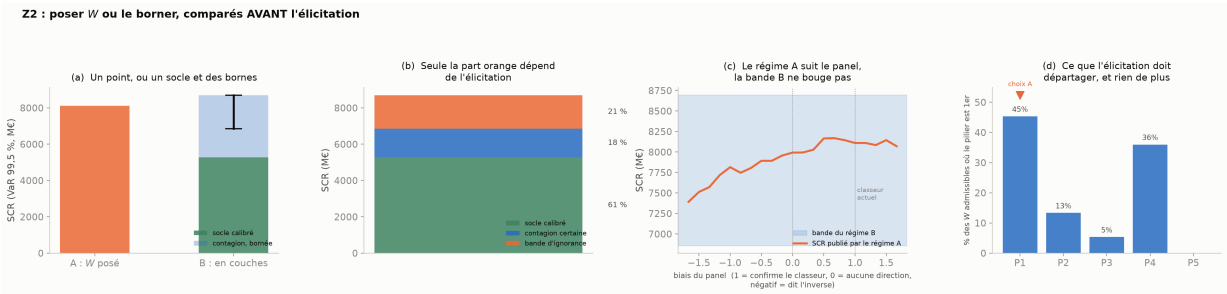


Figure 9.2. Poser W ou le borner, comparés avant élicitation. (a) Un point contre un socle et des bornes. (b) Seule la part supérieure dépend de l'éllicitation. (c) Le régime A suit le biais du panel, la bande du régime B ne bouge pas. (d) Ce que l'éllicitation doit départager, et rien de plus.

9.5 L'échelle de repli sur la direction

La décomposition $W = S + A$ borne la direction en bloc. On peut faire mieux, en suivant la méthode d'attaque puis de repli : reparamétriser la propagation par

$$\text{logit } p_{ij} = \text{logit } p_j + u_{ij},$$

où p_j est l'**attractivité de la cible** (ce qui subsiste quand la source ne compte pas) et u_{ij} l'**excès propre à la source**, c'est-à-dire la direction. La décomposition n'est identifiée qu'une fois posée la normalisation $\sum_{i \neq j} u_{ij} = 0$ pour chaque j : c'est une convention de repérage, et non une information, ce que l'on vérifie numériquement (une translation compensée de p_j et de u laisse le SCR strictement inchangé). On descend alors une échelle de crans, du plus ambitieux au repli : u libre, puis u de **rang 1** ($u_{ij} = b_j(a_i - \bar{a})$, qui capte 74 % de la direction posée et resserre les bornes de 25 % au prix d'une hypothèse de structure), puis u élicité, puis $u = 0$.

Le cran nul, et ce qu'il révèle de la contribution. À $u = 0$, la propagation ne dépend plus que de la cible : *aucune source ne se distingue*. Or c'est exactement là que P1 et P4, les deux piliers de tête, deviennent **indiscernables** (gains de remédiation 1 051 contre 1 052 M€, écart nul), alors qu'ils sont séparés de 353 M€ dès que la direction du classeur est rétablie. **La direction est donc précisément ce qui départage les deux piliers prioritaires** : sans elle, on ne sait plus lequel remédier d'abord. La contribution du mémoire ne se lit pas sur le niveau d'un quantile, elle se lit ici, sur une décision qui bascule (figure 9.3).

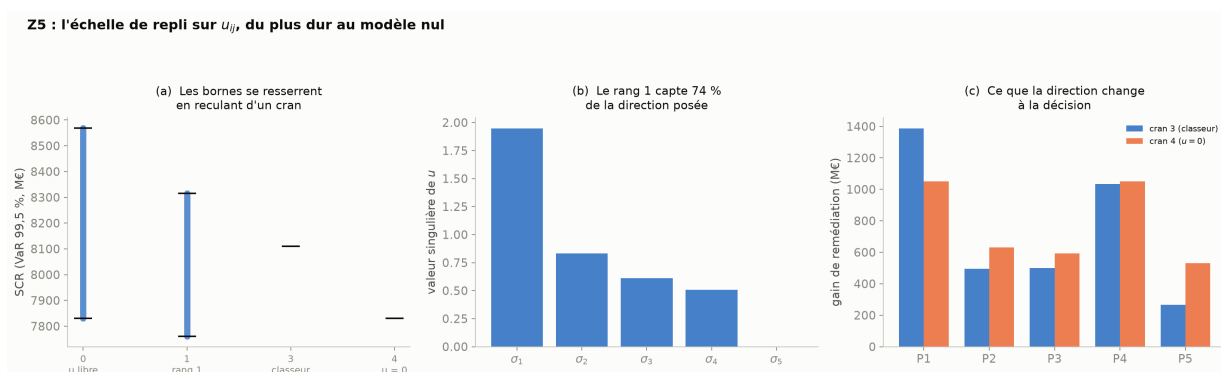


Figure 9.3. L'échelle de repli sur u_{ij} . (a) Les bornes de capital se resserrent quand on recule d'un cran (hypothèse de structure). (b) Un rang 1 capte 74 % de la direction posée. (c) Ce que la direction change à la décision : au cran nul, les gains de remédiation de P1 et P4 se rejoignent.

Ce que ce chapitre transmet à la suite

Les deux chapitres qui suivent font parler le modèle : la conformité y devient un état qui évolue (chapitre 10) et l'on en tire une trajectoire de capital, un surcoût et un ordre de remédiation (chapitre 11). Ils ne relâchent pas la discipline établie ici. Tout ce qu'ils calculent l'est à *contagion fixée*, sur un point de l'ensemble admissible : les bornes de ce chapitre enveloppent donc chaque niveau qu'ils afficheront. On lira par conséquent leurs montants comme illustratifs, leurs écarts comme robustes, et la priorité entre les deux piliers de tête comme ce que seule la direction, non identifiée, peut trancher. Le reste du mémoire est l'application de ce principe, pas un second modèle.

10 La conformité multi-états

Idée directrice. Ce chapitre et le suivant sont l'*application* du modèle construit et discipliné aux chapitres 6–9 : ils répondent au « combien » de la question du mémoire, sous la prudence qu'imposent les bornes du chapitre 9. Le SCR dépend de l'**état de conformité** de l'entité, objet ni binaire ni statique. On le modélise à **deux échelles de temps** (*fast-slow*). À l'échelle rapide, un **Vasicek multi-états** définit l'état (non conforme, partiellement conforme, conforme) de chaque pilier et le fait piloter la cascade. À l'échelle lente, une **chaîne de Markov** fait progresser la conformité le long de la mise en conformité. C'est le remplacement *dynamique* de la variable latente statique de l'ancien mémoire, et tout ce qui en sort se lit avec la même règle : le niveau est illustratif, l'écart et l'ordre sont ce qui est défendable.

10.1 Le principe des deux échelles de temps

Le chapitre 6 chiffre le SCR pour un état de conformité *figé*. Or la conformité n'est ni un point ni un instantané : elle est graduelle (trois niveaux au moins) et évolue dans le temps. On distingue donc deux dynamiques. La **couche rapide** est celle des incidents et de leur cascade à l'intérieur d'une année, chiffrée par le moteur du chapitre précédent, *conditionnellement* à une configuration de conformité. La **couche lente** est celle de la gouvernance : l'état de conformité de chaque pilier progresse sur des mois et des années. L'état de la couche lente sert de **paramètre** à la couche rapide. C'est exactement la structure d'un modèle de risque de crédit à migration de rating, sur laquelle on revient en §10.6.

10.2 Le Vasicek multi-états : latente et seuils ordonnés

Chaque pilier porte une **capacité de conformité latente** $C^* \sim \mathcal{N}(0, 1)$, décomposée à la Vasicek en un facteur systémique commun Θ et un choc idiosyncratique :

$$C^* = \gamma \Theta + \sqrt{1 - \gamma^2} \varepsilon, \quad \gamma = 0,68. \quad (10.1)$$

Au lieu d'un unique seuil de défaut, on en pose **deux**, ordonnés, qui découpent trois états :

$$\text{NC si } C^* \leq K_{\text{bas}}, \quad \text{PC si } K_{\text{bas}} < C^* \leq K_{\text{haut}}, \quad \text{C si } C^* > K_{\text{haut}}. \quad (10.2)$$

Les seuils sont fixés par les probabilités d'état **ancrées** sur les enquêtes de conformité (fin 2025), $K_{\text{bas}} = \Phi^{-1}(p_{\text{NC}})$ et $K_{\text{haut}} = \Phi^{-1}(p_{\text{NC}} + p_{\text{PC}})$. Ce dispositif est un **ordered-probit** posé sur la structure de Merton-Vasicek : il réutilise la machinerie de seuil du chapitre 6 (le seuil K_j) et généralise la variable latente de défaut, binaire, en une variable latente de conformité à trois niveaux.

Le facteur systémique rend les probabilités conditionnelles. La probabilité d'être dans chaque état sachant l'environnement Θ s'écrit

$$\mathbb{P}(\text{NC} \mid \Theta) = \Phi\left(\frac{K_{\text{bas}} - \gamma\Theta}{\sqrt{1-\gamma^2}}\right), \quad \mathbb{P}(\text{C} \mid \Theta) = 1 - \Phi\left(\frac{K_{\text{haut}} - \gamma\Theta}{\sqrt{1-\gamma^2}}\right). \quad (10.3)$$

Intégrée sur Θ , la marginale redonne exactement l'ancrage (contrôle de cohérence) ; en crise systémique, la masse bascule vers la non-conformité. C'est la version à trois états ordonnés de l'amplification systémique que portait l'ancienne variable latente, qu'on remplace ainsi proprement.

10.3 Les trois canaux : comment l'état pilote la cascade

L'état de conformité agit sur la cascade par **trois canaux**, câblés sans réécrire l'agrégation du chapitre 6 :

1. **Fréquence** λ : l'état module le nombre d'incidents amorcés, via les multiplicateurs de scénario sourcés (S_0 conforme, S_1 partiel, S_2 non conforme).
2. **Propagation** g : une entité plus conforme contient mieux la contagion, donc un gain plus faible. La propension à propager depuis un pilier reste $e_j = g(c_j) s_j / \max_k s_k$, avec un gain indexé sur l'état du pilier source.
3. **Détection** p_u : le taux de matérialité (le seuil de détection du chapitre 6). Une entité conforme intercepte et remédie tôt, de sorte qu'une moindre fraction d'incidents atteint la sévérité matérielle.

On présente ces canaux en **lectures emboîtées** (fréquence seule ; + propagation ; + détection), ce qui rend visible la contribution marginale de chacun et empêche qu'un canal domine en silence. Le canal détection, qui se compose avec la fréquence, est traité à part et présenté en sensibilité tant que son ampleur n'est pas tranchée.

10.4 L'état par pilier

L'apport central est de porter l'état **par pilier** : chaque pilier a sa propre latente C_j^* , les cinq étant corrélées par le facteur systémique commun Θ . C'est ce qui fait *interagir* la conformité et la cascade : un pilier non conforme propage plus et détecte moins que ses voisins conformes. Les trois canaux deviennent indexés par pilier ($\lambda_j, g_j, p_{u,j}$) et alimentent un moteur d'agrégation qui se réduit exactement à la version globale lorsque tous les piliers partagent un état (contrôle de cohérence). On en déduit la **décomposition** du surcoût de non-conformité par pilier, en basculant un pilier à la fois, dont les résultats sont au chapitre 11.

10.5 La chaîne de Markov et les séjours de type phase

À l'échelle lente, l'état de conformité suit une chaîne de Markov à temps continu $\text{NC} \rightarrow \text{PC} \rightarrow \text{C}$, l'état Conforme étant **absorbant** en cas de base (une fois conforme, on le reste ; la régression est un axe de sensibilité). Les séjours ne sont pas exponentiels mais de **type phase** (Erlang- k) : une exponentielle autoriserait une remédiation quasi instantanée (densité maximale en zéro), irréaliste, alors qu'un projet DORA a une durée minimale. L'Erlang- k , somme de k exponentielles, a un mode strictement positif qui capte cette durée. On développe chaque macro-état transitoire en k phases et l'on résout le générateur Q sur l'espace de phases par exponentielle de matrice :

$$(\mathbb{P}(\text{NC}, t), \mathbb{P}(\text{PC}, t), \mathbb{P}(\text{C}, t)) = (\text{sommes de phases de}) v_0 \exp(Qt), \quad (10.4)$$

où v_0 est la distribution initiale. À chaque horizon t , cette distribution agrège les SCR par état du Vasicek multi-états :

$$\text{SCR}(t) = \sum_{e \in \{\text{NC}, \text{PC}, \text{C}\}} \mathbb{P}(e, t) \text{SCR}_e. \quad (10.5)$$

10.6 Le couplage systémique et l'analogie de crédit

Un seul facteur couple les deux couches. Le même facteur systémique Θ agit à la fois sur la couche lente et sur la couche rapide. Un environnement dégradé ($\Theta < 0$) fait deux choses avec le *même* tirage : il **ralentit la remédiation**, via des taux de transition $\mu(\Theta) = \mu_0 e^{\beta_{\text{rem}}\Theta}$, et il **durcit la cascade**, via $\text{SCR}_e(\Theta) = \text{SCR}_e e^{-\beta_{\text{casc}}\Theta}$. Les deux poussent le capital dans le même sens : la corrélation entre conformité et sinistralité, qu'auraient perdue des couches indépendantes, est restaurée. La dispersion de Θ engendre la bande d'incertitude de la trajectoire.

Cette architecture est celle, éprouvée, du risque de crédit à **migration de rating** : la chaîne de Markov joue le rôle de la migration d'un rating de conformité DORA à la qualité change lentement, d'année en année), et le Vasicek multi-états celui du modèle de **défaut conditionnel au rating** (rapide, dans l'année, pour un rating donné). Transposer cette structure à deux étages au risque cyber n'est pas une invention fragile mais l'application d'un cadre reconnu, ce qui en fait un argument de robustesse et non un pari.

Ce chapitre en donne la méthodologie complète ; les résultats chiffrés et les figures qui en découlent sont rassemblés au chapitre 11.

11 Résultats

Ce chapitre livre le « combien » de la question du mémoire, sous la discipline posée aux chapitres 8 et 9 : les niveaux sont illustratifs, les écarts et les ordres sont ce qui résiste. Tous les résultats sont ancrés, comme dans l'ancien mémoire, sur une entité type de 15 000 M€ de provisions, avec deux périmètres de sévérité : **OpRisk** (grandes pertes opérationnelles, queue lourde) et **PRC** (sévérité plafonnée à 40 M€). Sauf mention contraire, on lit la médiane et l'intervalle interquartile, la variance de la sévérité étant infinie ($\xi \approx 0,9$).

Comment lire les niveaux de ce chapitre. Les montants qui suivent sont **illustratifs** et ne doivent pas être lus comme la mesure du capital d'une entité réelle. Le chapitre 9 le démontre : en ne faisant varier que la loi de sévérité et la fréquence, c'est-à-dire des *entrées* du modèle qui dépendent d'un périmètre de collecte non transposable, le niveau se déplace d'un facteur 41, tandis que les rapports au socle varient d'au plus 33 % et que le groupe de tête du classement des piliers ne change pas. Le tableau 11.1 en donne d'ailleurs l'illustration immédiate : le même état conforme vaut 8 301 M€ sous OpRisk et 2 589 M€ sous PRC, soit un facteur 3,2 pour un seul changement de périmètre de sévérité. **Ce chapitre établit donc des écarts, des rapports et des ordres**, et c'est sur eux, jamais sur un niveau, que reposent ses conclusions.

Réconciliation avec le socle du chapitre 9. Ce chapitre parle d'un SCR *conforme* d'environ 5 900 M€, quand le chapitre 9 parle d'un *socle* de 5 275 M€. Ce ne sont pas deux mesures de la même chose, mais deux points d'un seul modèle. Le socle est pris à contagion **nulle** ($W = 0$), fréquence de référence, sans canal de détection. L'état conforme, lui, conserve une contagion (le gain $g = 0,45$ n'est pas nul) et module la détection. Le pont, calculé sur le moteur commun à graine fixée, l'établit terme à terme :

$$\underbrace{5\,275}_{\text{socle } W=0} \xrightarrow{+ \text{ contagion } g=0,45} 6\,504 \xrightarrow{+ \text{ détection } \times 0,85} 5\,936 \approx \text{conforme.}$$

Le canal fréquence est neutre ici (le scénario conforme S0 a la fréquence de référence). L'écart résiduel entre le moteur exact du chapitre 9 et le Monte-Carlo de ce chapitre est de 210 M€ (4 %) sur une configuration identique, soit le bruit d'échantillonnage déjà déclaré, non une divergence de fond (figure 11.1). L'ordre socle < conforme < non conforme est donc cohérent : le socle est plus bas *parce qu'il n'a aucune contagion*.

11.1 SCR par état de conformité

Le SCR croît de façon monotone de l'état conforme à l'état non conforme (figure 11.2). Le tableau 11.1 donne les trois lectures emboîtées : la lecture A (fréquence seule) est directement comparable au mémoire ; la lecture B ajoute la propagation de la cascade ; la lecture C ajoute le canal détection.

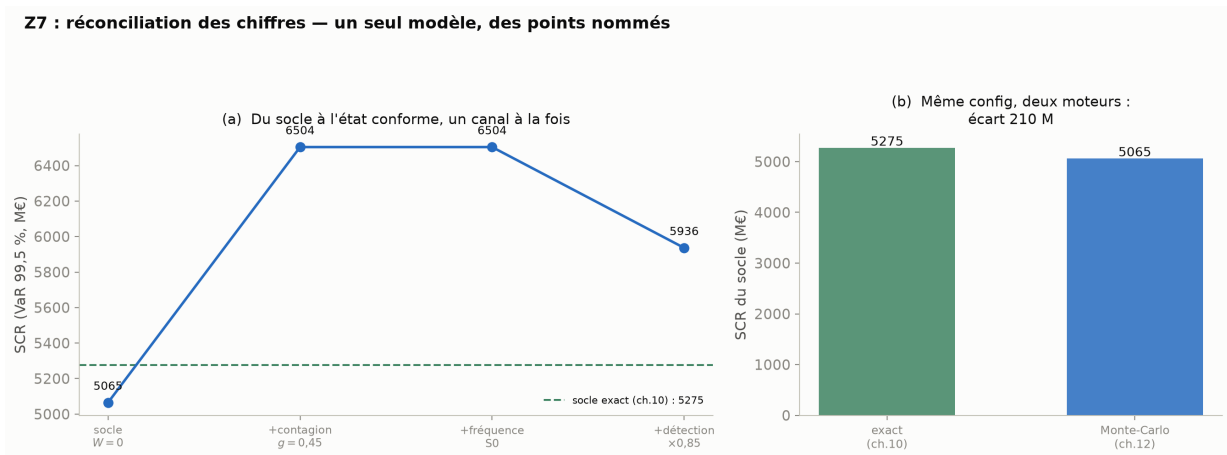


Figure 11.1. Réconciliation des chiffres. (a) Du socle ($W = 0$, chapitre 9) à l'état conforme (ce chapitre), un canal ajouté à la fois sur le moteur commun. (b) Sur une configuration identique, l'écart entre le moteur exact et le Monte-Carlo est le seul bruit d'échantillonnage. Source : script 36.

État	OpRisk (M€)			PRC (M€)		
	A	B	C	A	B	C
Conforme	8301	6664	5932	2589	1903	1642
Partiellement conforme	11059	9625	9625	3653	3118	3118
Non conforme	15074	15074	16595	5520	5520	6577

Table 11.1. SCR par état, trois lectures (A : fréquence ; B : + propagation ; C : + détection). Source : script 16. Le canal détection ne joue qu'aux extrêmes (il abaisse l'état conforme et relève le non conforme), l'état partiel n'étant pas modulé.

Deux lectures à trancher pour le chiffre de tête. Le canal détection porte le SCR non conforme (OpRisk) de 15 074 (lecture B) à 16 595 M€ (lecture C), soit +10 %. Ce canal se compose avec la fréquence et pourrait sur-estimer l'effet ; il est présenté ici *séparément* et exclu des trajectoires du §11.4 et de la priorisation du §11.5, tant que son ampleur n'est pas validée. Le reste des résultats est présenté en lecture B (fréquence + propagation), la plus prudente sur le chiffre de tête.

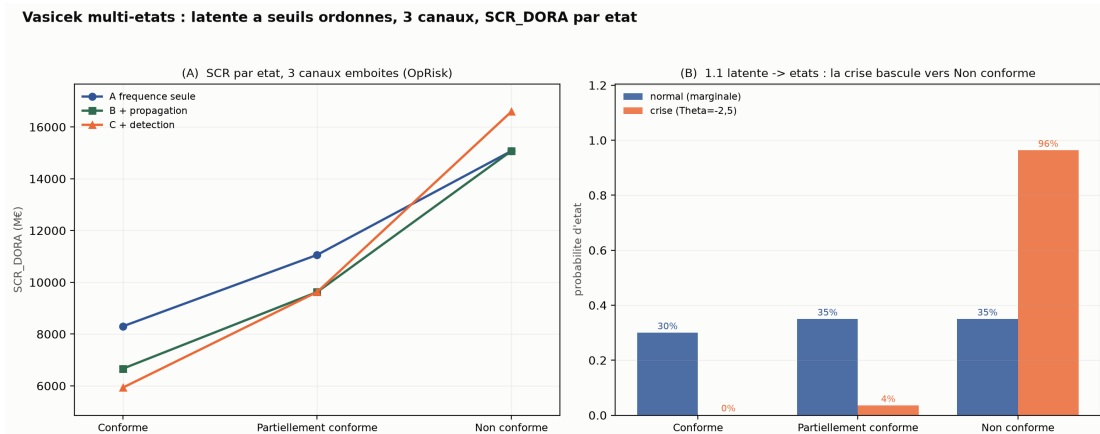


Figure 11.2. SCR par état de conformité (trois canaux emboîtés) et bascule des états en crise systémique. Source : script 16.

Le **surcoût de non-conformité** $\Delta_{DORA} = SCR(NC) - SCR(C)$, à graine Monte-Carlo commune (l'écart ne vient que du changement d'état, non du bruit), s'obtient par bootstrap deux niveaux (multiplicateurs + sévérité). Il ressort du même ordre que celui du mémoire, amplifié par la propagation, et 100 % **des tirages sont positifs**.

	médiane	IC90 %	mémoire (réf.)
Δ_{DORA} NC vs C (OpRisk)	7401	[2830 ; 38793]	3879
Δ_{DORA} PC vs C (OpRisk)	2556	[963 ; 12768]	—
Δ_{DORA} NC vs C (PRC)	3668	[3201 ; 4094]	2015
Δ_{DORA} PC vs C (PRC)	1257	[1077 ; 1466]	—

Table 11.2. Surcoût de non-conformité en euros (M€), lecture B (fréquence + propagation), bootstrap deux niveaux. Côté OpRisk la sévérité de queue est ré-échantillonnée sur les 91 excès réels (méthode du mémoire, script 14), non tirée dans une approximation normale ; l'intervalle reste large parce que la queue l'est, non par artefact de méthode. Le surcoût intermédiaire (PC vs C) est chiffré pour la première fois. Source : script 16.

Lecture actuarielle. L'intervalle très large côté OpRisk n'est pas un défaut du modèle : c'est la signature d'une queue d'indice 0,60, où le niveau du capital est intrinsèquement imprécis. L'écart typique (interquartile) est bien plus resserré que l'intervalle à 90 %, et le *signe* du surcoût, lui, est certain. On retrouve la thèse du mémoire : le SCR est une distribution, pas un point.

L'intervalle PRC est étroit, et il le reste quand on cesse de croire la conversion exacte. La sévérité PRC est dérivée du nombre d'enregistrements compromis par la relation log-log de Jacobs (2014), dont la sortie de régression donne un écart-type résiduel de 0,523 en logarithme naturel ($R^2 = 0,51$) : à volume donné, le coût réel varie d'un facteur 2,4 autour de la droite à 90 %. Réinjecter ce résidu enregistrement par enregistrement dans le bootstrap (script 21, figure 11.3) ne rouvre pourtant presque pas l'intervalle (facteur d'IC $\approx 1,4$ avec comme sans résidu) : sur 15 053

enregistrements, le bruit se moyenne dans l'ajustement GPD, et le plafond de sévérité borne la queue épaissie. L'effet est un déplacement de *niveau* : la queue dérivée s'épaissit (ξ de 1,03 à 1,07, taux de matérialité de 0,150 à 0,157) et la médiane du surcoût monte de 7 % (de 3 600 à 3 861 M€). L'étroitesse de l'intervalle PRC n'est donc pas un artefact de la conversion déterministe. L'incertitude qui ne se moyenne pas, elle, est celle des coefficients (a, b) de la régression, estimés sur 115 observations : elle relève d'un axe de sensibilité, non d'un bruit par enregistrement.

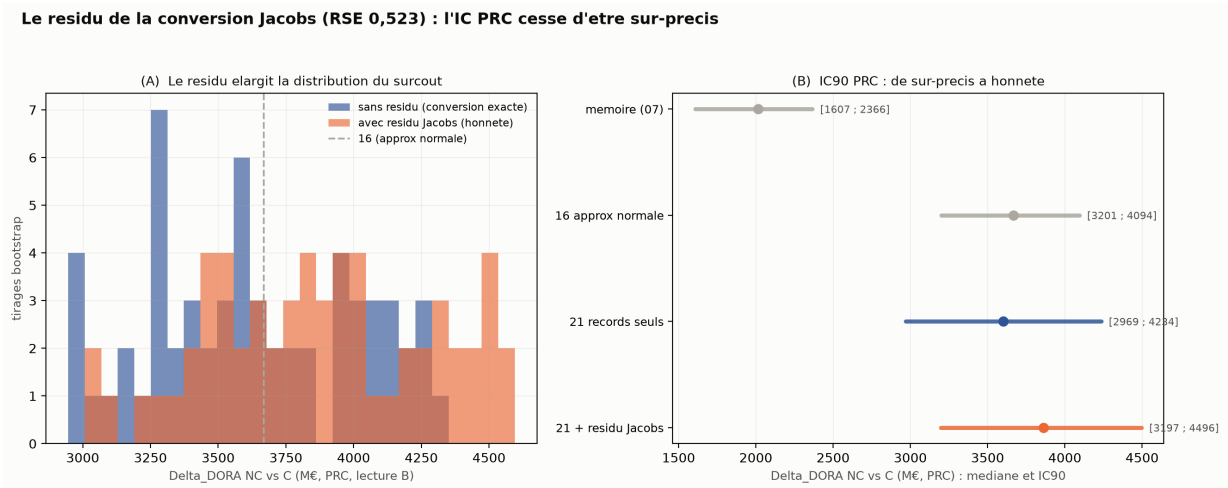


Figure 11.3. Le résidu de la conversion Jacobs ($RSE = 0,523$) : la distribution du surcoût PRC se déplace plus qu'elle ne s'élargit. Source : script 21.

11.2 Décomposition par pilier

En basculant un pilier à la fois de conforme à non conforme, le surcoût se décompose (figure 11.4). Le classement obtenu, $P1 > P4 > P2 > P3 > P5$, **reproduit exactement le classement ROOT** du modèle qualitatif, établi indépendamment par jugement d'expert : deux voies de construction distinctes convergent sur la même hiérarchie de piliers.

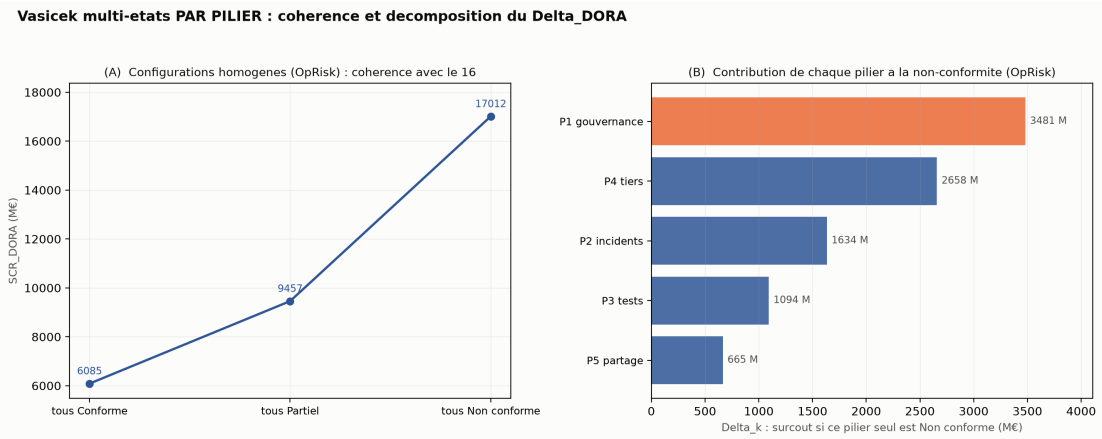


Figure 11.4. Décomposition du Δ_{DORA} par pilier et validation croisée avec ROOT. Source : script 16b.

Une interaction super-additive, établie là où l'estimateur est fiable. Les surcoûts isolés ne somment pas au surcoût total : il reste un terme d'*interaction*, signature de la cascade (un pilier non conforme amplifie aussi les contagions amorcées ailleurs qui le traversent), qu'un modèle sans propagation (le LDA à copule du mémoire) ne peut pas produire. Sa mesure exige toutefois de la prudence : une interaction est une différence de différences, l'estimateur Monte-Carlo le plus fragile qui soit en queue lourde. Sur la VaR à 99,5 % OpRisk, son *signe* n'est pas résolu : il varie de $-1,9$ à $+2,1$ Md€ selon la graine à résolution égale, et la mesure de référence (60 000 années, graine 909) donne $+1\,395$ M€. Un tel intervalle interdit d'en tirer quoi que ce soit. La super-additivité est en revanche robuste partout où le bruit de queue ne domine pas : en *perte moyenne* sur les deux périmètres ($+560$ M€ OpRisk, $+827$ M€ PRC, soit environ un cinquième du surcoût moyen dans les deux cas), et jusque dans la VaR du périmètre PRC, dont le plafond de sévérité tronque la queue ($+905$ M€). Conséquence pratique : puisque les marginaux ne somment pas au total, l'attribution du surcoût aux piliers exige une règle principielle qui somme exactement : c'est l'objet de la valeur de Shapley (section 11.3). Sources : scripts 16b, 20b.

11.3 Allocation du capital : Shapley et Euler

La décomposition qui précède pose deux questions d'allocation distinctes. *Qui porte le surcoût ?* appelle une attribution par pilier *source* de la non-conformité, qui doit composer avec l'interaction (les marginaux ne somment pas au total). *Où loge le capital ?* appelle une allocation du niveau SCR(NC) par pilier *touché*, cohérente au sens où les parts somment au total. La valeur de Shapley répond à la première, la règle d'Euler à la seconde (script 20, figure 11.5).

11.3.1 Shapley : attribuer le surcoût, interaction comprise

On munit les piliers d'une fonction caractéristique

$$v(S) = \text{SCR}(S \text{ en NC, reste C}) - \text{SCR}(\text{tous C}), \quad S \subseteq \{P1, \dots, P5\},$$

calculée par la cascade sur les 2^5 configurations à graine Monte-Carlo commune. Le marginal de la section précédente est $v(\{k\})$; la valeur de Shapley

$$\varphi_j = \sum_{S \subseteq \{P1, \dots, P5\} \setminus \{j\}} \frac{|S|! (5 - |S| - 1)!}{5!} [v(S \cup \{j\}) - v(S)]$$

moyenne la contribution de j sur tous les ordres d'arrivée. Par efficience, $\sum_j \varphi_j = v(\text{tous}) = \Delta_{\text{DORA}}$ *exactement* : la règle redistribue l'interaction que les marginaux isolés laissent de côté, quel que soit son signe.

Le classement de Shapley reproduit le classement ROOT sur les deux périmètres. Une part de cette convergence est mécanique, et il faut le dire : les amorces de la cascade sont semées proportionnellement à ROOT (parts 30/27/18/15/9 %), et le canal fréquence d'un pilier module sa propre part d'amorce. Le test non trivial est la *déformation* : la part de Shapley de P1 (34 %) excède sa part d'amorce (30 %), effet propre de la propagation (P1 est l'émetteur le plus fort de W), et l'interaction redistribuée ($+1\,395$ M€ OpRisk, $+905$ PRC à cette graine) est intégralement un produit de la cascade, absent d'un modèle additif.

11.3.2 Euler : allouer le niveau, et une limite d'estimation assumée

La règle d'Euler alloue SCR(NC) par $C_j = \mathbb{E}[L_j \mid L \geq \text{VaR}_{99,5\%}]$ (version TVaR, exacte par construction), où L_j est la perte du pilier *touché* j dans la cascade. Côté PRC, l'allocation est stable et presque plate : P2 23 %, P4 23 %, P1 20 %, P3 18 %, P5 17 %, et les parts de capital

pilier	OpRisk			PRC		
	marginal	φ_j	part	marginal	φ_j	part
P1 gouvernance	3481	3717	34 %	1375	1608	32 %
P4 tiers	2658	2810	26 %	1075	1252	25 %
P2 incidents	1634	1867	17 %	721	920	19 %
P3 tests	1094	1484	14 %	571	738	15 %
P5 partage	665	1048	10 %	311	438	9 %
somme	9531	10 927	100 %	4052	4957	100 %

Table 11.3. Valeur de Shapley du surcoût Δ_{DORA} (M€, NC vs C, trois canaux, protocole du script 16b). Les marginaux somment à 9531 (OpRisk), la valeur de Shapley à 10 927, le surcoût total exactement. Cellules arrondies au million et parts au point de pourcentage; les sommes sont calculées avant arrondi. Source : script 20.

coïncident avec les parts de perte moyenne parce que le plafond de sévérité tronque la queue ($\text{TVaR} = 6\,795 \approx \text{VaR} = 6\,573$ M€). Côté OpRisk, les parts *moyennes* sont stables (P2 23 %, P4 22 %, P1 20 %, P3 18 %, P5 16 %), mais l'allocation de la queue extrême ne l'est pas, et ce n'est pas un défaut de calcul : avec $\xi \approx 0,6 > 0,5$, la sévérité est de variance infinie, l'estimateur Monte-Carlo de la TVaR converge en régime de loi stable, et le classement conditionnel bascule d'une résolution à l'autre (vérifié à 150 et 240 mille années simulées). On rapporte donc l'allocation de queue du périmètre PRC, régularisée par le cap, et l'on tient celle d'OpRisk pour indicative. Contrôle de cohérence EVT au passage : $\text{TVaR}/\text{VaR} \approx 2,1$, à comparer à l'asymptote $1/(1 - \xi) = 2,5$.

Sources et réceptacles. Les deux allocations ne racontent pas la même chose, et c'est le résultat : Shapley, vue *source*, concentre le surcoût sur P1 (34 %), là où naît la non-conformité ; Euler, vue *réceptacle*, répartit le capital presque uniformément sur les piliers touchés (P2 et P4 en tête légère). La remédiation se décide côté source ; le capital, lui, se loge là où les cascades atterrissent.

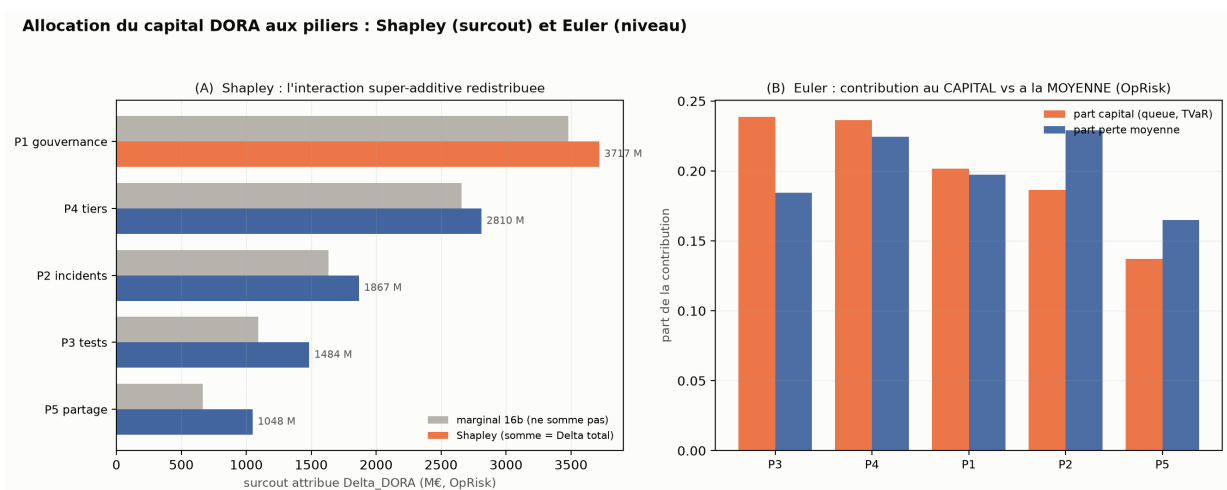


Figure 11.5. Allocation du capital DORA (OpRisk). (A) Shapley contre marginaux : l'interaction redistribuée. (B) Euler : parts de capital (queue) contre parts de perte moyenne ; sur ce périmètre non plafonné, l'allocation fine de la queue extrême reste indicative ($\xi \approx 0,6$, variance de sévérité infinie). Source : script 20.

11.4 Trajectoire du capital

Le long de la mise en conformité, le capital décroît de l'état initial vers le SCR conforme, et le surcoût résiduel $\Delta_{\text{DORA}}(t)$ tend vers zéro (tableau 11.4, figure 11.6). Partant de l'état marginal actuel (NC 35 %, PC 35 %, C 30 %), le capital OpRisk passe de $\sim 10\,750$ à $\sim 7\,040$ M€ sur cinq ans, vers le SCR conforme ($\sim 6\,925$).

t (ans)	SCR(t) médiane	bande 90 %	$\Delta_{\text{DORA}}(t)$
0	10752	[9092 ; 12654]	3827
1	9576	[7205 ; 12040]	2652
2	8310	[6194 ; 11042]	1385
3	7575	[5924 ; 10164]	650
5	7041	[5857 ; 9028]	116

Table 11.4. Trajectoire du capital DORA (M€, OpRisk). Source : script 17.

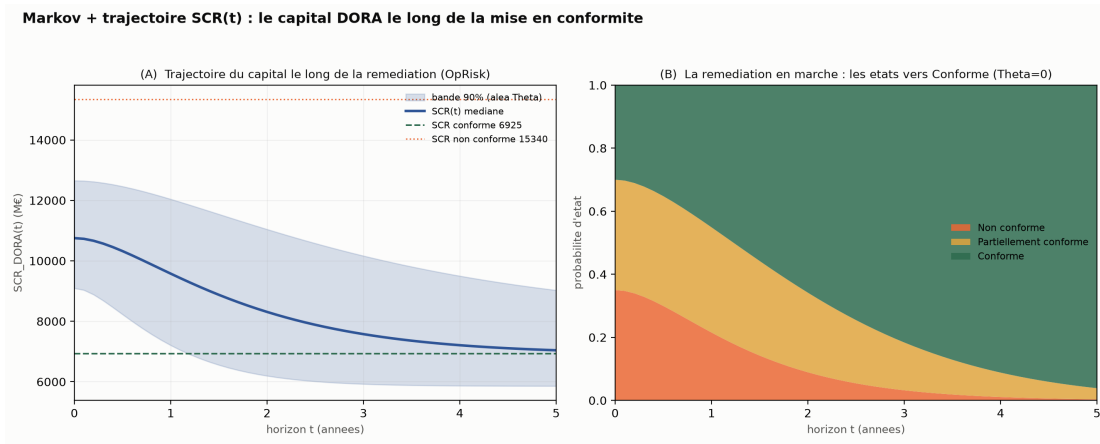


Figure 11.6. Trajectoire SCR(t) et évolution des états de conformité. Source : script 17.

Lecture actuarielle. L'intégrale de la trajectoire, à un coût de capital près, est le *coût de portage* de la non-conformité pendant la remédiation. La bande reste large et surtout haute en environnement dégradé : la vraie exposition n'est pas le capital médian, c'est le risque que la remédiation traîne quand la menace monte, précisément le scénario où le capital importe le plus.

11.5 Priorisation de la remédiation

Sous budget contraint (un pilier remédié à la fois), l'énumération des 120 ordres donne l'ordre optimal $P1 \rightarrow P4 \rightarrow P2 \rightarrow P3 \rightarrow P5$, **égal à l'ordre ROOT** et distinct de l'ordre glouton par valeur d'accélération (figure 11.7). L'écart de capital intégré entre le pire ordre et l'optimal atteint 21 %.

Le myope n'est pas l'optimal. Remédier au coup par coup le pilier au plus fort gain immédiat (l'ordre glouton) coûte plus cher que l'ordre optimal, parce que les interactions de cascade imposent de raisonner sur l'horizon entier. Que l'optimum coïncide avec le classement ROOT, obtenu par une voie qualitative indépendante, est la troisième convergence euro $\leftrightarrow$ ordinal du mémoire, après la stabilité de la progéniture (§6.5) et la décomposition par pilier.

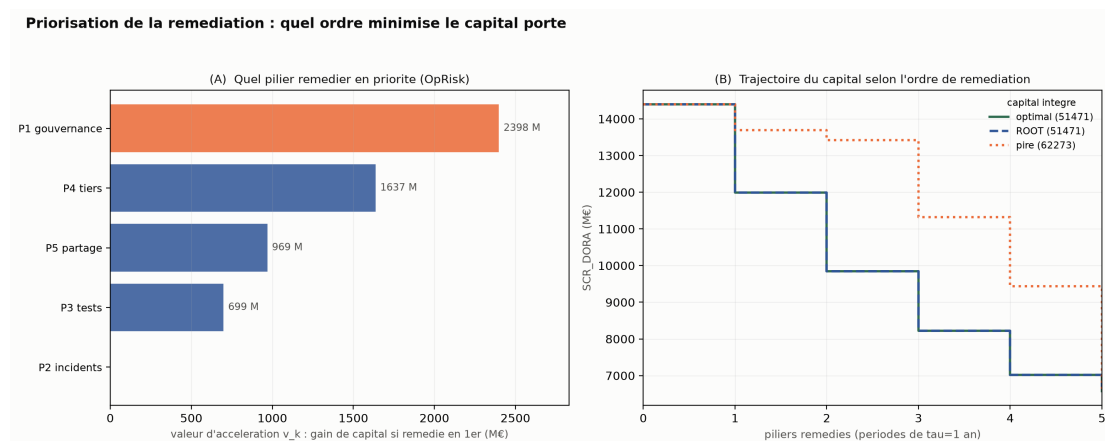


Figure 11.7. Valeur d'accélération par pilier et ordre de remédiation optimal. Source : script 18.

11.6 Robustesse

Le niveau du capital bouge fortement selon les leviers non calibrés (l'indice de queue ξ domine, facteur ~ 6), mais la **direction** ($\Delta_{DORA} > 0$) et la **priorité** (P1 en tête) tiennent sur tous les réglages testés (figure 11.8).

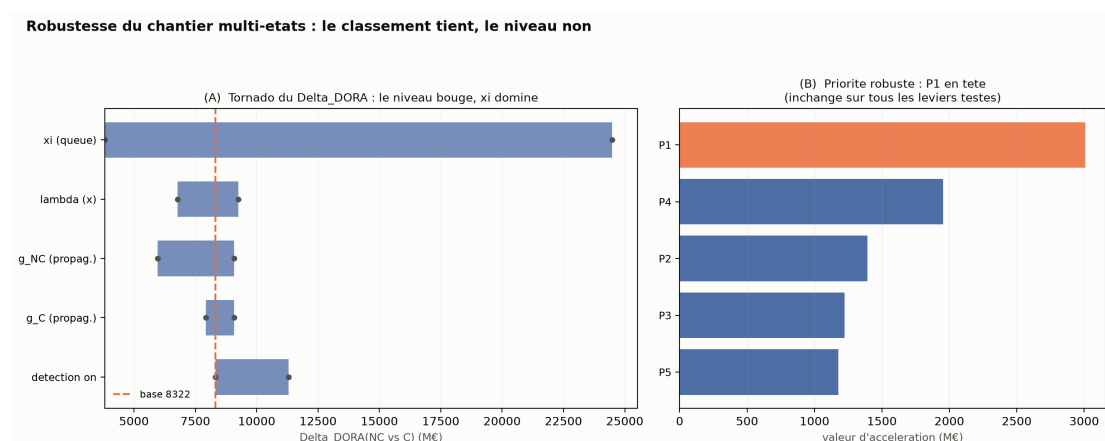


Figure 11.8. Robustesse : le classement tient, le niveau non. Source : script 19.

La recommandation ne dépend d'aucun paramètre non mesurable. L'ordre de remédiation optimal ne dépend que des SCR par configuration, donc il est **invariant aux taux de transition de la chaîne de Markov**, pourtant les paramètres les moins calibrables. Ces taux fixent le calendrier de la trajectoire, jamais la séquence recommandée. Le verdict d'ensemble rejoint celui de toute la démarche : le classement est robuste là où le niveau ne l'est pas.

Ce que cette robustesse ne couvre pas, et il faut le dire. Les tests ci-dessus font varier les paramètres du modèle à *matrice W fixée*, celle du classeur qualitatif. Ils établissent donc que P1 arrive en tête *si l'on admet cette direction*. Dès lors que l'on admet ne pas connaître la direction et que l'on balaie l'ensemble admissible (chapitre 9), P1 et P4 deviennent **pratiquement à égalité** : P1 arrive premier dans 45 % des configurations, P4 dans 36 %, et l'écart de regret maximal entre les deux n'est que de 1,5 %. Les deux énoncés ne se contredisent pas, ils portent sur des sources d'incertitude différentes. Ce qui est robuste dans les deux cadres, c'est que P1 et P4 devancent nettement P2, P3 et P5, et que P5 n'arrive *jamais* en tête.

Les hypothèses restantes ont leur axe de stress. Trois entrées du chantier ne figuraient pas dans le tornado : les coefficients de la conversion Jacobs, la charge systémique γ et l'ancrage des probabilités d'état (figure 11.9). Les coefficients (a, b) , estimés sur 115 observations, sont stressés à $\pm 1,645$ écart-type en *pivotant la droite au centroïde* de la régression, déduit des erreurs-types publiées ($\bar{x} = 10,04$, soit environ 23 000 enregistrements) ; stresser a et b indépendamment ignorerait leur corrélation négative. L'élasticité b commande l'épaisseur de la queue dérivée (ξ de 0,85 à 1,21) mais le surcoût PRC reste contenu, de 3 125 à 3 977 M€ autour du central (3 577), le plafond de sévérité bornant l'effet : c'est l'axe d'hypothèse dominant du périmètre PRC, et le verdict y survit. γ ne touche, par construction, ni le SCR par état ni le SCR espéré en régime normal (invariant à 10 644 M€) : il ne commande que la sévérité de la bascule en crise (P(NC | crise) de 84 à 100 %, SCR espéré en crise de 14 148 à 15 071). L'ancrage des probabilités d'état, enfin, déplace le capital espéré actuel (9 951 à 11 485 M€ selon les enquêtes retenues) mais jamais le SCR par état ni le surcoût NC contre C, qui lui sont conditionnels. Les trois axes confirment la ligne de partage du chantier : les hypothèses bougent des niveaux, jamais la direction ni le classement. Source : script 22.

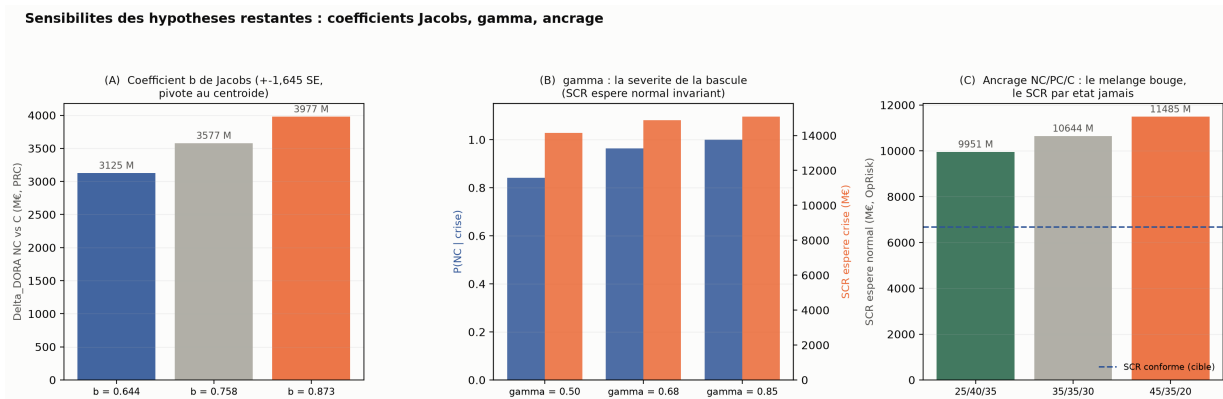


Figure 11.9. Sensibilités des hypothèses restantes : coefficients Jacobs (pivotés au centroïde déduit des erreurs-types publiées), charge systémique γ , ancrage des probabilités d'état. Source : script 22.

11.7 Benchmark : la dépendance n'est pas le mécanisme

Le mémoire a remplacé le LDA à copule par la cascade dirigée. Ce que ce remplacement apporte se mesure en confrontant la cascade à des jumeaux copule construits pour lui ressembler (script 23, figure 11.10, périmètre OpRisk, graines Monte-Carlo communes).

La photo. À marges par pilier *identiques* (celles de la cascade, état conforme) et corrélation calée, la copule gaussienne retombe sur le SCR de la cascade (+0,1 %) : en queue lourde ($\xi \approx 0,6$), la queue annuelle obéit au principe de la perte unique dominante et le *niveau* de base n'identifie pas la dépendance. La Student ($\nu = 4$) le surestime de 17 % en forçant des co-extrêmes que le mécanisme ne produit pas (2,28 piliers extrêmes par année de queue contre 1,12). Le choix de

copule est donc à la fois non identifiable et conséquent ; la cascade n’a pas ce degré de liberté : sa dépendance est produite par le mécanisme, pas choisie.

L’intervention. Basculer un pilier en non-conformité est une intervention, pas un conditionnement. Le jumeau LDA-copule exprime les canaux fréquence et détection (les marges dépendent de l’état de leur pilier), mais trois manques sont structurels. (i) La propagation n’a nulle part où vivre : le surcoût total ressort à 6 760 M€ contre 10 927 pour la cascade, une sous-estimation de 38 %. (ii) Les marges ne dépendant que de l’état de leur propre pilier et la copule étant figée, la perte moyenne totale est *exactement* additive : interaction moyenne nulle par construction (+0 M€ mesuré), là où la cascade en produit +560 M€ : l’interaction moyenne mesurée plus haut est une signature falsifiable qu’aucun modèle copule-marges ne peut reproduire. (iii) La priorité de remédiation impliquée s’inverse sur P2/P3, et la dépendance ne durcit pas quand la conformité se dégrade, alors que c’est précisément le canal que DORA fait bouger (*g* de 0,45 à 0,90).

Ce que le benchmark établit. La copule peut imiter la photo d’un état ; elle ne peut imiter ni le surcoût (propagation), ni l’interaction (additivité en moyenne), ni le durcissement de la dépendance avec la non-conformité. La dépendance n’est pas le mécanisme : c’en est l’ombre portée.

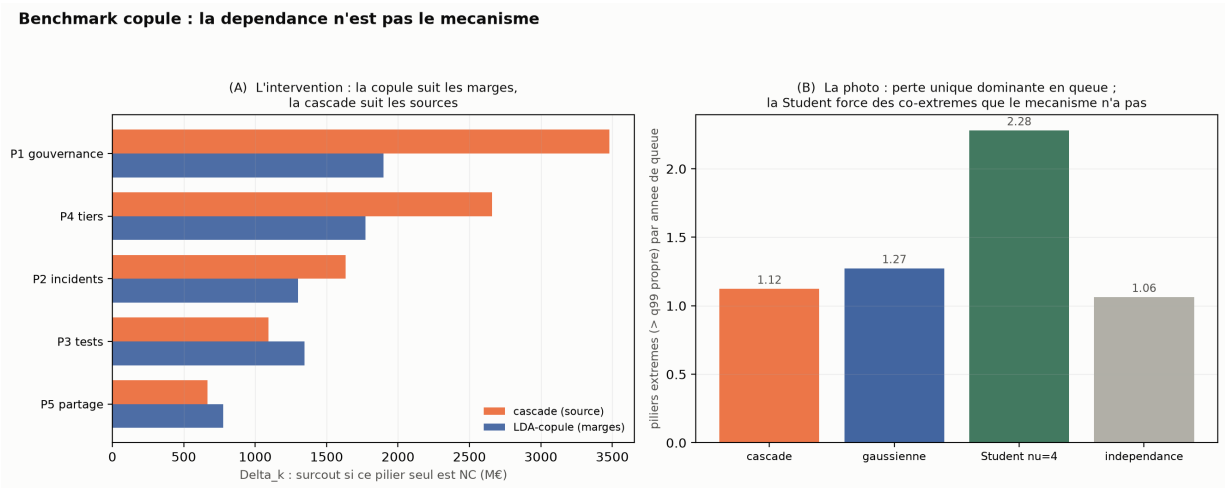


Figure 11.10. Benchmark copule (OpRisk). (A) Intervention : le jumeau copule suit les marges et sous-estime le surcoût, la cascade suit les sources. (B) Photo : perte unique dominante en queue ; la Student force des co-extrêmes que le mécanisme n’a pas. Source : script 23.

11.8 Mise en regard réglementaire

La question finale est celle de la portée : de l’effet de la conformité que le modèle mesure, quelle fraction les cadres existants savent-ils exprimer ? On confronte donc, sur le même écart de capital entre profil conforme et non conforme, trois dispositifs (script 27).

Cadre	Δ capital $C \rightarrow NC$	part de l’effet cascade
Formule Standard (Solvabilité II)	0 M€	0 %
LDA-copule (dépendance symétrique)	6 760 M€	62 %
Cascade dirigée	10 927 M€	100 % (référence)

Table 11.5. Fraction de l’effet DORA que chaque cadre sait exprimer. Source : script 27.

La Formule Standard est structurellement aveugle. La charge de risque opération-

nel $SCR_{op} = \min(0,3 BSCR ; 0,03 \max(\text{primes}, \text{provisions}))$ ne dépend que du volume : elle est *identique* pour une entité exemplaire et pour une entité défaillante sur DORA. Sa réponse à la conformité est nulle par construction. La copule en capte 62 % (les canaux fréquence et détection) mais rate la propagation, faute de direction. Seule la cascade exprime l'effet complet. La valeur du modèle se lit donc en **effet DORA rendu visible**, non en un niveau de SCR à interpréter dans l'absolu.

Jusqu'où l'open data descend, et où il s'arrête (script 28). Un test sur la base VCDB montre que les sous-piliers de P2 (familles d'action) et, plus grossièrement, la détection de P3 sont exploitables sur donnée ouverte (plusieurs centaines d'incidents en finance, 45 % de détection lente). Mais le pilier des tiers P4 **s'effondre** : 56 incidents à acteur partenaire en finance, et la donnée ouverte sous-code notoirement l'externalisation. Le pilotage fin de P4 exige donc une donnée que seul un registre d'externalisation, tenu par l'entité ou le régulateur, peut fournir. C'est le même verdict que celui du chapitre 8, décliné au niveau des sous-piliers.

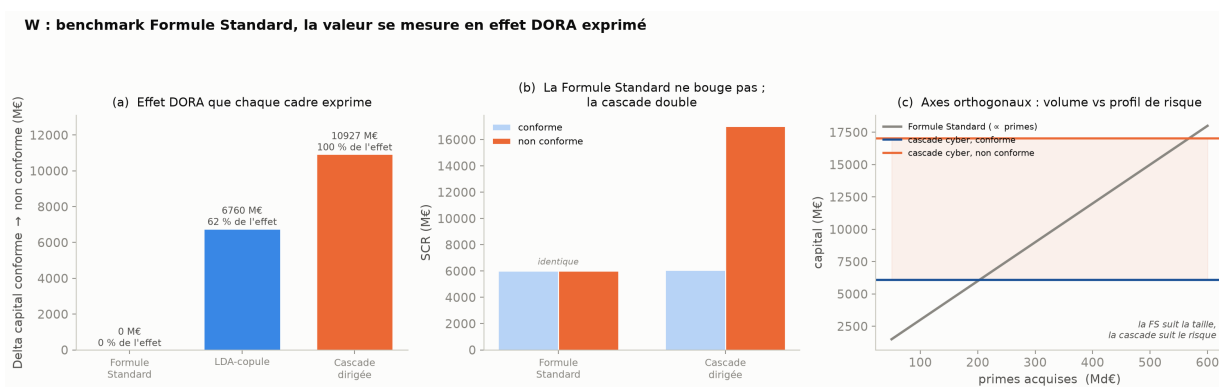


Figure 11.11. Ce que chaque cadre exprime de l'effet DORA : 0 % pour la Formule Standard, 62 % pour la copule, 100 % pour la cascade. Source : script 27.

11.9 Un ordre de grandeur à l'épreuve du réel

Le niveau absolu n'ayant jamais été présenté comme une mesure, il reste à le confronter au réel, non pour le valider mais pour vérifier qu'il ne *peut* pas l'être. Deux confrontations suffisent.

Contre la Formule Standard, sur la même entité. Pour l'entité notionnelle (15 000 M€ de provisions), la charge opérationnelle de la Formule Standard plafonne à $0,03 \times 15\,000 \approx 450$ M€. Le socle de la cascade (5 275 M€, chapitre 9) lui est **une dizaine de fois supérieur**. Deux lectures cohabitent, et aucune ne se tranche sans donnée d'entité : soit la charge générique *sous-capte massivement* le cyber, ce que le benchmark ci-dessus établit par ailleurs ; soit la sévérité OpRisk, tirée de grandes institutions américaines, *sur-représente* pour une entité de taille moyenne. Les deux jouent, à des degrés qu'on ne sait pas départager.

Contre le marché. Un capital cyber de l'ordre de 5 milliards d'euros pour une *seule* entité représenterait une fraction substantielle des primes cyber annuelles mondiales, elles-mêmes de l'ordre de la dizaine de milliards d'euros (Munich Re, 2024). Le rapport est invraisemblable à l'échelle d'un assureur moyen : il signale que le niveau, transporté d'une sévérité de grandes institutions vers une entité notionnelle, ne saurait être lu comme le capital d'une entité réelle.

Ce que la confrontation établit. Elle ne calibre pas le niveau, elle le **disqualifie comme mesure** et confirme, par un chemin externe, la lecture que tout le mémoire adopte : ce sont le **rapport au socle**, la **largeur de la bande** d'ignorance et la **hiérarchie des piliers** qui portent les conclusions, jamais le montant en euros. Loin d'affaiblir le travail, cette mise à l'épreuve montre que sa discipline de lecture n'est pas une précaution de style mais une nécessité que le réel impose.

12 Inventaire des hypothèses et de leur sensibilité

Le chapitre 11 a conduit les tests de robustesse eux-mêmes (tornado, sensibilités des hypothèses restantes, invariance de l'ordre de remédiation). Ce chapitre ne les refait pas : il en donne la **synthèse en une table**, puis l'inventaire exhaustif des paramètres, de leur nature et de leur sensibilité. Il sert de pièce justificative, de sorte qu'aucun chiffre du mémoire ne soit sans origine déclarée.

Thèse. Les conclusions du modèle ne reposent pas sur les paramètres non calibrés. Je le montre en deux temps : (i) elles sont **insensibles** aux choix de modélisation innocents (structure de la cascade, famille de dépendance, couche temporelle, source de sévérité) ; (ii) elles ne **réagissent** qu'aux leviers qui doivent compter (conformité, contagion), ce qui est une *qualité*, pas un défaut, c'est la sensibilité au risque que la Formule Standard n'a pas. Reste une incertitude irréductible, la queue de sévérité, que j'assume en présentant le SCR comme une **distribution**, jamais un point.

12.1 L'argument de robustesse, en une table

Conclusion	Ce qu'on fait varier	Effet mesuré	Verdict
La non-conformité coûte cher ($\Delta_{\text{DORA}} > 0$, grand)	source de sévérité (OpRisk / PRC), famille de copule ($\theta \in [1, 4]$)	facteur $\sim 1,9$ entre sources ; Δ_{DORA} varie $< 1,4\%$ sur θ	robuste
Priorité de remédiation P1 puis P4 (les <i>sources</i>)	cadre de dépendance (cascade vs copule), branchement vs marche	P1 et P4 en tête dans tous les cadres ; SCR $\pm 4\%$ (branchement)	robuste
C'est l' asymétrie de W qui porte le résultat	knockout de l'asymétrie (3 000 tirages), placebo directionnel	sans la direction, le signal tombe sous le bruit du placebo	robuste
Pas de couche de Hawkes	noyau exponentiel puis à retard, logique two-phase	excitation intra-journalière ; endogénéité $\rightarrow 0$ si exogène isolé	robuste
Le SCR <i>réagit</i> à la conformité et à la contagion	score de conformité $q \in [0, 1]$, gain $g \in [0,05; 0,90]$	-53% de NC à C ; $\times 1,6$ sur la plage de g	voulu
Le SCR est une distribution large, pas un point	incertitude de paramètre (bootstrap deux niveaux)	facteur $\sim 2,5$ sur la VaR par la seule incertitude de calibration	assumé

Lecture. Les quatre premières lignes sont l'**ossature** : le signe et l'ordre de grandeur de l'effet DORA, la hiérarchie des piliers, le rôle de la direction et le rejet du Hawkes tiennent quand on change ce qui pourrait sembler arbitraire. La cinquième ligne n'est pas une fragilité mais le **cœur du modèle** : un SCR qui ne bougerait pas avec la conformité serait inutile (c'est le reproche fait à la Formule Standard, chapitre ??). La dernière est la limite honnête : la queue de sévérité domine l'incertitude, donc toute lecture ponctuelle du SCR serait une surinterprétation.

12.2 Tableau des paramètres non calibrés (et de leur sensibilité)

Trois natures sont distinguées : **calibré** sur données (avec son incertitude), **posé** par jugement d'expert ou choix normatif (non identifiable, cf. chapitre 8), et **semi-ancré** sur un proxy externe non spécifique au périmètre.

Paramètre	Valeur	Nature	Justification	Sensibilité du SCR
Queue de sévérité ξ	0,90 (OpRisk 0,60, PRC 1,03)	calibré, incertain	GPD sur pertes réelles ; hétérogène par catégorie (0,92–1,37)	forte : 0,68–0,93 selon le seuil ; pilote la queue
Échelle GPD σ , seuil u , p_u	57,97 M€ ; 20,03 M€ ; 0,15	calibré	POT au percentile 85, conversion en euros	modérée (via la queue)
Fréquence λ	~21,6/an (OpRisk)	calibré	incidents TIC matériels / 27 ans	linéaire sur le niveau
Sur-dispersion ϕ	9,20	semi-calibré	Var/Moyenne observé, maintenu entre scénarios	faible
Choc commun fréquence a	0,60	posé (prudent)	dépasse l'IC empirique haut (0,22) : conservateur	enveloppe le modèle à paquets ($\times 2,5$)
Structure $W = g \text{ TRANS} / \max_k s_k$	classeur qualitatif	posé / normatif	jugement d'expert, à éliciter (Cooke) ; direction non identifiable	l'asymétrie porte le résultat (knockout)
Gain de propagation g	0,90 base ; par état 0,45/0,68/0,90	posé	amplitude de W , bornée par Leontief $\rho(W) \leq g < 1$	levier : $\times 1,6$ sur [0,05 ; 0,90]
Score de conformité q / états	continu [0, 1] (ou NC/PC/C)	posé	décrit le profil, subsume 3 ou 5 niveaux	levier : –53 % de NC à C
Multiplicateur de matérialité par état	0,85/1,00/1,20	posé	module p_u selon la conformité	modérée (canal détection)
Charge systémique γ	0,68	semi-ancré	proxy concentration cloud (AWS+Azure+GCP, Synergy 2025)	modérée
Seuil de crise θ_{crise}	–2,5	posé	déclenche le régime de comouvement extrême	agit sur la seule queue crise
Probas d'état $P(\text{NC/PC/C})$	0,35/0,35/0,30	semi-ancré	enquêtes conformité DORA ~50 % non conformes (Deloitte, ESA)	déplace le mélange, pas les états
Copule de dépendance θ	Gumbel 1,8	posé	queue supérieure entre briques	négligeable : $\Delta_{\text{DORA}} < 1,4\%$ sur [1, 4]
Plafond de sévérité	40 M€	posé	capacité de réassurance ($\xi \geq 1$)	borne la queue extrême

Ce que la table rend visible. Les seuls paramètres à **forte** sensibilité sont soit calibrés sur données (la queue ξ , dont on assume et chiffre l'incertitude), soit des **leviers voulus** (g , q) qui traduisent précisément l'objet du mémoire (l'effet de la conformité et de la contagion sur le capital). Les paramètres purement **posés** qui ne sont pas des leviers (θ de copule, γ , θ_{crise} , probas d'état, matérialité) ont une influence **faible à modérée** et documentée. Aucune conclusion ne repose sur un paramètre à la fois non calibré *et* déterminant hors de son rôle attendu.

La double lecture. « Insensible aux choix innocents, sensible aux leviers réels » : le modèle n'est ni sur-ajusté ni fragile, il est **piloté par ce qui doit le piloter**. Et la seule grande incertitude, la queue, est nommée et bornée, pas cachée. C'est ce qui transforme « je n'ai pas tout calibré » en « je sais précisément de quoi mon SCR dépend, et de quoi il ne dépend pas ».

13 Conclusion

Ce mémoire a construit un modèle interne partiel du coût en capital de la non-conformité à DORA, où la dépendance entre les cinq piliers est portée par une cascade dirigée plutôt que par une copule, et où le capital dépend de l'état de conformité de l'entité. Trois lignes de résultat s'en dégagent, et il importe de dire aussi nettement ce qui est acquis que ce qui ne l'est pas.

13.1 Ce qui est établi

Le mécanisme tient et se distingue formellement de ses concurrents : la criticité dépend de l'**ordre** de propagation, propriété qu'aucune dépendance symétrique ni aucun score additif ne peut reproduire, et la normalisation de Leontief garantit la stabilité de la contagion, cycles compris, par construction et non par calibration heureuse. Sur les marges que la donnée fixe, la queue de sévérité ($\xi \approx 0,9$), la fréquence d'entrée et l'accumulation par cause commune, l'ancrage empirique est solide, et le rejet du processus de Hawkes est argumenté plutôt que subi. Enfin, le modèle exprime intégralement l'effet de la conformité sur le capital là où la Formule Standard n'en exprime rien.

13.2 Ce qui est démontré comme non mesurable

La **direction** de la contagion n'est pas identifiable sur les données publiques. Le mémoire l'établit sur deux sources qui échouent pour des raisons opposées, résiste à la tentation du test dégénéré du temps inversé, et pousse jusqu'à la meilleure expérience naturelle disponible, le choc de chaîne d'approvisionnement MOVEit, dont l'effet net s'annule une fois un placebo retranché. Cette limite n'est pas dissimulée, elle est convertie en méthode : on borne le capital sur l'ensemble des matrices admissibles plutôt que d'en poser une. Le socle sans contagion est ainsi défendable sans aucune hypothèse non identifiable, et la contagion ajoute une bande explicite au-dessus de ce socle.

13.3 Ce qui en découle pour le régulateur

La donnée qui rendrait la contagion mesurable se déduit par complémentarité des deux échecs : un registre d'incidents horodatant la **survenance** à la semaine, catégorisant par **domaine de contrôle** et non par vecteur d'attaque, et consolidant une cause commune comme un événement unique. Cette spécification n'est pas un vœu : le mémoire chiffre en euros de capital le resserrement des bornes qu'elle apporterait. La limite d'identifiabilité devient une recommandation de reporting opposable, ce qui donne au travail une portée au-delà du modèle.

13.4 Limites, sans détour

Le panel d'élicitation reste à constituer, et tant qu'il ne l'est pas la lecture centrale de la direction repose sur un classeur qualitatif, non sur une agrégation d'experts pondérée. Le niveau absolu du SCR est illustratif et ne doit pas être cité hors de son cadrage relatif. L'incertitude de queue domine toute lecture ponctuelle, ce qui impose de présenter le capital en distribution. Et

l'ordre de remédiation entre les deux piliers de tête, la gouvernance et la gestion des tiers, dépend de la direction non identifiée : le mémoire sait dire que ces deux-là dominant, pas lequel remédier d'abord sans un dire d'expert.

13.5 Ouvertures

Trois prolongements se dessinent : mener l'élicitation structurée pour resserrer la bande directionnelle sur ses deux degrés de liberté restants ; approfondir le pilier des tiers sur des données clients, là où l'open data s'effondre ; et passer de la sensibilité de propagation à une véritable criticité au sens de l'audit, c'est-à-dire au risque résiduel après mesures de contrôle, une fois disponible une métrique de mitigation par pilier.

A Démonstrations : le modèle de cascade

Cette annexe démontre les propriétés énoncées à la section 6.8. Les notations sont celles du chapitre 6 : $P = \{1, \dots, 5\}$, $W \in [0, 1]^{P \times P}$ avec $W_{jj} = 0$, et la cascade indépendante de la définition 6.1.

Forme réduite et descendance espérée (proposition 6.2)

Démonstration. Soit $\mathcal{M}_n(a, k)$ le nombre de marches dirigées de longueur n de a vers k dans le graphe pondéré. Une marche $a = v_0 \rightarrow v_1 \rightarrow \dots \rightarrow v_n = k$ est vivante avec probabilité $\prod_t W_{v_{t-1}v_t}$, ces arêtes étant indépendantes; en sommant sur les marches, $\mathbb{E} \mathcal{M}_n(a, k) = \sum \prod_t W_{v_{t-1}v_t} = (W^n)_{ak}$ par définition du produit matriciel. Le nombre de fois où k est atteint depuis a en comptant chaque chemin vaut $\sum_{n \geq 0} \mathcal{M}_n(a, k)$, d'espérance $\sum_{n \geq 0} (W^n)_{ak}$. Cette série matricielle est la série de Neumann de W ; elle converge vers $(I - W)^{-1}$ si et seulement si $\rho(W) < 1$, auquel cas $\sum_{n \geq 0} W^n = (I - W)^{-1}$.

L'indicatrice $\mathbf{1}\{k \in S_a\}$ vaut 1 dès qu'*au moins un* chemin vivant relie a à k , donc $\mathbf{1}\{k \in S_a\} \leq \sum_{n \geq 0} \mathcal{M}_n(a, k)$ presque sûrement. En prenant l'espérance puis en sommant sur k ,

$$\mathbb{E}|S_a| = \sum_k \mathbb{P}(k \in S_a) \leq \sum_k ((I - W)^{-1})_{ak} = [(I - W)^{-1} \mathbf{1}]_a.$$

L'inégalité est stricte dès qu'un pilier est accessible par plusieurs chemins avec probabilité positive, ce qui quantifie les collisions. $\square$

Sous-criticité par normalisation (proposition 6.3)

Démonstration. Par construction (6.4), $W = (g/s_{\max}) \text{TRANS} \geq 0$ et, pour toute ligne j , $\sum_k W_{jk} = (g/s_{\max}) \sum_k \text{TRANS}_{jk} \leq (g/s_{\max}) s_{\max} = g$, puisque $s_{\max}$ est la plus grande somme de ligne de TRANS. Pour une matrice à coefficients positifs, le rayon spectral est majoré par toute norme d'opérateur subordonnée, en particulier la norme infinie, qui est le maximum des sommes de lignes : $\rho(W) \leq \|W\|_\infty = \max_j \sum_k W_{jk} \leq g < 1$. La série de Neumann converge donc et $(I - W)^{-1} = \sum_{n \geq 0} W^n$ existe, à coefficients positifs. $\square$

Loi exacte de l'ensemble atteint (proposition 6.4)

Démonstration. Fixons $A \ni a$. L'événement $\{S_a = A\}$ est l'intersection de deux événements portant sur des arêtes disjointes, donc indépendants : (i) aucune arête ne relie A à son complémentaire (sans quoi S_a dépasserait A), et (ii) a atteint tout A par les seules arêtes internes à A . L'événement (i) ne concerne que les arêtes $j \rightarrow k$ avec $j \in A$, $k \notin A$, chacune absente avec probabilité $1 - W_{jk}$ indépendamment; sa probabilité est $B(A) = \prod_{j \in A, k \notin A} (1 - W_{jk})$. L'événement (ii) ne concerne que les arêtes internes à A ; notons $R(A)$ sa probabilité. Par indépendance, $\mathbb{P}(S_a = A) = R(A) B(A)$.

Pour $R(A)$, on partitionne selon le sous-ensemble A' effectivement atteint par les arêtes internes : A' contient a , et $A' \subsetneq A$ est *propre* si et seulement si A n'est pas entièrement atteint. Or, conditionnellement à ce que l'ensemble atteint par les arêtes internes soit exactement A' , aucune

arête ne va de A' vers $A \setminus A'$, événement de probabilité $\prod_{j \in A', k \in A \setminus A'} (1 - W_{jk})$ et indépendant de la réalisation interne à A' . En sommant les probabilités de ces sous-ensembles propres et en passant au complémentaire,

$$R(A) = 1 - \sum_{\substack{A' \subsetneq A \\ a \in A'}} R(A') \prod_{j \in A', k \in A \setminus A'} (1 - W_{jk}),$$

avec $R(\{a\}) = 1$. La récursion sur les sous-ensembles emboîtés est finie et détermine R de proche en proche. $\square$

Monotonie stochastique (proposition 6.5)

Démonstration. On construit un *couplage*. Soit (U_{jk}) une famille de variables uniformes sur $[0, 1]$ indépendantes, commune aux deux matrices. Pour une matrice M , déclarons l'arête $j \rightarrow k$ vivante si $U_{jk} < M_{jk}$; le graphe obtenu a la bonne loi (arête vivante avec probabilité M_{jk}). Si $W \leq W'$ terme à terme, alors $U_{jk} < W_{jk} \Rightarrow U_{jk} < W'_{jk}$: toute arête vivante sous W l'est sous W' . Le graphe sous W est donc un sous-graphe de celui sous W' , et l'accessibilité étant croissante par ajout d'arêtes, $S_a(W) \subseteq S_a(W')$ presque sûrement. Pour toute fonctionnelle φ croissante pour l'inclusion, $\varphi(S_a(W)) \leq \varphi(S_a(W'))$ p.s., d'où la domination stochastique et la monotonie de l'espérance et des quantiles. Enfin, pour une perturbation antisymétrique A , l'entrée W_{jk} croît quand W_{kj} décroît : les deux effets jouent en sens contraire sur S_a , la monotonie en A_{jk} n'a plus lieu, et l'optimum sur le pavé $\{|A_{jk}| \leq t S_{jk}\}$ doit être cherché aux sommets sans garantie qu'ils le réalisent. $\square$

Dépendance à l'ordre et non-identification (propositions 6.6 et 6.7)

Démonstration. *Ordre.* Soit $\sigma = (i_1, \dots, i_n)$ et σ' une permutation de σ . Alors $\ell(\sigma) = \ell(\sigma')$ pour toute paire si et seulement si le produit $\prod_k \text{TRANS}_{i_k i_{k+1}}$ ne dépend pas de l'ordre des facteurs disponibles, ce qui, pour $n = 2$, équivaut à $\text{TRANS}_{ij} = \text{TRANS}_{ji}$ pour tout (i, j) , soit la symétrie de TRANS. La contraposée donne le résultat : TRANS asymétrique implique l'existence d'une paire dont l'ordre change la vraisemblance, donc la criticité n'est pas une fonction de l'ensemble. Toute copule et tout score additif étant symétriques en leurs arguments, aucun ne reproduit cette dépendance.

Non-identification. La décomposition $W = \frac{1}{2}(W + W^\top) + \frac{1}{2}(W - W^\top) = S + A$ est unique car S est symétrique, A antisymétrique, et cette somme directe est celle des matrices en parties symétrique et antisymétrique. La co-occurrence observée d'une paire $\{j, k\}$ est, par échange des rôles, une fonction de $W_{jk} + W_{kj} = 2S_{jk}$ seulement ; de même la statistique d'asymétrie du placebo compare M à sa transposée et son espérance sous permutation ne dépend que de S . Donc W et $W^\top = S - A$ induisent les mêmes lois observables de co-occurrence. Ils diffèrent par le signe de A , et la proposition 6.5 montre qu'un tel changement modifie l'ensemble atteint, donc le SCR, en général : la direction est non identifiée. $\square$

B Démonstrations

Les preuves de stabilité de la cascade ($\rho(W) < 1$ par normalisation de Leontief) et de la propriété de branchement figurent au chapitre 7, avec leur vérification numérique. Cette annexe rassemble les démonstrations de la théorie des valeurs extrêmes sur lesquelles s'appuie la calibration de sévérité.

La loi limite H des maxima normalisés est *max-stable* : $H^t(x) = H(a_t x + b_t)$ pour tout $t > 0$. En posant $g(x) = -\ln H(x)$, la max-stabilité devient l'équation fonctionnelle $t g(a_t x + b_t) = g(x)$. Sa résolution (via la théorie des fonctions à variation régulière de Karamata) impose $g(x) = (1 + \xi x)^{-1/\xi}$, soit $H = H_\xi$. Le domaine d'attraction se caractérise ensuite par le comportement de queue : $F \in \text{DA}(H_\xi)$ avec $\xi > 0$ si et seulement si $\bar{F}$ est à variation régulière d'indice $-1/\xi$, i.e. $\bar{F}(tx)/\bar{F}(x) \rightarrow t^{-1/\xi}$. Les lois lognormale et gamma relèvent du cas $\xi = 0$ (Gumbel) ; les lois à support borné du cas $\xi < 0$ (Weibull).

Pour $F \in \text{DA}(H_\xi)$, il existe une fonction positive $a(\cdot)$ telle que, pour $y \geq 0$, $\lim_{u \rightarrow x_F} \bar{F}(u + y a(u))/\bar{F}(u) = (1 + \xi y)^{-1/\xi}$. Or $\bar{F}(u + y a(u))/\bar{F}(u) = \mathbb{P}(X > u + y a(u) \mid X > u) = 1 - F_u(y a(u))$, dont la limite est la survie GPD $\bar{G}_{\xi,1}(y)$. En posant $\sigma(u) = a(u)$, on obtient $F_u(y) \rightarrow G_{\xi,\sigma(u)}(y)$. La convergence est uniforme car les F_u sont des fonctions de répartition monotones convergeant vers une limite continue (théorème de Pólya). Le paramètre ξ est préservé car il gouverne à la fois la variation régulière de $\bar{F}$ et la forme de la GPD limite.

On part de la log-vraisemblance (5.9), écrite par observation avec $W_i = 1 + \xi Y_i/\sigma$:

$$\ell_i(\xi, \sigma) = -\ln \sigma - \left(1 + \frac{1}{\xi}\right) \ln W_i. \quad (\text{B.1})$$

Moments-clés. La transformation de probabilité intégrale donne $W_i^{-1/\xi} = \bar{G}(Y_i) \sim \mathcal{U}(0, 1)$, donc $W_i \stackrel{d}{=} U^{-\xi}$ avec $U \sim \mathcal{U}(0, 1)$. On en déduit les quatre moments qui suffisent au calcul :

$$\mathbb{E}[W^{-1}] = \mathbb{E}[U^\xi] = \frac{1}{1+\xi}, \quad \mathbb{E}[W^{-2}] = \frac{1}{1+2\xi}, \quad \mathbb{E}[\ln W] = -\xi \mathbb{E}[\ln U] = \xi, \quad \mathbb{E}[(\ln W)^2] = 2\xi^2, \quad (\text{B.2})$$

tous finis dès que $\xi > -\frac{1}{2}$ (condition assurant $\mathbb{E}[W^{-2}] < \infty$).

Score et hessienne. En dérivant ℓ_i ,

$$\partial_\xi \ell_i = \frac{1}{\xi^2} \ln W_i - \left(1 + \frac{1}{\xi}\right) \frac{Y_i/\sigma}{W_i}, \quad \partial_\sigma \ell_i = -\frac{1}{\sigma} + \left(1 + \frac{1}{\xi}\right) \frac{\xi Y_i/\sigma^2}{W_i}.$$

En prenant l'espérance de l'opposé des dérivées secondes et en substituant les moments ci-dessus, on obtient l'information de Fisher par observation

$$\mathcal{I}(\xi, \sigma) = \frac{1}{1 + 2\xi} \begin{pmatrix} 2 & \sigma^{-1} \\ \sigma^{-1} & \sigma^{-2}(1 + \xi) \end{pmatrix}, \quad \mathcal{I}^{-1} = (1 + \xi) \begin{pmatrix} 1 + \xi & -\sigma \\ -\sigma & 2\sigma^2 \end{pmatrix}. \quad (\text{B.3})$$

La variance asymptotique de $\hat{\xi}$ est le terme $(1, 1)$ de $\mathcal{I}^{-1}$ divisé par N_u , soit $(1 + \xi)^2/N_u$; celle de $\hat{\sigma}$ vaut $2\sigma^2(1 + \xi)/N_u$. Le terme hors-diagonal négatif $-\sigma(1 + \xi)$ traduit la corrélation négative entre $\hat{\xi}$ et $\hat{\sigma}$, retrouvée empiriquement sur le nuage *a posteriori* bayésien. C'est cette corrélation qui interdit de stresser ξ et σ indépendamment, et qui justifie le pivotement au centroïde retenu

au chapitre 11. La condition $\xi > -\frac{1}{2}$ garantit la finitude des moments impliqués, donc la validité de la normalité asymptotique classique de l'EMV (Smith, 1987).

Sous variation régulière $\bar{F}(x) = x^{-1/\xi}\ell(x)$ avec ℓ à variation lente, les log-espacements $\log X_{(i)} - \log X_{(i+1)}$ des k plus grandes statistiques d'ordre sont, à la limite, des variables exponentielles indépendantes d'espérance ξ/i (représentation de Rényi). L'estimateur $\hat{\xi}_{Hill}(k) = \frac{1}{k} \sum_{i=1}^k (\log X_{(i)} - \log X_{(k+1)})$ est alors une moyenne empirique d'espérance ξ et de variance ξ^2/k ; le théorème central limite donne $\sqrt{k}(\hat{\xi}_{Hill} - \xi) \xrightarrow{d} \mathcal{N}(0, \xi^2)$, sous la condition de second ordre $\sqrt{k} A(n/k) \rightarrow 0$ contrôlant le biais dû à ℓ .

La forme fermée de la VaR découle directement de l'inversion de la fonction de survie POT $\bar{F}(x) = \zeta_u(1 + \xi(x - u)/\sigma)^{-1/\xi}$. Pour la TVaR, on utilise $\text{TVaR}_\alpha = \frac{1}{1-\alpha} \int_\alpha^1 \text{VaR}_s ds$; la stabilité de la GPD (l'excès au-delà de tout seuil $v > u$ reste GPD de forme ξ et d'échelle $\sigma + \xi(v - u)$) donne $\mathbb{E}[X - \text{VaR}_\alpha \mid X > \text{VaR}_\alpha] = \frac{\sigma + \xi(\text{VaR}_\alpha - u)}{1 - \xi}$ pour $\xi < 1$, d'où (5.13). Pour $\xi \geq 1$, $\int_u^\infty \bar{F} = \infty$: la moyenne de queue diverge.

C Table des notations

Symbole	Signification
ξ, σ, u	Indice de queue, échelle et seuil POT de la GPD de sévérité
$\zeta_u = p_u$	Probabilité de dépassement du seuil $\mathbb{P}(X > u)$
N_u	Nombre d'excès au-delà de u
$\text{VaR}_\alpha, \text{TVaR}_\alpha$	Value-at-Risk et Tail-VaR (Expected Shortfall) au niveau $\alpha = 99,5 \%$
$\lambda, \lambda_{\text{eff}}$	Fréquence annuelle d'incidents ; fréquence de pertes non nulles
r, p	Paramètres de la loi binomiale négative de fréquence
θ	Paramètre de la copule de Gumbel ($\theta \geq 1$)
λ_U, λ_L	Coefficients de dépendance de queue supérieure / inférieure
τ	τ de Kendall
ρ	Corrélation d'actifs du modèle de Vasicek
Y, X_i, Z_i	Facteur systémique, facteur idiosyncratique, robustesse latente
$\text{PCD}_i(y)$	Probabilité conditionnelle de défaut de conformité
L_{DORA}, AC_k	Perte agrégée DORA ; contribution d'Euler de la brique k
Δ_{DORA}	Surcoût de capital imputable à la non-conformité
S_0, S_1, S_2	Scénarios conforme / partiel / non-conforme

Bibliographie

- Adrian Baldwin, Iffat Gheyas, Christos Ioannidis, David Pym, and Julian Williams. Contagion in cyber security attacks. *Journal of the Operational Research Society*, 68(7), 2017.
- Jan Beirlant, Yuri Goegebeur, Johan Segers, and Jozef Teugels. *Statistics of Extremes : Theory and Applications*. Wiley, 2004.
- Yannick Bessy-Roland, Alexandre Boumezoued, and Caroline Hillairet. Multivariate hawkes process for cyber insurance. *Annals of Actuarial Science*, 15(1) :14–39, 2021.
- Christian Biener, Martin Eling, and Jan Hendrik Wirfs. Insurability of cyber risk : An empirical analysis. *The Geneva Papers on Risk and Insurance – Issues and Practice*, 40 :131–158, 2015.
- Rainer Böhme and Gaurav Kataria. Models and measures for correlation in cyber-insurance. In *Workshop on the Economics of Information Security (WEIS)*, 2006.
- Alexandre Boumezoued, Yousra Cherkaoui, and Caroline Hillairet. Cyber risk modeling using a two-phase hawkes process with external excitation, 2023. arXiv :2311.15701.
- Benjamin Edwards, Steven Hutchings, and Stephanie Forrest. Hype and heavy tails : a closer look at data breaches. *Journal of Cybersecurity*, 2, 2016.
- Paul Embrechts, Claudia Klüppelberg, and Thomas Mikosch. *Modelling Extremal Events for Insurance and Finance*. Springer, 1997.
- Sébastien Farkas, Olivier Lopez, and Maud Thomas. Cyber claim analysis using generalized pareto regression trees with applications to insurance. *Insurance : Mathematics and Economics*, 98 : 92–105, 2021.
- Hemantha Herath and Tejaswini Herath. Copula-based actuarial model for pricing cyber-insurance policies. *Insurance Markets and Companies*, 2, 2011.
- Bruce M. Hill. A simple general approach to inference about the tail of a distribution. *The Annals of Statistics*, 3(5) :1163–1174, 1975.
- Caroline Hillairet and Olivier Lopez. Propagation of cyber incidents in an insurance portfolio : counting processes combined with compartmental epidemiological models. *Scandinavian Actuarial Journal*, 2021.
- Caroline Hillairet, Anthony Réveillac, and Mathieu Rosenbaum. An expansion formula for hawkes processes and application to cyber-insurance derivatives, 2021. arXiv :2104.01579, Stochastic Processes and their Applications (2023).
- Caroline Hillairet, Olivier Lopez, Louise d’Oultremont, and Briec Spooenberg. Cyber-contagion model with network structure applied to insurance. *Insurance : Mathematics and Economics*, 2022.
- Wassily Leontief. Quantitative input and output relations in the economic system of the united states. *The Review of Economics and Statistics*, 18(3), 1936.

- Yang Lu, Yaodi Zhang, and Wenjun Zhu. Cyber risk modeling : a discrete multivariate count process approach. *Scandinavian Actuarial Journal*, 2024(6), 2024.
- Munich Re. Cyber insurance : risks and trends – global market estimates, 2024. Primes cyber mondiales estimées de l'ordre de 15 milliards de dollars.
- Chen Peng, Maochao Xu, Shouhuai Xu, and Taizhong Hu. Modeling and predicting extreme cyber attack rates via marked point processes. *Journal of Applied Statistics*, 44(14), 2016.
- Richard L. Smith. Estimating tails of probability distributions. *The Annals of Statistics*, 15(3) : 1174–1207, 1987.
- Oldrich Vasicek. The distribution of loan portfolio value. *Risk*, 2002.
- Maochao Xu and Lei Hua. Cybersecurity insurance : modeling and pricing. *North American Actuarial Journal*, 2017.